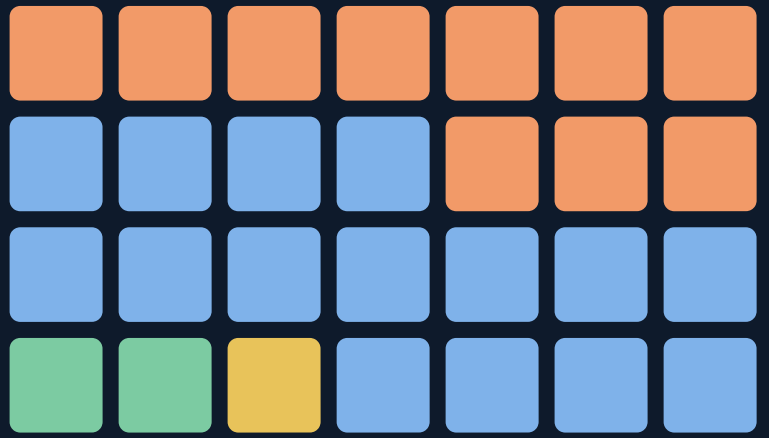
كورس تدريبي شامل · من الصفر إلى التطبيق

تطبيق الضوابط الأساسية للأمن السيبراني ECC-2:2024



المربعات هي المكونات الفرعية الثمانية والعشرون: الحوكمة 10 · التعزيز 15 · الصمود 1 · الأطراف الخارجية والسحابة 2

ماذا يطلب كل ضابط، وكيف تطبقه خطوة بخطوة، وكيف يبدو الدليل الذي يثبته.

مصمم للمبتدئين في الأمن السيبراني والامتثال، ومفيد لكل فريق يبدأ التطبيق فعلياً.

9 وحدات | 28 مكوناً فرعياً | أمثلة أدلة مصورة | تمارين واختبار نهائي

مقدمة الكورس

لمن هذا الكورس، وماذا تحتاج قبل البدء

المبتدئون في المجال

من يدخل الأمن السيبراني أو الامتثال لأول مرة، ويريد أن يفهم الضوابط ويطبقها لا أن يحفظها.

فرق تقنية المعلومات

من سينفذ الضوابط التقنية على الأنظمة والشبكات، ويحتاج أن يعرف ما المطلوب منه وما الدليل.

الحوكمة والمراجعة

فرق الامتثال والمراجعة الداخلية والموارد البشرية والمشتريات، فلكل منها دور في التطبيق.

قبل أن تبدأ

لا يشترط خبرة سابقة. يكفي إلمام عام بالحاسب والشبكات، ونسخة من وثيقة الضوابط الرسمية من موقع الهيئة. المصطلحات الجديدة مشروحة في الوحدة الأولى.

مقدمة الكورس

ماذا ستتعلم في هذا الكورس

لغة المجال

الأصل والتهديد والثغرة والخطر، وأنواع الضوابط والأدلة، وأهم المصطلحات.

فهم ECC-2:2024

النطاق والبنية، وكيف تقرأ رمز الضابط، والنمط الذي يتكرر في أغلب المكونات.

بناء برنامج التطبيق

المراحل والأولويات والأدوار، وكيف تنظم الأدلة من اليوم الأول.

تطبيق 28 مكوناً فرعياً

لكل مكون: شرح مبسط، ثم ما يطلبه كل ضابط، وكيف تنفذه، وما دليله.

التعرف على الأدلة

أمثلة مصورة لأدلة حقيقية ونماذج توضيحية، وما الذي يبحث عنه المقيّم فيها.

استدامة الامتثال

المراجعات الدورية والمؤشرات، والاستعداد لتقييم الهيئة.

مقدمة الكورس

خريطة الكورس: تسع وحدات

01 **مفاهيم أساسية**
لغة المجال: الأصول والمخاطر والضوابط والأدلة
الشرائح من 7 إلى 21

02 **أساسيات ECC-2:2024**
النطاق والبنية ونمط الضوابط
الشرائح من 22 إلى 30

03 **برنامج التطبيق**
المراحل والأدوار وسجل الأدلة
الشرائح من 31 إلى 39

04 **الحوكمة**
المكونات الفرعية 1-1 إلى 1-10
الشرائح من 40 إلى 73

05 **التعزيز (1)**
المكونات الفرعية 2-1 إلى 2-8
الشرائح من 74 إلى 109

06 **التعزيز (2)**
المكونات الفرعية 2-9 إلى 2-15
الشرائح من 110 إلى 143

07 **الصمود والأطراف الخارجية**
3-1 و4-1 و4-2
الشرائح من 144 إلى 158

08 **الاستدامة والجاهزية**
المراجعات والمؤشرات وتقييم الهيئة
الشرائح من 159 إلى 168

09 **الاختبار والختام**
أسئلة وخلاصة وتكليف عملي
الشرائح من 169 إلى 174

فهرس المكونات الفرعية الثمانية والعشرين

04 الحوكمة — الشريحة 40

1-1	الاستراتيجية	41
1-2	إدارة الأمن السيبراني	43
1-3	السياسات والإجراءات	46
1-4	الأدوار والمسؤوليات	49
1-5	إدارة المخاطر	51
1-6	الأمن في المشاريع	55
1-7	الالتزام بالتشريعات	59
1-8	المراجعة والتدقيق	61
1-9	الموارد البشرية	63
1-10	التوعية والتدريب	67

05 التعزيز (1) — الشريحة 74

2-1	إدارة الأصول	75
2-2	الهويات والصلاحيات	79
2-3	حماية الأنظمة	84
2-4	حماية البريد	88
2-5	أمن الشبكات	92
2-6	الأجهزة المحمولة	98
2-7	حماية البيانات	102
2-8	التشفير	104

06 التعزيز (2) — الشريحة 110

2-9	النسخ الاحتياطية	111
2-10	إدارة الثغرات	116
2-11	اختبار الاختراق	120
2-12	السجلات والمراقبة	124
2-13	الحوادث والتهديدات	129
2-14	الأمن المادي	133
2-15	تطبيقات الويب	138

07 الصمود والأطراف الخارجية — الشريحة 144

3-1	الأمن السيبراني في استمرارية الأعمال	145
4-1	الأطراف الخارجية	149
4-2	الحوسبة السحابية والاستضافة	153

مقدمة الكورس

كيف تقرأ شرائح هذا الكورس

تعريف المكون

شرح مبسط، ومثال من الحياة، وما يحدث لو غاب. ابدأ منها قبل الجداول.

الضوابط

جدول: رمز الضابط، وما يطلبه، وكيف تطبقه، والدليل. عمود الدليل ملوّن.

مثال الدليل

صورة حقيقية من الإنترنت أو نموذج توضيحي، مع ما يبحث عنه المقيّم.

تمرين وحل

تطبيق عملي على خلفية رمادية زرقاء، تليه شريحة الحل ونقاط النقاش.

أين أنا؟ شريط الخطوات أعلى الشريحة يبيّن موقعك داخل المكوّن.

تعريف — 2 الضوابط 1 من 2 — 3 الدليل

تنبيه مهم

عمودا «كيف تطبقه» و«الدليل» ممارسات مقترحة من الكورس، لا متطلبات إضافية من الهيئة. صياغات الضوابط مختصرة للشرح، والنص العربي الرسمي هو المرجع.

الوحدة 01

01 مفاهيم أساسية قبل أن نبدأ

لغة مشتركة نحتاجها طوال الكورس: ماذا نحمي، ومم نحميه، وكيف نثبت أننا نحميه.

01 ما الأمن السيبراني الشريحة 8

02 أهداف الحماية الثلاثة الشريحة 9

03 الأصل والتهديد والثغرة والخطر الشريحة 10

04 ما الضابط وأنواعه الشريحة 11

05 الامتثال ودور الهيئة الشريحة 12

06 ما الدليل وكيف يكون جيداً الشريحة 13

07 قاموس المصطلحات الشريحة 15

08 تمرين التصنيف الشريحة 20

ما الأمن السيبراني؟

ببساطة: حماية الشبكات والأنظمة والأجهزة والبيانات والخدمات الإلكترونية من أي اختراق أو تعطيل أو تعديل أو استخدام غير مشروع. وهذا ما نحميه:

البيانات

بيانات المستفيدين والموظفين، والبيانات المالية، والوثائق الرسمية.

الأنظمة والأجهزة

الخوادم، وأجهزة الموظفين، والتطبيقات، وقواعد البيانات.

الشبكات والخدمات

الشبكة الداخلية، والبريد، والبوابات الإلكترونية، والخدمات السحابية.

الأشخاص

الموظفون والمتعاقدون، وهم الهدف الأول لكثير من الهجمات مثل التصيد.

الفكرة الأساسية

الأمن السيبراني ليس منتجاً تشتريه مرة واحدة، بل منظومة من الأشخاص والإجراءات والتقنية تعمل معاً وتُراجع باستمرار.

أهداف الحماية الثلاثة: السرية والسلامة والتوافر

السرية

ألا يطّلع على المعلومة إلا المصرح له. مثال الإخلال: ملف رواتب يُرسل بالخطأ إلى بريد خارجي.

السلامة

أن تبقى المعلومة صحيحة كاملة، ولا تُعدَّل دون صلاحية. مثال الإخلال: تغيير رقم حساب بنكي في فاتورة.

التوافر

أن تكون الخدمة والمعلومة متاحة عند الحاجة. مثال الإخلال: توقف البوابة الإلكترونية بهجوم حجب خدمة.

تذكّر

تذكر ECC هذه الأهداف صراحة: منهجية إدارة المخاطر في الضابط 1-5-1 يجب أن تراعي السرية والسلامة والتوافر.

الأصل والتهديد والثغرة والخطر

الأصل

كل ما له قيمة ويحتاج حماية: خادم، تطبيق، بيانات، خدمة. وفي البيت: المجوهرات.

التهديد

ما قد يسبب ضرراً: مهاجم، برمجية فدية، موظف مهمل، حريق. وفي البيت: اللص.

الثغرة

ضعف يستغله التهديد: نظام بلا تحديث، كلمة مرور ضعيفة. وفي البيت: نافذة لا تُقفل.

الخطر

احتمال أن يستغل تهديدٌ ثغرةً فيصيب أصلاً، مع حجم الأثر. وفي البيت: احتمال السرقة وقيمة الخسارة.

الفكرة الأساسية

الخطر = الاحتمال × الأثر. والضابط إما يخفض الاحتمال، مثل قفل النافذة، أو يخفض الأثر، مثل خزنة للمجوهرات.

ما الضابط؟ وكيف نصنّف الضوابط

الضابط إجراء أو وسيلة تخفض الخطر: تمنع الحدث، أو تكشفه بسرعة، أو تحد من أثره وتعالجه. وهذه أمثلة من ECC لكل نوع:

طبيعة الضابط	وقائي: يمنع الحدث	كشفي: يكشفه عند وقوعه	تصحيحي: يعالجه ويحد من أثره
إداري (أشخاص وإجراءات)	سياسة الاستخدام المقبول والتوعية	مراجعة الصلاحيات الدورية	خطة الاستجابة للحوادث
تقني (أنظمة)	التحقق متعدد العوامل والجدار الناري	نظام إدارة الأحداث ومراقبة السجلات	الاستعادة من النسخ الاحتياطية
مادي (أماكن ومعدات)	بطاقات دخول غرفة الخوادم	كاميرات المراقبة وسجل الزوار	موقع بديل للتعافي من الكوارث

الفكرة الأساسية

ECC تجمع الأنواع كلها، ولهذا تجد فيها لجاناً وسياسات وتدريباً بجانب الأنظمة التقنية. وأقوى حماية تجمع طبقات من الأنواع الثلاثة.

الامتثال، والهيئة، والضوابط الأساسية

الامتثال

أن تطبق الجهة متطلبات محددة، وتثبت ذلك بأدلة يمكن التحقق منها.

الهيئة الوطنية للأمن السيبراني

الجهة المختصة بالأمن السيبراني في المملكة، وتصدر الضوابط والأطر وتتابع الالتزام بها.

الضوابط الأساسية ECC

الحد الأدنى من متطلبات الأمن السيبراني للجهات الوطنية. صدر إصدارها الأول عام 2018، والحالي ECC-2:2024.

كيف يُقاس الامتثال

بالتقييم الذاتي، وتقارير أداة الامتثال الدورية، والزيارات الميدانية، وفق آلية الهيئة.

الفكرة الأساسية

الامتثال ليس الهدف النهائي، فالهدف خفض المخاطر فعلاً. لكنه يعطينا حداً أدنى منظماً، وطريقة واضحة لإثبات أننا نطبقه.

ما الدليل؟ أربعة أنواع ستراها في كل الكورس

الدليل هو ما يثبت للمقيّم أن الضابط مطبق فعلاً، وله أربعة أنواع:

وثيقة

سياسة أو إجراء أو معيار معتمد. تثبت أن المتطلب محدد ومعتمد. مثال: سياسة النسخ الاحتياطي موقعة.

إعداد

لقطة أو تصدير من النظام. يثبت أن التقنية مضبوطة. مثال: إعداد التحقق متعدد العوامل.

سجل

أثر تشغيلي يتكرر بتواريخ. يثبت أن الممارسة تحدث فعلاً. مثال: تقارير فحص الثغرات الشهرية.

محضر

اجتماع أو مراجعة أو قرار موثق. يثبت أن المراجعة حدثت. مثال: محضر اللجنة الإشرافية.

نصيحة عملية

الضابط التشغيلي يحتاج غالباً أكثر من نوع: الوثيقة تقول ماذا نفعل، والإعداد يثبت أننا ضبطناه، والسجل يثبت أنه يعمل عبر الزمن.

متى يكون الدليل جيداً؟ أربعة أسئلة

1
مرتبط
يثبت الضابط المطلوب بعينه، ويحمل رمزه في اسمه.

2
يغطي النطاق كله
كل الأجهزة أو كل الحسابات المعنية، لا عينة مختارة.

3
حديث
ضمن الفترة التي يغطيها التقييم، لا لقطة قديمة.

4
قابل للتحقق
مصدره واضح، ويستطيع المقيّم رؤيته في النظام عند الطلب.

دليل ضعيف

لقطة شاشة لإعداد التحقق متعدد العوامل على حساب واحد، مأخوذة قبل سنة.

دليل قوي

تقرير من النظام بتاريخ هذا الشهر: 37 من 37 حساباً مميزاً مسجلة في التحقق، مع قائمة الحسابات من الدليل النشط للمقارنة.

قاموس المصطلحات (1): الهويات والوصول

الحساب Account

المعرّف الذي يدخل به المستخدم أو النظام، ويجب أن يكون فريداً لكل شخص.

التحقق متعدد العوامل MFA

إثبات الهوية بعاملين أو أكثر: شيء تعرفه كالكلمة السرية، وشيء تملكه كالجوال.

حساب ذو صلاحيات هامة Privileged

حساب يستطيع تغيير الأنظمة أو الوصول لكل البيانات، مثل مدير النظام.

الحد الأدنى من الصلاحيات Least Privilege

أن يُمنح كل شخص ما يحتاجه لعمله فقط، لا أكثر.

فصل المهام SoD

ألا ينفذ شخص واحد عملية حساسة كلها، مثل طلب الصلاحية واعتمادها معاً.

إدارة الصلاحيات المميزة PAM

نظام يحفظ كلمات مرور الحسابات المميزة، ويسجل جلساتها، ويمنحها مؤقتاً.

قاموس المصطلحات (2): الشبكات والأنظمة

الجدار الناري Firewall
جهاز أو برنامج يسمح بحركة الشبكة أو يمنعها حسب قواعد محددة.

تقسيم الشبكة Segmentation
فصل الشبكة إلى مناطق، مثل الخوادم والمستخدمين، بينها جدار ناري.

المنطقة المنزوعة السلاح DMZ
منطقة للخدمات المواجهة للإنترنت، معزولة عن الشبكة الداخلية.

الشبكة الافتراضية الخاصة VPN
قناة مشفرة يدخل منها الموظف عن بعد إلى شبكة الجهة.

نظام منع الاختراق IPS
يراقب حركة الشبكة، ويوقف الأنماط الهجومية المعروفة.

التحديثات والإصلاحات Patch
تحديث يصدره المورد لسد ثغرة أو إصلاح خلل في نظامه.

قاموس المصطلحات (3): المراقبة والاستجابة

سجل الأحداث Log

سطر يكتبه النظام عند كل حدث: من دخل، ومتى، وماذا فعل.

نظام إدارة الأحداث SIEM

منصة تجمع السجلات من الأنظمة، وتحللها، وتطلق التنبيهات.

مركز العمليات الأمنية SOC

الفريق والمنصة اللذان يراقبان التنبيهات باستمرار ويستجيبان لها.

حماية نقاط النهاية المتقدمة EDR

برنامج على الجهاز يكتشف السلوك المشبوه ويوقفه، لا التواقيع المعروفة فقط.

فحص الثغرات Vulnerability Scan

أداة آلية تبحث عن الثغرات المعروفة في الأنظمة.

اختبار الاختراق Penetration Test

محاكاة هجوم حقيقي يجريها مختص، ليعرف ما يمكن استغلاله فعلاً.

قاموس المصطلحات (4): البيانات والصمود

تصنيف البيانات Classification

تحديد مستوى حساسية البيانات، لتحديد كيف تُحمى وتُتداول.

التشفير Encryption

تحويل البيانات إلى صيغة لا يقرؤها إلا من يملك المفتاح.

النسخ الاحتياطي Backup

نسخة من البيانات والإعدادات تُحفظ لاستعادتها عند الفقد أو الهجوم.

أهداف الاستعادة RTO · RPO

أقصى مدة توقف مقبولة، وأقصى فقد بيانات مقبول، لكل نظام.

حماية البريد من الانتحال SPF · DKIM · DMARC

سجلات تثبت أن البريد المرسل باسم نطاق الجهة صادر منها فعلاً.

إدارة الأجهزة المحمولة MDM

نظام يفرض سياسة الجهة على الحواسيب والجوالات، ويمسحها عند الفقد.

قاموس المصطلحات (5): مصطلحات أخرى ستمر بها

جدار حماية تطبيقات الويب WAF
يحمي مواقع الويب من الهجمات على التطبيق نفسه، مثل حقن الأوامر.

حجب الخدمة الموزع DDoS
إغراق خدمة بطلبات كثيرة من أجهزة متعددة حتى تتوقف.

مؤشرات الاختراق IoC
آثار تدل على هجوم، مثل عنوان أو نطاق أو بصمة ملف ضار.

مقياس خطورة الثغرات CVSS
مقياس عالمي من 0 إلى 10 لتصنيف خطورة الثغرات.

منع تسرب البيانات DLP
تقنية تكشف خروج البيانات الحساسة عبر البريد أو الوسائط وتمنعه.

مزامنة التوقيت NTP
بروتوكول يوحّد ساعة كل الأنظمة، فتتطابق أوقات السجلات.

تمرين 1 · فردي · 10 دقائق

صنّف: أصل، أم تهديد، أم ثغرة، أم ضابط؟

لكل عنصر، اكتب نوعه. وإن كان ضابطاً، فاذكر طبيعته (إداري، تقني، مادي) ووظيفته (وقائي، كشفي، تصحيحي).

أ خادم قاعدة بيانات الموارد البشرية

ب رسالة تصيد تنتحل بنكاً معروفاً

ج نظام تشغيل لم يُحدَّث منذ سنة

د التحقق متعدد العوامل على البريد

هـ موظف يكتب كلمة المرور على ورقة بجانب الشاشة

و كاميرا عند باب غرفة الخوادم

ز البوابة الإلكترونية لخدمات المستفيدين

ح برمجية فدية تشفّر الملفات

حل التمرين 1

الحل ونقاط النقاش

العنصر	النوع	لماذا
أ · خادم قاعدة بيانات الموارد البشرية	أصل	يحوي بيانات حساسة للموظفين
ب · رسالة تصيد تنتحل بنكاً	تهديد	وسيلة هجوم تستهدف الموظفين
ج · نظام تشغيل بلا تحديث	ثغرة	ضعف معروف يمكن استغلاله
د · التحقق متعدد العوامل	ضابط تقني وقائي	يمنع الدخول بكلمة مرور مسروقة
هـ · كلمة المرور على ورقة	ثغرة	سلوك يسهل سرقة الحساب
و · كاميرا عند غرفة الخوادم	ضابط مادي كشفي	يكشف الدخول ويسجله، مع أثر رادع
ز · البوابة الإلكترونية	أصل	خدمة مهمة مواجهة للإنترنت
ح · برمجية فدية	تهديد	تمس التوافر، وقد تمس السرية

الوحدة 02

02 أساسيات ECC-2:2024

ما الضوابط، ومن يلتزم بها، وكيف بُنيت، والنمط الذي يتكرر في أغلب المكونات الفرعية.

01 التعريف والأساس النظامي الشريحة 23

02 النطاق وقابلية التطبيق الشريحة 24

03 البنية وقراءة رمز الضابط الشريحة 25

04 ECC والضوابط المكملة الشريحة 26

05 الطبقات الأربع الشريحة 27

06 هرم الوثائق الشريحة 28

07 تمرين ربط الأدلة الشريحة 29

ما الضوابط الأساسية، ولماذا هي ملزمة

التعريف

الحد الأدنى من متطلبات الأمن السيبراني للجهات الوطنية، مبني على أفضل الممارسات والمعايير، لتقليل التهديدات الداخلية والخارجية على أصولها المعلوماتية والتقنية.

الأساس النظامي

المادة العاشرة (الفقرة 3) من تنظيم الهيئة، والأمر السامي رقم 57231 وتاريخ 10/11/1439هـ: على الجهات اتخاذ ما يلزم لضمان الالتزام المستمر بالضوابط.

أهداف الحماية الثلاثة

السرية · السلامة · التوافر

الركائز الأربع

الاستراتيجية · الأشخاص · الإجراءات · التقنية

الفكرة الأساسية

الكلمة المفتاحية «الحد الأدنى»: الضوابط ليست وصفاً لجهة مثالية، بل الأرضية التي لا يجوز النزول عنها.

من يلتزم، وما الذي ينطبق، وكيف يُقاس

نطاق العمل

الجهات الحكومية من وزارات وهيئات ومؤسسات وغيرها، وشركاتها والجهات التابعة لها داخل المملكة وخارجها. وجهات القطاع الخاص التي تملك أو تشغّل أو تستضيف بنى تحتية وطنية حساسة.

قابلية التطبيق

تلتزم الجهة بكل الضوابط المنطبقة عليها، وبعضها يختلف حسب طبيعة عملها والتقنيات التي تستخدمها. مثال الوثيقة: ضوابط 2-4 ملزمة لمن يستخدم الحوسبة السحابية والاستضافة أو يخطط لاستخدامها.

قياس الامتثال

تقيّم الهيئة الامتثال بالتقييم الذاتي، وتقارير أداة الامتثال الدورية، والزيارات الميدانية، وفق الآلية التي تراها، وتصدر أداة خاصة لتقييم الامتثال لـ ECC-2:2024.

نصيحة عملية

القاعدة العملية: كل الضوابط منطبقة إلا ما تثبت الجهة عدم انطباقه بمبرر موثق ومعتمد.

البنية بالأرقام، وكيف تقرأ رمز الضابط

4
مكونات أساسية

28
مكوناً فرعياً

108
ضوابط أساسية

92
ضابطاً فرعياً

كيف تقرأ رمز الضابط: المثال 2-3-2-2، ويُقرأ من اليسار إلى اليمين

2	-	2	-	3	-	2
المكون الأساسي		المكون الفرعي		الضابط الأساسي		الضابط الفرعي
التعزيز		الهويات والصلاحيات		الحد الأدنى		التحقق متعدد العوامل

ECC هي الأساس، وفوقها ضوابط مكملة

CSCC
الأنظمة الحساسة
للجهات التي لديها أنظمة حساسة

CCC
الحوسبة السحابية
لمقدمي الخدمات السحابية والمستفيدين منها

DCC
البيانات
لحماية البيانات حسب مستوى تصنيفها

OTCC
الأنظمة التشغيلية
للأنظمة الصناعية والتشغيلية

TCC
العمل عن بعد
عند إتاحة العمل عن بعد

OSMACC
حسابات التواصل الاجتماعي
للحسابات الرسمية للجهة

ECC-2:2024 الأساس لكل جهة داخل النطاق؛ والضوابط المكملة تضيف عليها ولا تحل محلها. تحقق من الإصدار الحالي لكل وثيقة ونطاقها في موقع الهيئة.

الطبقات الأربع: النمط الذي يتكرر في أغلب المكونات

أغلب المكونات الفرعية مبنية بالترتيب نفسه. حرف X يعني رقم المكون، فالمثال في 2-9 النسخ الاحتياطية: 1-9-2 ثم 2-9-2 ثم 3-9-2 ثم 4-9-2.

01

حدّد ووثّق واعتمد

X-1 · المخرج: وثيقة متطلبات معتمدة. الدليل: الوثيقة واعتمادها ودليل تعميمها.

02

طبّق

X-2 · المخرج: ضوابط تقنية وتشغيلية تعمل. الدليل: إعدادات وسجلات تغطي النطاق كله.

03

غطّ الحد الأدنى

X-3 · المخرج: كل بند فرعي مغطى في الوثيقة والتطبيق. الدليل: دليل مستقل لكل بند.

04

راجع دورياً

X-4 · المخرج: مراجعة مجدولة بنتائج وإجراءات. الدليل: تقرير أو محضر مؤرخ.

تذكّر

يتكرر النمط في أغلب مكونات التعزيز وفي 1-3 و2-4. أما الحوكمة و1-2 و2-7 و1-4 فلها صياغات خاصة، فاقرأها ضابطاً ضابطاً.

هرم الوثائق: من الاستراتيجية إلى السجل



تمرين 2 · ثنائي · 15 دقيقة

أي ضابط يثبته هذا الدليل؟

لكل دليل: حدّد رمز الضابط الذي يثبته، والطبقة (X-1 إلى X-4) أو نوع الضابط. استخدم وثيقة الضوابط.

أ محضر اجتماع لمراجعة تطبيق متطلبات إدارة الثغرات

ب سياسة النسخ الاحتياطي موقعة من صاحب الصلاحية

ج تقرير اختبار استعادة نسخة احتياطية لنظام الموارد البشرية

د إعدادات تُظهر التحقق متعدد العوامل على الشبكة الافتراضية الخاصة

هـ تذاكر معالجة تنبيهات نظام إدارة الأحداث خلال الشهر

و بريد تعميم سياسة الاستخدام المقبول على الموظفين

ز عقد مركز مراقبة مُدار ينص على أن تشغيله بالكامل داخل المملكة

ح تقرير فحص الثغرات الدوري لخوادم الإنتاج

حل التمرين 2

كل دليل وضابطه

الدليل	الضابط	الطبقة أو النوع
أ · محضر مراجعة إدارة الثغرات	2-10-4	X-4 مراجعة دورية
ب · سياسة النسخ الاحتياطي المعتمدة	2-9-1	X-1 توثيق واعتماد
ج · اختبار استعادة النسخ	2-9-3-3	X-3 حد أدنى
د · التحقق متعدد العوامل للدخول عن بعد	2-2-3-2	X-3 حد أدنى (جزئي)
هـ · المراقبة المستمرة للسجلات	2-12-3-4	X-3 حد أدنى
و · تعميم سياسة الاستخدام المقبول	2-1-3	سياسة الاستخدام المقبول
ز · مركز مُدار داخل المملكة	4-1-3-2	متطلب عقود الأطراف الخارجية
ح · الفحص الدوري للثغرات	2-10-3-1	X-3 حد أدنى

الوحدة 03

03 برنامج التطبيق

كيف تحوّل 108 ضوابط إلى برنامج له مراحل وأولويات ومالكون وأدلة.

01 المراحل الخمس الشريحة 32

02 الاعتماديات الشريحة 33

03 موجات التنفيذ الشريحة 34

04 الأدوار والمسؤوليات الشريحة 35

05 سجل الأدلة الشريحة 36

06 تمرين ترتيب المبادرات الشريحة 38

خمس مراحل لبرنامج التطبيق

المرحلة	أهم الأنشطة	المخرج
1 · التأسيس	دعم صاحب الصلاحية، والإدارة المستقلة واللجنة الإشرافية، والأدوار، ونطاق البرنامج	ميثاق البرنامج المعتمد
2 · تقييم الوضع الحالي	تقييم فجوات لكل ضابط، وحصر أولي للأصول، وتحديد ما لا ينطبق بمبرر	سجل الفجوات وأولوياتها
3 · التصميم والتوثيق	الاستراتيجية، والسياسات والإجراءات، والمعايير التقنية، ومنهجية المخاطر	حزمة وثائق معتمدة ومعممة
4 · التنفيذ	مشاريع تقنية وتشغيلية حسب الأولوية، وتعديل العقود، والتدريب والتوعية	ضوابط مفعّلة وأدلة مسجلة
5 · التشغيل والاستدامة	مراجعات دورية، ومؤشرات، ومراجعة وتدقيق مستقل، وتقييم ذاتي، وتحديث الوثائق	تقارير دورية للجنة الإشرافية

الاعتماديات: ما يجب أن يسبق ماذا

ابدأ بهذا أولاً	لأنه شرط لهذه الضوابط
2-1 حصر الأصول وتصنيفها	حماية البيانات حسب التصنيف 2-7 · التشفير 2-8 · نطاق النسخ 2-9 · سجلات الأصول الحساسة 2-12
1-5 منهجية إدارة المخاطر	تقييمات المشاريع 3-5-1 · مخاطر الموردين قبل التعاقد 1-3-1-4 · معالجة الثغرات حسب المخاطر 3-3-10-2
2-2 حصر الحسابات المميزة	التحقق متعدد العوامل لها 2-2-3-2 · إدارة الصلاحيات المميزة 4-3-2-2 · سجلاتها 2-3-12-2
1-2 و1-4 الإدارة والأدوار	كل ما سواها: لا اعتماد ولا تنفيذ ولا مراجعة بلا مالك محدد
2-13-3-2 تصنيف الحوادث	خطط التصعيد 1-3-13-2 · الإبلاغ للهيئة 3-3-13-2 · خطط الاستمرارية 2-3-1-3

نصيحة عملية

استثناء: المكاسب السريعة التي لا تعتمد على شيء، مثل التحقق متعدد العوامل للدخول عن بعد وسجلات DMARC، تبدأ فوراً.

مثال توضيحي لجهة متوسطة الحجم

خارطة طريق مقترحة: ثلاث موجات

الموجة 1 · 0–3 أشهر

التأسيس والمكاسب السريعة

- الإدارة واللجنة والأدوار · 1-2 و1-4
- الاستراتيجية والسياسات الأساسية · 1-1 و1-3
- حصر أولي للأصول · 2-1
- التحقق متعدد العوامل للدخول عن بعد · 2-2-3-2
- SPF وDKIM وDMARC · 2-4-3-5
- الاحتفاظ بالسجلات 12 شهراً · 2-12-3-5

الموجة 2 · 3–9 أشهر

البنية الأساسية للحماية

- إدارة الصلاحيات المميزة · 2-2-3-4
- الثغرات والتحديثات · 2-10 و2-3-3-3
- تقسيم الشبكة وعزل الاختبار · 2-5-3-1 و2-5-3-2
- المراقبة ونظام إدارة الأحداث · 2-12
- النسخ واختبار الاستعادة · 2-9
- برنامج التوعية والتدريب · 1-10

الموجة 3 · 9–18 شهراً

النضج والاستدامة

- اختبار الاختراق الدوري · 2-11
- الاستمرارية والتعافي من الكوارث · 3-1
- عقود الأطراف الخارجية والسحابة · 1-4 و2-4
- حماية البيانات والتشفير الكامل · 2-7 و2-8
- المراجعة والتدقيق المستقل · 2-8-1
- دورة المراجعات الدورية الأولى · X-4

من يفعل ماذا في التطبيق

الدور	المسؤولية	ضوابط مرتبطة
صاحب الصلاحية	يعتمد الاستراتيجية والسياسات والهيكل والأدوار، ويدعم البرنامج	1-1-1 · 1-3-1 · 1-4-1
اللجنة الإشرافية	تضمن الالتزام وتدعمه وتتابعه، وتتلقى نتائج المراجعة والتدقيق	1-2-3 · 1-8-3
إدارة الأمن السيبراني	توثق المتطلبات، وتتأكد من تطبيقها، وتراجعها دورياً	1-3 · 1-5 · 1-8-1
تقنية المعلومات	تنفذ الضوابط التقنية وتشغّلها وتوفر أدلتها	أغلب 2-x
الموارد البشرية	متطلبات ما قبل التوظيف وأثناءه وعند انتهائه	1-9
المشتريات والقانونية	بنود الأمن السيبراني في العقود والاتفاقيات	4-1 · 4-2
جهة مستقلة	مراجعة وتدقيق مستقل عن إدارة الأمن السيبراني	1-8-2
ملاك الأصول	تصنيف أصولهم، واعتماد الصلاحيات عليها ومراجعتها	2-1-5 · 2-2-3-5

سجل الأدلة: نظّمه من اليوم الأول

حقول السجل المقترحة

رقم الدليل | رمز الضابط | الوصف | النوع | المالك | تاريخ الإنشاء | موعد التحديث | الموقع | الحالة

- دليل واحد قد يخدم عدة ضوابط: اربطه بها ولا تكرره
- لكل دليل تشغيلي موعد تحديث، وإلا تقادم
- المستودع مقيد الصلاحيات، فالإعدادات نفسها معلومات حساسة
- احتفظ بالإصدارات السابقة لإثبات الاستمرارية

مثال تسمية الملف: الرمز أولاً، ثم رقم الدليل، ثم الوصف، ثم التاريخ

```
ECC-2-2-3-2_EV01_MFA-VPN-config_2026-09.pdf
```

كيف يبدو سجل الأدلة عملياً

ما الذي تراه

1. لكل ضابط صف: الدليل، ومالكه، وتاريخه، وحالته.
2. التاريخ يكشف الدليل القديم قبل أن يكتشفه المقيّم.
3. الحالة تحول السجل إلى قائمة عمل واضحة.

ما الذي يبحث عنه المقيّم

- أن الدليل في السجل موجود فعلاً ويمكن فتحه.
- أن التاريخ ضمن فترة التقييم.
- أن الدليل يغطي النطاق كله لا عينة صغيرة.

يثبت: 1-8-1 كل الضوابط

سجل الأدلة · ECC-2:2024

الضابط	الدليل	المالك	التاريخ	الحالة
1-3-1	محضر اعتماد حزمة السياسات	مدير الحوكمة	2026-02-10	معتمد
2-2-3-2	تقرير تغطية التحقق للمميزة	مدير الهويات	2026-09-30	ناقص · %59
2-9-3-3	محضر اختبار استعادة	مدير البنية	2026-09-21	سليم
2-12-3-5	إعداد الاحتفاظ بالسجلات	مدير العمليات	2026-08-14	سليم
4-1-2	عينة عقود بملحق الأمن	المشتريات	2025-11-03	متأخر · يحتاج تحديث

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

تمرين 3 · مجموعات · 20 دقيقة

رتّب المبادرات الثماني في ثلاث موجات

جهة حكومية تبدأ تطبيق ECC من الصفر. ضع كل مبادرة في موجة، واذكر ما تعتمد عليه.

- أ — شراء نظام لتشفير البيانات المخزنة
- ب — تشكيل اللجنة الإشرافية للأمن السيبراني
- ج — حصر الأصول المعلوماتية والتقنية وتصنيفها
- د — تفعيل التحقق متعدد العوامل للدخول عن بعد
- هـ — التعاقد مع مركز عمليات أمنية مُدار
- و — اعتماد منهجية إدارة مخاطر الأمن السيبراني
- ز — تشغيل نظام إدارة الأحداث (SIEM)
- ح — أول مراجعة مستقلة لتطبيق الضوابط

حل التمرين 3

ترتيب مقترح ومبرراته

المبادرة	الموجة	تعتمد على
ب · اللجنة الإشرافية	1	قرار صاحب الصلاحية فقط
د · التحقق متعدد العوامل	1	لا شيء؛ مكسب سريع يخفض خطراً حقيقياً
ج · حصر الأصول وتصنيفها	1	الأدوار وملاك الأصول
و · منهجية المخاطر	1	الإدارة واللجنة لاعتمادها
ز · نظام إدارة الأحداث	2	معرفة الأصول الحساسة (ج) لتحديد ما يُراقب
هـ · مركز عمليات مُدار	2	تقييم مخاطر قبل التعاقد (و)، ومركز داخل المملكة
أ · نظام التشفير	2 أو 3	التصنيف (ج) والمعايير الوطنية للتشفير
ح · المراجعة المستقلة	3	وجود ضوابط مطبقة تُراجع

الوحدة 04 · المكون الأساسي 1

04 حوكمة الأمن السيبراني

من يقرر، ومن ينفذ، ومن يراجع: الاستراتيجية والإدارة والسياسات والأدوار والمخاطر والموظفون والتوعية.

1-1	الاستراتيجية	الشريحة 41	
1-2	إدارة الأمن السيبراني	الشريحة 43	
1-3	السياسات والإجراءات	الشريحة 46	
1-4	الأدوار والمسؤوليات	الشريحة 49	
1-5	إدارة المخاطر	الشريحة 51	
1-6	الأمن في المشاريع	الشريحة 55	
1-7	الالتزام بالتشريعات	الشريحة 59	
1-8	المراجعة والتدقيق	الشريحة 61	
1-9	الموارد البشرية	الشريحة 63	
1-10	التوعية والتدريب	الشريحة 67	

1-1 استراتيجية الأمن السيبراني

هدف الوثيقة أن تسهم خطط الجهة وأهدافها ومبادراتها ومشاريعها في الالتزام بالمتطلبات التشريعية والتنظيمية ذات العلاقة.

ببساطة

خطة عليا لعدة سنوات تحدد إلى أين تريد الجهة أن تصل في الأمن السيبراني، وما المبادرات والميزانية التي توصلها، وكيف تقيس التقدم.

مثال من الحياة

مثل خطة سفر: الوجهة، والطريق، والميزانية، ومحطات التوقف. بلا خطة تتحرك الفرق في اتجاهات مختلفة.

ماذا لو غاب؟

مبادرات متفرقة بلا أولويات ولا ميزانية واضحة، ولا تعرف الإدارة هل يتقدم الأمن السيبراني أم يتراجع.

صاحب الصلاحية
رئيس الجهة أو من يفوضه، وهو من يعتمد

خطة العمل
المبادرات بمالك وموعد وميزانية

المؤشر
رقم يقيس التقدم نحو الهدف

استراتيجية الأمن السيبراني: الضوابط الثلاثة

الضابط	المطلوب	كيف تطبقه	الدليل
1-1-1 توثيق واعتماد	**تحديد الاستراتيجية وتوثيقها واعتمادها بدعم صاحب الصلاحية، ومواءمتها مع المتطلبات**	صُغ رؤية وأهدافاً لثلاث سنوات من نتائج تقييم الفجوات والمخاطر، واربط كل هدف بمتطلب نظامي	وثيقة الاستراتيجية بتوقيع الاعتماد وتاريخه، وجدول مواءمة الأهداف مع المتطلبات
1-1-2 تطبيق	**تنفيذ خطة عمل لتطبيق الاستراتيجية**	حوّل كل هدف إلى مبادرات بمالك وميزانية وموعد ومؤشر، وتابعها في اللجنة	خطة العمل المعتمدة، وتقارير المتابعة، ومحاضر اللجنة الإشرافية
1-1-3 مراجعة دورية	**مراجعة الاستراتيجية على فترات مخطط لها أو عند تغير المتطلبات**	حدّد موعد المراجعة في الوثيقة نفسها، وأضف محفزاً عند صدور تنظيم جديد	محضر مراجعة مؤرخ، وسجل تغييرات الوثيقة

خطأ شائع

استراتيجية عامة منقولة بلا أهداف خاصة بالجهة ولا ميزانية ولا مؤشرات، تُعتمد ثم لا تُنفذ؛ فتسقط في 2-1-1.

1-2 إدارة الأمن السيبراني

هدف الوثيقة التزام صاحب الصلاحية ودعمه لتطبيق برامج الأمن السيبراني وإدارتها في الجهة.

ببساطة

إدارة متخصصة للأمن السيبراني، مستقلة عن تقنية المعلومات، يشغلها سعوديون متفرغون ومؤهلون، ومعها لجنة إشرافية تتابع العمل.

مثال من الحياة

مثل المراجع الداخلي في الشركة: لا يتبع الإدارة التي يراجع عليها، حتى يقول الحقيقة دون حرج.

ماذا لو غاب؟

تقنية المعلومات تراقب نفسها، فتتأخر المعالجات حين تتعارض مع أولويات التشغيل، ولا يصل صوت الأمن إلى الإدارة العليا.

الاستقلال
ألا تتبع الإدارة إدارة تقنية المعلومات

اللجنة الإشرافية
لجنة عليا تدعم البرنامج وتتابعه

التوطين
وظائف بسعوديين متفرغين ومؤهلين

إدارة الأمن السيبراني: ثلاثة متطلبات وطنية

الضابط	المطلوب	كيف تطبقه	الدليل
1-2-1 متطلب وطني	**إدارة للأمن السيبراني مستقلة عن تقنية المعلومات والاتصالات (الأمر السامي 37140)**	قرار بإنشاء الإدارة وتحديد ارتباطها، ويوصى بارتباطها برئيس الجهة أو من يفوضه دون تعارض مصالح	القرار الإداري، والهيكل التنظيمي المعتمد يُظهر الاستقلال وخط الارتباط
1-2-2 متطلب وطني	**شغل جميع الوظائف بسعوديين متفرغين ومؤهلين**	حصر كل وظائف الأمن السيبراني، وخطة توطين وتأهيل لكل وظيفة لا تحقق الشرط	قائمة الوظائف وشاغليها: الجنسية والتفرغ والمؤهلات، وخطة سد الشواغر
1-2-3 متطلب وطني	**لجنة إشرافية بأعضاء ومسؤوليات وإطار حوكمة معتمد، ورئيس إدارة الأمن السيبراني عضو فيها**	قرار تشكيل، وميثاق يحدد الأعضاء والصلاحيات والنصاب ودورية الاجتماع؛ ويوصى بارتباطها برئيس الجهة	قرار التشكيل، والميثاق المعتمد، ومحاضر الاجتماعات وقراراتها

خطأ شائع

إدارة «مستقلة» بالاسم، لكنها ترفع تقاريرها إلى مدير تقنية المعلومات، فلا تحقق 1-2-1.

كيف يبدو الدليل: محضر اللجنة الإشرافية

ما الذي تراه

1. قرار مرقّم يمكن الرجوع إليه: اعتماد خارطة الطريق.
2. متابعة رقمية لمبادرة، لا عبارة عامة مثل «جارٍ العمل».
3. تكليف بمالك وموعد، وتوقيع رئيس اللجنة وأمينها.

ما الذي يبحث عنه المقيّم

- أن رئيس إدارة الأمن السيبراني عضو حاضر، كما ينص 1-2-3.
- أن الاجتماعات تتكرر فعلاً، بمحاضر لأكثر من فترة.
- أن قرارات الاجتماع السابق تُتابع في اللاحق.

يثبت: 1-2-3 1-1-2 1-8-3

محضر اجتماع اللجنة الإشرافية للأمن السيبراني · الاجتماع 3/2026

التاريخ	2026-09-14
الحضور	رئيس اللجنة، ورئيس إدارة الأمن السيبراني، ورئيس تقنية المعلومات، و4 أعضاء
النصاب	مكتمل وفق الميثاق

- القرار 3/1: اعتماد خارطة طريق تطبيق ECC-2:2024
- متابعة: التحقق متعدد العوامل للحسابات المميزة 22 من 37 (59%)
- تكليف: تقنية المعلومات بإكمال الباقي قبل 2026-11-30
- عرض نتائج التقييم الذاتي للربع الثالث

رئيس اللجنة
التوقيع والتاريخ

أمين اللجنة
التوقيع والتاريخ

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

1-3 سياسات وإجراءات الأمن السيبراني

هدف الوثيقة توثيق متطلبات الأمن السيبراني والتزام الجهة بها ونشرها.

ببساطة

كتابة ما تلتزم به الجهة في وثائق رسمية: سياسات تقول ماذا، وإجراءات تقول كيف، ومعايير تقنية تقول ما الإعداد الصحيح، يعتمدها صاحب الصلاحية وتُعمَّم.

مثال من الحياة

مثل أنظمة المرور: القانون هو السياسة، وخطوات استخراج الرخصة هي الإجراء، والمواصفات الفنية للسيارة هي المعيار.

ماذا لو غاب؟

كل فريق يعمل باجتهاده، ولا يوجد مرجع يُحاسب عليه أحد، ولا يعرف المقيّم ما الذي التزمت به الجهة أصلاً.

السياسة
ماذا نلتزم به ولماذا

الإجراء
خطوات التنفيذ ومن ينفذها

المعيار التقني
الإعدادات الآمنة لكل تقنية

السياسات والإجراءات: الكتابة والاعتماد والتطبيق والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
1-3-1 توثيق واعتماد	**توثيق السياسات والإجراءات واعتمادها من صاحب الصلاحية وتعميمها**	حزمة تغطي كل المكونات الفرعية بقالب ورقم إصدار موحد، ثم الاعتماد والنشر	الوثائق بتوقيع الاعتماد، وجدول تغطية الضوابط، ودليل التعميم
1-3-2 تطبيق	**تأكد إدارة الأمن السيبراني من تطبيقها**	فحوص التزام دورية، وإجراء معتمد للاستثناءات بمدة ومبرر	تقارير فحص الالتزام، وسجل الاستثناءات بموافقاتها
1-3-3 معايير تقنية	**دعمها بمعايير تقنية (الجدار الناري، قواعد البيانات، أنظمة التشغيل)**	معيار تقوية لكل تقنية رئيسية، مبني على مرجع معروف مثل CIS Benchmarks	المعايير المعتمدة، ونتائج فحص مطابقة الإعدادات لها
1-3-4 مراجعة دورية	**مراجعتها وتحديثها دورياً أو عند تغير المتطلبات، مع توثيق التغييرات واعتمادها**	موعد مراجعة لكل وثيقة، وسجل تغييرات، وإعادة اعتماد عند التعديل	سجل الإصدارات والتغييرات، ومحضر المراجعة، والاعتماد الجديد

كيف يبدو الدليل: صفحة اعتماد سياسة

ما الذي تراه

1. جدول ضبط الوثيقة: رمز، ومالك، ومعتمِد، وتواريخ.
2. ربط صريح بالضوابط التي تغطيها السياسة.
3. سجل تغييرات وطريقة تعميم موثقة.

ما الذي يبحث عنه المقيّم

- أن المعتمِد صاحب الصلاحية، لا مدير الأمن السيبراني وحده.
- أن موعد المراجعة لم يفت، وأن التغييرات موثقة ومعتمدة.
- دليل وصول السياسة إلى المعنيين، والإقرار أقوى من البريد.

يثبت: 1-3-1 1-3-4 2-9-1

سياسة النسخ الاحتياطي · الإصدار 2.0

معتمد

رمز الوثيقة	POL-BKP-01
المالك	إدارة الأمن السيبراني
المعتمِد	صاحب الصلاحية: [الاسم والمنصب]
تاريخ الاعتماد	2026-06-10
موعد المراجعة	2027-06-10
الضوابط المغطاة	2-9-4 · 2-9-3 · 2-9-1

- سجل التغييرات: الإصدار 2.0 أضاف اختبار الاستعادة كل ربع سنة
- التعميم: بريد عام وإقرار اطلاع إلكتروني لفرق التقنية

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

1-4 أدوار ومسؤوليات الأمن السيبراني

هدف الوثيقة تحديد أدوار ومسؤوليات واضحة لكل الأطراف المشاركة في تطبيق الضوابط.

ببساطة

تحديد من يفعل ماذا في الأمن السيبراني بالاسم: من يعتمد، ومن ينفذ، ومن يراجع، دون تعارض في المصالح.

مثال من الحياة

مثل فريق كرة قدم: لكل لاعب مركز ومهمة واضحة، وإلا ركض الجميع خلف الكرة وتُرك المرمى.

ماذا لو غاب؟

مهام تسقط بين الإدارات لأن كلاً منها يظنها مسؤولية غيره، وشخص واحد يمنح الصلاحيات ويراجعها بنفسه.

مصفوفة المسؤوليات
من ينفذ ويعتمد ويُستشار ويُبلَّغ

تعارض المصالح
أن يراجع الشخص عمله بنفسه

التكليف
قرار رسمي يسمي الشخص ودوره

الأدوار والمسؤوليات: الاعتماد والتكليف والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
1-4-1 توثيق واعتماد	**يحدد صاحب الصلاحية الأدوار ويعتمدها، ويكلّف الأشخاص ويدعمهم دون تعارض مصالح**	وثيقة أدوار مع مصفوفة مسؤوليات لكل مكون فرعي، وتكليفات رسمية بالأسماء، وفحص لتعارض المصالح	الوثيقة المعتمدة، والمصفوفة، وقرارات التكليف، والأوصاف الوظيفية
1-4-2 مراجعة دورية	**مراجعة الأدوار والمسؤوليات وتحديثها دورياً أو عند تغير المتطلبات**	مراجعة عند كل تغيير تنظيمي وفي موعد مخطط، وتحديث التكليفات عند تغير الأشخاص	محضر المراجعة، والنسخة المحدثة، وتكليفات البدلاء

أطراف تغطيها الوثيقة عادة

صاحب الصلاحية · اللجنة الإشرافية · إدارة الأمن السيبراني · تقنية المعلومات · الموارد البشرية · القانونية والمشتريات · المراجعة الداخلية · ملاك الأصول · جميع العاملين

1-5 إدارة مخاطر الأمن السيبراني

هدف الوثيقة إدارة المخاطر السيبرانية بمنهجية لحماية الأصول المعلوماتية والتقنية للجهة.

ببساطة

طريقة منظمة لاكتشاف ما قد يضر الجهة، وتقدير احتماله وأثره، ثم تقرير ما نفعله تجاهه، وفي أوقات محددة منها قبل المشاريع والعقود الجديدة.

مثال من الحياة

مثل الفحص الطبي الدوري، وقبل أي عملية جراحية: نقيس ونقرر قبل أن نبدأ، لا بعد أن تقع المشكلة.

ماذا لو غاب؟

تُصرف الميزانية على ما يخيف أكثر لا على ما يضر أكثر، وتُطلق خدمات وتوقَّع عقود دون معرفة مخاطرها.

سجل المخاطر
قائمة المخاطر بتقييمها ومالكها ومعالجتها

قبول المخاطر
قرار معتمد بالتعايش مع خطر معروف

خطة المعالجة
إجراءات لخفض الخطر بموعد ومالك

إدارة المخاطر: المنهجية والتطبيق والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
1-5-1 توثيق واعتماد	**منهجية وإجراءات لإدارة المخاطر موثقة ومعتمدة، تراعي السرية والسلامة والتوافر**	منهجية متوافقة مع الإطار الوطني لإدارة المخاطر: معايير الأثر والاحتمالية، ومصفوفة، ومستوى مقبول، وأدوار	المنهجية المعتمدة، ومعايير الأثر والاحتمالية، ونموذج سجل المخاطر
1-5-2 تطبيق	**تطبيق المنهجية والإجراءات**	تقييمات دورية للأصول والخدمات المهمة، وسجل مخاطر حي، وخطط معالجة بمالكين ومواعيد	تقارير التقييم، وسجل المخاطر المحدث، وخطط المعالجة ومتابعتها
1-5-4 مراجعة دورية	**مراجعة المنهجية وتحديثها دورياً أو عند تغير المتطلبات والمعايير**	مراجعة بعد كل دورة تقييم، وعند صدور متطلبات أو معايير جديدة	محضر المراجعة، وسجل التغييرات، والاعتماد الجديد

تذكّر

تفاصيل التقييم خطوة بخطوة في الكورس الأول من السلسلة: تقييم المخاطر وفق الإطار الوطني لإدارة مخاطر الأمن السيبراني.

1-5-3: متى يجب تقييم المخاطر

الضابط	المطلوب	كيف تطبقه	الدليل
1-5-3-1 حالات التقييم	**في المراحل المبكرة لمشاريع التقنية**	بوابة إلزامية في منهجية المشاريع: لا تصميم قبل تقييم المخاطر	تقييمات لعينة مشاريع، مؤرخة قبل مرحلة التصميم
1-5-3-2 حالات التقييم	**قبل التغييرات الجوهرية في البنية التقنية**	حقل إلزامي في طلب التغيير، مع تعريف معتمد للتغيير الجوهري	طلبات تغيير جوهرية مرفق بها تقييم سابق للموافقة
1-5-3-3 حالات التقييم	**عند التخطيط للحصول على خدمات طرف خارجي**	خطوة إلزامية في إجراء المشتريات قبل الطرح أو الترسية	تقييمات لعقود حديثة، مؤرخة قبل التوقيع
1-5-3-4 حالات التقييم	**عند التخطيط لخدمات أو منتجات تقنية جديدة وقبل إطلاقها**	قائمة تحقق إطلاق تشترط تقييم مخاطر معتمداً	تقييم معتمد وموافقة إطلاق لخدمة جديدة

كيف يبدو الدليل: سجل مخاطر حي

ما الذي تراه

1. كل خطر مكتوب كجملة واضحة، بمستوى ومالك.
2. لكل خطر حالة: معالجة بموعد، أو قبول معتمد.
3. تاريخ تحديث حديث في عنوان السجل.

ما الذي يبحث عنه المقيّم

- أن السجل يُحدَّث فعلاً، بتواريخ متغيرة عبر الزمن.
- أن قبول المخاطر معتمد ممن يملك الصلاحية بحسب المنهجية.
- أن المخاطر العالية لها خطط معالجة يظهر تقدمها.

سجل مخاطر الأمن السيبراني · آخر تحديث 2026-09-30

الخطر	المستوى	المالك	الحالة
حسابات مميزة بلا تحقق متعدد العوامل	عالٍ	مدير البنية	معالجة · 2026-11
نسخ احتياطية متصلة بالشبكة فقط	عالٍ	مدير الأنظمة	معالجة · 2027-01
مورد دعم فني بدخول عن بعد دائم	متوسط	المشتريات	معالجة · 2026-12
خادم قديم لا يدعمه المورد	متوسط	مالك التطبيق	قبول مؤقت معتمد

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 1-5-2 1-5-1

6-1 الأمن السيبراني في إدارة المشاريع

هدف الوثيقة تضمين متطلبات الأمن السيبراني في منهجية المشاريع وإجراءاتها لحماية الأصول المعلوماتية والتقنية.

ببساطة

إدخال متطلبات الأمن في كل مشروع تقني وكل تغيير من بدايته، وفحصه قبل الإطلاق، وتطوير البرمجيات بطريقة آمنة.

مثال من الحياة

مثل اشتراطات الدفاع المدني في البناء: تُراعى في المخطط من البداية، فإضافتها بعد البناء أصعب وأغلى.

ماذا لو غاب؟

أنظمة تُطلق بثغرات معروفة وإعدادات افتراضية، ثم تُكتشف بعد أن تصبح في الإنتاج ويصعب إصلاحها.

إدارة التغيير
إجراء لاعتماد أي تعديل على الأنظمة

بوابة الإطلاق
فحص يجب اجتيازه قبل التشغيل

التطوير الآمن
برمجة بممارسات تمنع الثغرات

الأمن في المشاريع وإدارة التغيير

الضابط	المطلوب	كيف تطبقه	الدليل
1-6-1 توثيق واعتماد	**تضمين المتطلبات في منهجية المشاريع وإدارة التغيير، كجزء أساسي من متطلبات المشروع**	متطلبات أمنية في كل مرحلة من دورة المشروع، وممثل للأمن السيبراني في لجنة التغيير	منهجية المشاريع وإجراء التغيير المحدثان، وعينة مشاريع بمتطلبات أمنية
1-6-2-1 بوابة الإطلاق	**تقييم الثغرات ومعالجتها في المشاريع والتغييرات**	فحص ثغرات إلزامي قبل الإطلاق، وإغلاق الحرجة والعالية قبل التشغيل	تقارير فحص قبل الإطلاق، ودليل المعالجة أو قبول المخاطر
1-6-2-2 بوابة الإطلاق	**مراجعة الإعدادات والتقوية والتحديثات قبل الإطلاق**	قائمة تحقق إطلاق مقابل المعايير التقنية في 3-3-1	قوائم تحقق موقعة لعينة من المشاريع والتغييرات
1-6-4 مراجعة دورية	**مراجعة متطلبات إدارة المشاريع دورياً**	مراجعة المنهجية مع عينة من المشاريع المنفذة	تقرير المراجعة ونتائج العينة

تعريف — 2 الضوابط 2 من 3

1-6-3: مشاريع تطوير البرمجيات (1)

الضابط	المطلوب	كيف تطبقه	الدليل
1-6-3-1 تطوير البرمجيات	**استخدام معايير التطوير الآمن**	معيار تطوير آمن معتمد مثل إرشادات OWASP، وتدريب المطورين، ومراجعة الشيفرة	المعيار المعتمد، وسجلات مراجعة الشيفرة أو الفحص الساكن
1-6-3-2 تطوير البرمجيات	**مصادر موثوقة ومرخصة لأدوات التطوير والمكتبات**	مستودع داخلي معتمد للمكتبات، وفحص مكونات الطرف الثالث وتراخيصها	قائمة المصادر المعتمدة، وتقارير فحص المكونات
1-6-3-3 تطوير البرمجيات	**اختبار مطابقة البرمجيات لمتطلبات الأمن السيبراني**	اختبار أمني قبل الإطلاق: فحص ديناميكي أو اختبار اختراق للتطبيق	تقارير الاختبار ومعالجة نتائجه قبل الإطلاق

1-6-3: مشاريع تطوير البرمجيات (2)

الضابط	المطلوب	كيف تطبقه	الدليل
1-6-3-4 تطوير البرمجيات	**التكامل الآمن بين التطبيقات**	مصادقة بين الأنظمة، وتشفير قنوات التكامل، وبوابة للواجهات البرمجية	تصميم التكامل، وإعدادات المصادقة والتشفير للواجهات
1-6-3-5 تطوير البرمجيات	**مراجعة الإعدادات والتقوية والتحديثات قبل الإطلاق**	قائمة تحقق إطلاق للتطبيق وبيئته مقابل المعايير التقنية	قائمة التحقق الموقعة لكل إصدار

نصيحة عملية

إن كان التطوير مسنداً لمورد، فانقل هذه المتطلبات إلى العقد، واطلب منه أدلة الالتزام: مراجعة الشيفرة وفحص المكونات والاختبار الأمني.

1-7 الالتزام بالتشريعات والتنظيمات والمعايير

هدف الوثيقة التزام برنامج الأمن السيبراني بالمتطلبات التشريعية والتنظيمية ذات العلاقة.

ببساطة

إن كانت على الجهة اتفاقيات أو التزامات دولية معتمدة محلياً فيها متطلبات أمن سيبراني، فعليها أن تحددها وتلتزم بها.

مثال من الحياة

مثل شركة طيران تلتزم بأنظمة الطيران الدولية فوق أنظمة بلدها: عليها أن تعرف ما يخصها منها بالضبط.

ماذا لو غاب؟

مخالفة التزام دولي لم يعرف به أحد في الجهة، لأنه لم يُحصر ولم يُربط بالضوابط والسياسات.

سجل الالتزامات
الالتزامات ومتطلباتها ومالكوها

ضابط شرطي
ينطبق إن وُجد شرطه

مذكرة عدم الوجود
وثيقة تثبت البحث ونتيجته

الالتزام بالتشريعات: ضابط واحد شرطي

الضابط	المطلوب	كيف تطبقه	الدليل
1-7-1 ضابط شرطي	**إن وُجدت اتفاقيات أو التزامات دولية معتمدة محلياً فيها متطلبات سيبرانية، تحددها الجهة وتلتزم بها**	سجل يحصر الاتفاقيات والالتزامات الدولية ومتطلباتها السيبرانية، ويربط كل متطلب بمالك وضوابط	سجل الالتزامات المعتمد، وتقييم الالتزام بكل متطلب، أو مذكرة معتمدة بعدم وجودها

01
اجمع
قائمة الاتفاقيات والالتزامات من الشؤون القانونية

02
استخرج
متطلبات الأمن السيبراني بنصها

03
اربط
كل متطلب بالضوابط والسياسات الداخلية

04
حدّث
السجل عند كل اتفاقية أو التزام جديد

8-1 المراجعة والتدقيق الدوري

هدف الوثيقة التأكد من أن الضوابط مطبقة وتعمل وفق سياسات الجهة والمتطلبات الوطنية والدولية المفروضة عليها نظاماً.

ببساطة

فحص منتظم: هل الضوابط مطبقة فعلاً وتعمل؟ مرة من إدارة الأمن السيبراني نفسها، ومرة من جهة مستقلة عنها، وتُعرض النتائج على الإدارة العليا.

مثال من الحياة

مثل اختبارات الطلاب: المعلم يقيّم طلابه، ولجنة خارجية تراجع التقييم لضمان الحياد.

ماذا لو غاب؟

تظن الجهة أنها ممتثلة لأن أحداً لم يفحص، وتكتشف الفجوات لأول مرة في تقييم الهيئة.

التقييم الذاتي
مراجعة تجريها إدارة الأمن السيبراني

التدقيق المستقل
من جهة لا تتبع الأمن السيبراني

الإجراء التصحيحي
خطوة لإغلاق ملاحظة بمالك وموعد

المراجعة والتدقيق: داخلي ومستقل وعرض للنتائج

الضابط	المطلوب	كيف تطبقه	الدليل
1-8-1 مراجعة داخلية	**تراجع إدارة الأمن السيبراني تطبيق الضوابط دورياً**	خطة مراجعة تغطي كل المكونات الفرعية، بأداة الهيئة أو منهجية مكافئة	خطة المراجعة، وتقارير التقييم الذاتي، ومتابعة الملاحظات
1-8-2 تدقيق مستقل	**مراجعة وتدقيق من جهة غير إدارة الأمن السيبراني، باستقلالية ووفق معايير التدقيق المتعارف عليها**	إدراج الأمن السيبراني في خطة المراجعة الداخلية، أو التعاقد مع مراجع خارجي مؤهل	خطة التدقيق، والتقرير المستقل، وإقرار الاستقلالية
1-8-3 عرض النتائج	**توثيق النتائج وعرضها على اللجنة وصاحب الصلاحية: النطاق والملاحظات والتوصيات والمعالجة**	تقرير بقالب ثابت يشمل العناصر المطلوبة، وبند دائم في جدول أعمال اللجنة	التقارير المعروضة، ومحاضر اللجنة، وخطط المعالجة ومتابعتها

9-1 الأمن السيبراني في الموارد البشرية

هدف الوثيقة إدارة مخاطر العاملين، موظفين ومتعاقدين، قبل العمل وأثناءه وعند انتهائه.

ببساطة

حماية الجهة من مخاطر الموظفين والمتعاقدين في ثلاث مراحل: قبل التعيين، وأثناء العمل، وعند انتهاء العلاقة، وأهمها إلغاء الصلاحيات فوراً.

مثال من الحياة

مثل مفاتيح المكتب: تُسلَّم للموظف بعد التحقق منه، ويتعلم الحفاظ عليها، وتُستعاد يوم مغادرته.

ماذا لو غاب؟

موظف غادر قبل شهر وما زال بريده وحسابه في الشبكة الافتراضية يعملان، وهذه من أكثر الملاحظات تكراراً.

عدم الإفصاح
سرية المعلومات أثناء العمل وبعده

المسح الأمني
تحقق قبل تعيين الوظائف الحساسة

إخلاء الطرف
إجراء الانتهاء ومنه إلغاء الصلاحيات

الموارد البشرية: المتطلبات العامة وعند الانتهاء

الضابط	المطلوب	كيف تطبقه	الدليل
1-9-1 توثيق واعتماد	**تحديد المتطلبات للمراحل الثلاث وتوثيقها واعتمادها**	سياسة أمن الموارد البشرية بالتنسيق مع إدارة الموارد البشرية، تغطي المراحل الثلاث	السياسة المعتمدة
1-9-2 تطبيق	**تطبيق المتطلبات**	دمج المتطلبات في إجراءات التعيين والتهيئة وإنهاء الخدمة	عينة ملفات عاملين تثبت تطبيق كل مرحلة
1-9-5 عند الانتهاء	**مراجعة الصلاحيات وإلغاؤها فور انتهاء العمل أو إنهائه**	ربط نظام الموارد البشرية بنظام الهويات، أو إشعار فوري لفريق الصلاحيات بكل إنهاء	مقارنة تواريخ انتهاء الخدمة بتواريخ تعطيل الحسابات، ونماذج إخلاء الطرف
1-9-6 مراجعة دورية	**مراجعة المتطلبات دورياً**	مراجعة السياسة مع عينة من التطبيق	محضر المراجعة ونتائج العينة

قبل التعيين وأثناء العمل

الضابط	المطلوب	كيف تطبقه	الدليل
1-9-3-1 قبل التعيين	**بنود مسؤوليات الأمن السيبراني وعدم الإفصاح في العقود، أثناء العمل وبعده**	تعديل نماذج العقود مع الشؤون القانونية، وملحق للعقود القائمة	نموذج العقد المعتمد، وعينة عقود موقعة
1-9-3-2 قبل التعيين	**المسح الأمني أو التحقق لوظائف الأمن السيبراني والوظائف التقنية ذات الصلاحيات الهامة والحساسة**	تحديد هذه الوظائف بالاسم، وتحقق قبل التعيين وفق الأنظمة المعمول بها	قائمة الوظائف المشمولة، ونتائج التحقق لعينة منها
1-9-4-1 أثناء العمل	**التوعية عند بداية العمل وخلاله**	وحدة توعية إلزامية ضمن التهيئة، وتوعية مستمرة عبر برنامج 1-10	سجلات إكمال التوعية للموظفين الجدد والحاليين
1-9-4-2 أثناء العمل	**تطبيق المتطلبات والالتزام بها وفق السياسات والإجراءات**	إقرار دوري بالاطلاع على السياسات، وربط المخالفات بالإجراءات التأديبية	إقرارات موقعة، وسجل المخالفات ومعالجتها

كيف يبدو الدليل: مطابقة إنهاء الخدمة بتعطيل الحسابات

ما الذي تراه

1. قائمة من انتهت خدماتهم من الموارد البشرية، مقابل تاريخ تعطيل الحساب.
2. حالتان فيهما فجوة، وكلتاهما لمتعاقدين.
3. فترة محددة في عنوان التقرير.

ما الذي يبحث عنه المقيّم

- أن القائمة كاملة للفترة، وتشمل المتعاقدين لا الموظفين فقط.
- أن التعطيل يشمل البريد والشبكة الافتراضية والأنظمة الرئيسية.
- إجراءً تصحيحياً للعملية، لا لحساب واحد.

مطابقة إنهاء الخدمات مع تعطيل الحسابات · أغسطس–سبتمبر 2026

الموظف	انتهاء الخدمة	تعطيل الحساب	الحالة
موظف 1041	2026-08-03	2026-08-03	سليم
موظف 1077	2026-08-17	2026-08-18	سليم
متعاقد 2210	2026-08-21	لم يُعطَّل	نشط بعد 26 يوماً
متعاقد 2234	2026-09-05	2026-09-12	متأخر 7 أيام

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 1-9-5 2-2-3-5

10-1 برنامج التوعية والتدريب

هدف الوثيقة أن يمتلك العاملون الوعي اللازم، ويعرفوا مسؤولياتهم، ويحصلوا على المهارات والتدريب المطلوب.

ببساطة

توعية كل العاملين بالمخاطر وكيف يتصرفون بأمان، وتدريب متخصص لمن يعمل في الأمن السيبراني والتقنية وللقيادات.

مثال من الحياة

مثل تعليم القيادة: كل السائقين يتعلمون أنظمة المرور، وسائق الإسعاف يحتاج تدريباً إضافياً لعمله.

ماذا لو غاب؟

أغلب الهجمات تبدأ برسالة تصيد يفتحها موظف لم يتعلم كيف يميزها، مهما كانت التقنية قوية.

التصيد
رسالة تنتحل جهة موثوقة لسرقة بيانات

محاكاة التصيد
رسائل تجريبية لقياس وعي الموظفين

مصفوفة المهارات
ربط كل دور بالتدريب الذي يحتاجه

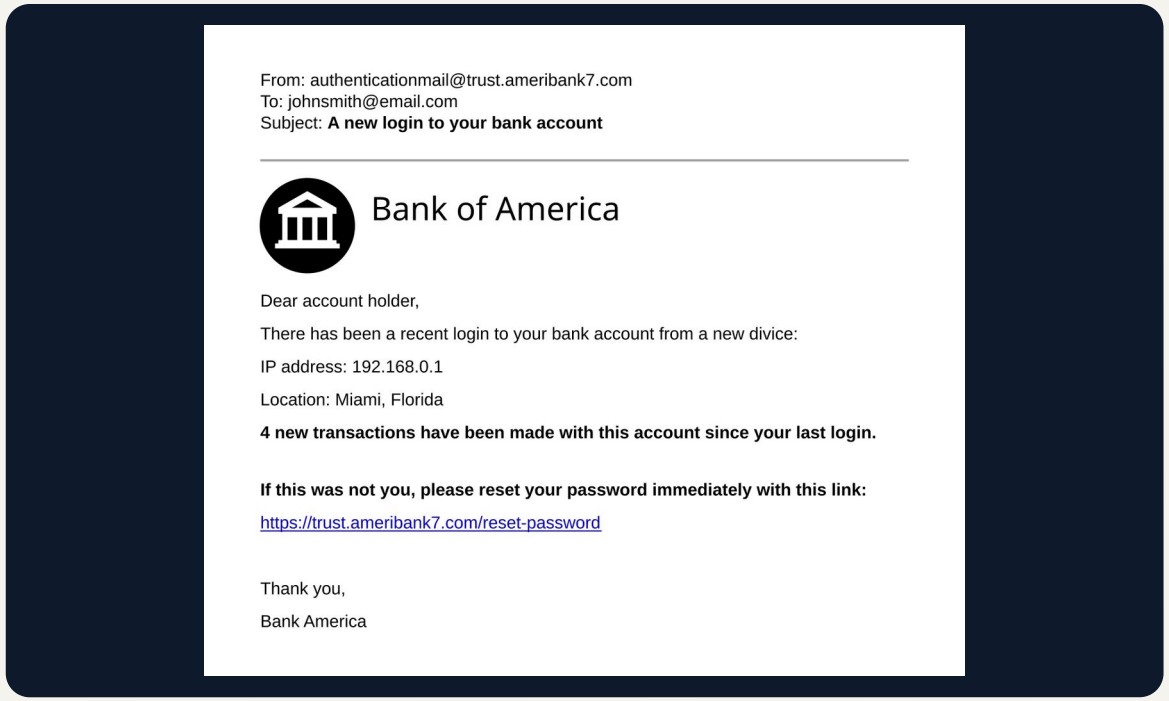
التوعية: البرنامج والتطبيق والمحتوى والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
1-10-1 توثيق واعتماد	**برنامج توعية عبر قنوات متعددة، يُطوَّر ويُعتمد دورياً**	خطة سنوية بالموضوعات والقنوات: بريد، ومنصة تعلم، وورش، ورسائل، وشاشات	البرنامج المعتمد بتاريخه وقنواته وجمهوره
1-10-2 تطبيق	**تطبيق البرنامج المعتمد**	تنفيذ الأنشطة وقياس الحضور والإكمال لكل فئة	سجلات الإكمال ونسبها، ومواد الحملات المنشورة
1-10-3 حد أدنى	**يشمل: البريد والتصيد، والأجهزة المحمولة ووسائط التخزين، والتصفح، ووسائل التواصل**	محتوى مخصص لكل موضوع، وتمارين تصيد محاكاة دورية	محتوى لكل موضوع من الأربعة، ونتائج محاكاة التصيد
1-10-5 مراجعة دورية	**مراجعة تطبيق البرنامج دورياً**	قياس الفعالية: نسب النقر في المحاكاة، ونتائج الاختبارات، والبلاغات	تقرير المراجعة ومؤشرات الفعالية

1-10-4: التدريب المتخصص حسب الدور

الضابط	المطلوب	كيف تطبقه	الدليل
1-10-4 تدريب متخصص	**مهارات وتدريب متخصص للوظائف المرتبطة مباشرة بالأمن السيبراني، مصنف حسب المسؤوليات**	تحليل احتياج: مصفوفة دور × مهارة × تدريب، ثم خطة سنوية بالميزانية	مصفوفة الأدوار والمهارات المعتمدة، وخطة التدريب السنوية
1-10-4-1 تدريب متخصص	**منسوبو إدارة الأمن السيبراني**	خطة تطوير فردية لكل موظف: شهادات مهنية وتدريب تقني حسب دوره	خطط التطوير الفردية، وسجلات التدريب والشهادات
1-10-4-2 تدريب متخصص	**العاملون في تطوير البرمجيات وعلى الأصول التقنية**	التطوير الآمن للمطورين، والتقوية والتشغيل الآمن لفرق التقنية	سجلات التدريب لعينة من المطورين والمشغلين
1-10-4-3 تدريب متخصص	**الوظائف التنفيذية والإشرافية**	جلسات للقيادات عن المخاطر والمسؤوليات وتمارين أزمات	سجلات حضور القيادات ومحتوى الجلسات

كيف يبدو المحتوى: مثال لرسالة تصيد



صورة حقيقية من الإنترنت للتوضيح · Isochrone، تعديل CC BY-SA 4.0 · Belbury · المصدر: Wikimedia Commons

ما الذي تراه

1. رسالة تنتحل جهة معروفة وتطلب إجراءً عاجلاً.
2. رابط أو مرفق يقود إلى صفحة لسرقة البيانات.
3. علامات يتعلمها الموظف: المرسل، والإلحاح، والرابط.

ما الذي يبحث عنه المقيّم

- أن محتوى التوعية يغطي البريد والتصيد كما ينص 1-10-3.
- أن الأمثلة حديثة وتعكس التهديدات الحالية.
- سجلات إكمال التوعية لكل الفئات.

يثبت: `1-10-3` `1-10-2`

كيف يبدو الدليل: تقرير محاكاة التصيد

ما الذي تراه

1. ثلاث حملات متتالية بالأرقام نفسها، فالمقارنة ممكنة.
2. نسبة من نقروا على الرابط، ونسبة من أبلغوا عن الرسالة.
3. اتجاه واضح بين الحملات، لا رقم واحد.

ما الذي يبحث عنه المقيّم

- أن البرنامج نُفذ فعلاً عبر الزمن، لا مرة واحدة.
- أن المراجعة في 1-10-5 تستخدم هذه الأرقام لتحسين البرنامج.
- أن نتائج الفئات الأعلى خطراً تُتابع بتدريب إضافي.

تقرير محاكاة التصيد · 2026

الحملة	المستلمون	نقروا	أبلغوا
حملة 1 · فبراير	1,200	18%	6%
حملة 2 · مايو	1,200	11%	14%
حملة 3 · أغسطس	1,250	7%	23%

الاتجاه: نسبة النقر تنخفض ونسبة الإبلاغ ترتفع بعد كل حملة توعية.

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 1-10-5 1-10-2

تمرين 4 · مجموعات · 20 دقيقة

ست حالات حوكمة: ما الضابط، وما الإجراء؟

لكل حالة: حدّد الضابط الذي لا تحققه الجهة، واقترح إجراءً تصحيحياً محدداً بمالك.

1. مدير الأمن السيبراني يرفع تقاريره إلى مدير تقنية المعلومات.
2. السياسات معتمدة بتوقيع مدير الأمن السيبراني وحده.
3. محللان في مركز العمليات متعاقدان بدوام جزئي.
4. خدمة إلكترونية جديدة أُطلقت بلا تقييم مخاطر «لأنها عاجلة».
5. موظف انتهت خدمته قبل ثلاثة أسابيع وحساب بريده ما زال نشطاً.
6. المراجعة السنوية للضوابط تجريها إدارة الأمن السيبراني فقط.

حل التمرين 4

الضابط والإجراء التصحيحي

الحالة	الضابط	الإجراء التصحيحي المقترح
1 · الارتباط بالتقنية	1-2-1	قرار من صاحب الصلاحية بنقل الارتباط، وتحديث الهيكل المعتمد
2 · اعتماد السياسات	1-3-1	رفع الحزمة لصاحب الصلاحية لاعتمادها، ثم إعادة التعميم
3 · الوظائف	1-2-2	خطة توطين وتعيين بدوام كامل بموعد محدد، تُعرض على اللجنة
4 · خدمة بلا تقييم	1-5-3-4	تقييم مخاطر لاحق فوري، وجعل التقييم شرطاً في قائمة الإطلاق
5 · حساب نشط	1-9-5	تعطيل فوري، ومراجعة كل المنتهية خدماتهم، وربط الموارد البشرية بالهويات
6 · مراجعة غير مستقلة	1-8-2	إدراج الأمن السيبراني في خطة المراجعة الداخلية أو مراجع خارجي

الوحدة 05 · المكون الأساسي 2

05 تعزيز الأمن السيبراني (1)

الحماية الأساسية للأصول والوصول والبنية: ماذا نملك، ومن يدخل، وكيف نحمي الأجهزة والبريد والشبكات والبيانات.

2-1 إدارة الأصول الشريحة 75

2-2 الهويات والصلاحيات الشريحة 79

2-3 حماية الأنظمة الشريحة 84

2-4 حماية البريد الشريحة 88

2-5 أمن الشبكات الشريحة 92

2-6 الأجهزة المحمولة الشريحة 98

2-7 حماية البيانات الشريحة 102

2-8 التشفير الشريحة 104

2-1 إدارة الأصول

هدف الوثيقة قائمة جرد دقيقة ومحدثة بتفاصيل كل الأصول المعلوماتية والتقنية، لدعم العمليات ومتطلبات الأمن السيبراني.

ببساطة

معرفة كل ما تملكه الجهة من أجهزة وأنظمة وبيانات وخدمات في سجل محدث، ولكل أصل مالك وتصنيف، مع سياسة واضحة للاستخدام المقبول.

مثال من الحياة

مثل جرد المستودع: لا تستطيع حماية بضاعة لا تعرف أنها موجودة، ولا أين وضعتها.

ماذا لو غاب؟

خادم منسي لا يحدثه أحد ولا يراقبه يصبح باب المهاجم، لأنه خارج كل الضوابط الأخرى.

سجل الأصول
قائمة مركزية بكل الأصول وتفاصيلها

مالك الأصل
المسؤول من الأعمال عن الأصل

الاستخدام المقبول
ما يُسمح وما يُمنع للعاملين

إدارة الأصول: السياسة والسجل والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
2-1-1 توثيق واعتماد	**تحديد متطلبات إدارة الأصول وتوثيقها واعتمادها**	سياسة تغطي الحصر والملكية ودورة حياة الأصل من الاقتناء إلى الإتلاف	السياسة المعتمدة
2-1-2 تطبيق	**تطبيق متطلبات إدارة الأصول**	سجل مركزي يُحدَّث آلياً قدر الإمكان من أدوات الاكتشاف، ولكل أصل مالك من الأعمال	سجل الأصول بتاريخ تحديث حديث، ومطابقة عينة بين السجل والواقع
2-1-6 مراجعة دورية	**مراجعة متطلبات إدارة الأصول دورياً**	مراجعة المتطلبات، ومطابقة دورية للسجل مع نتائج الاكتشاف الآلي	تقرير المراجعة ونتائج المطابقة

حقول مقترحة لسجل الأصول

المعرّف · النوع · المالك · الموقع · التصنيف · الأهمية · النظام والإصدار · العنوان الشبكي · مواجه للإنترنت؟ · آخر تحديث

الاستخدام المقبول وتصنيف الأصول

الضابط	المطلوب	كيف تطبقه	الدليل
2-1-3 توثيق وتعميم	**تحديد سياسة الاستخدام المقبول وتوثيقها واعتمادها وتعميمها**	سياسة قصيرة وواضحة: المسموح والممنوع في الأجهزة والبريد والإنترنت والبيانات	السياسة المعتمدة، ودليل تعميمها
2-1-4 تطبيق	**تطبيق سياسة الاستخدام المقبول**	إقرار عند التعيين وبشكل دوري، وضوابط تقنية تفرض أهم بنودها	إقرارات موقعة لعينة عاملين، وإعدادات تقنية داعمة
2-1-5 التصنيف	**تصنيف الأصول وترميزها والتعامل معها وفق المتطلبات التشريعية والتنظيمية**	اعتماد مستويات التصنيف الوطنية، وترميز الوثائق والأجهزة، وقواعد تعامل لكل مستوى	حقل التصنيف في سجل الأصول، وعينة وثائق مرمّزة، وقواعد التعامل المعتمدة

الفكرة الأساسية

التصنيف هو مفتاح 2-7 و2-8 و2-9: مستوى الحماية والتشفير ونطاق النسخ كلها تُبنى عليه.

كيف يبدو الدليل: نظام لجرد الأصول



صورة حقيقية من الإنترنت للتوضيح · GLPI project (Teclib') · مقتطعة · GPL-3.0 · المصدر: GitHub · glpi-project/glpi

ما الذي تراه

1. لوحة أداة جرد: عدد الأجهزة والبرمجيات وأجهزة الشبكة حسب النوع.
2. رسوم للأجهزة حسب الحالة والشركة المصنعة والنوع.
3. خلف كل رقم قائمة تفصيلية تُصفّى وتُصدَّر للمطابقة.

ما الذي يبحث عنه المقيّم

- تاريخ تحديث حديث، ومالكاً من الأعمال لكل أصل.
- مطابقة عينة بين السجل والشبكة في الاتجاهين.
- حقل التصنيف والأهمية، وأن الأصول السحابية مشمولة.

يثبت: 2-1-2 2-1-5

2-2 إدارة هويات الدخول والصلاحيات

هدف الوثيقة حماية الدخول المنطقي للأصول، ومنع الوصول غير المصرح به، وتقييده بما يلزم لأداء المهام.

ببساطة

ضبط من يدخل إلى أنظمة الجهة وماذا يستطيع أن يفعل: حساب فريد لكل شخص، وصلاحيات بقدر الحاجة، وتحقق متعدد العوامل للحسابات المهمة.

مثال من الحياة

مثل بطاقات المبنى: لكل موظف بطاقته، وتفتح له الأبواب التي يحتاجها فقط، وغرفة الخزنة تحتاج بطاقة ورمزاً معاً.

ماذا لو غاب؟

كلمة مرور واحدة مسروقة لحساب مدير نظام تكفي المهاجم للسيطرة على الشبكة كلها.

التحقق متعدد العوامل
كلمة مرور ومعها عامل آخر

الحساب المميز
حساب بصلاحيات إدارة عالية

مراجعة الصلاحيات
تأكيد دوري أن كل صلاحية لازمة

الهويات والصلاحيات: المتطلبات والتحقق الأحادي

الضابط	المطلوب	كيف تطبقه	الدليل
2-2-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة ومعيار: دورة حياة الحساب، وكلمات المرور، والصلاحيات، والحسابات المميزة والخدمية	السياسة والمعيار المعتمدان
2-2-2 تطبيق	**تطبيق المتطلبات**	نظام هويات مركزي، وإجراء لطلب الصلاحية بموافقة المدير ومالك النظام	عينة طلبات صلاحية بموافقاتها، وتصدير إعدادات النظام
2-2-3-1 حد أدنى	**التحقق الأحادي باسم المستخدم وكلمة المرور**	معرّف فريد لكل مستخدم، وقواعد للطول والتعقيد والقفل، ومنع الحسابات المشتركة	إعدادات سياسة كلمات المرور، وقائمة الحسابات المشتركة ومبرراتها
2-2-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة المتطلبات وتطبيقها على عينة من الأنظمة	تقرير المراجعة ونتائج العينة

التحقق متعدد العوامل والصلاحيات المميزة

الضابط	المطلوب	كيف تطبقه	الدليل
2-2-3-2 حد أدنى	**تحقق متعدد العوامل للدخول عن بعد والحسابات ذات الصلاحيات الهامة، بعوامل تحددها نتيجة تقييم الأثر**	تقييم أثر موثق، ثم تفعيل التحقق على الدخول عن بعد وبوابات الإدارة وكل الحسابات المميزة	تقييم الأثر، وإعدادات التحقق، ومطابقة قائمة الحسابات المميزة مع المسجلين فيه
2-2-3-3 حد أدنى	**الصلاحيات وفق الحاجة للمعرفة والاستخدام، والحد الأدنى، وفصل المهام**	أدوار معيارية لكل وظيفة، ومصفوفة فصل مهام للأنظمة الحساسة	مصفوفة الأدوار وفصل المهام، وعينة صلاحيات مطابقة لها
2-2-3-4 حد أدنى	**إدارة الصلاحيات الهامة والحساسة**	حصر الحسابات المميزة، وخزنة لكلمات مرورها، وتسجيل الجلسات، وصلاحيات مؤقتة عند الحاجة	قائمة الحسابات المميزة، وإعدادات النظام، وسجلات الجلسات
2-2-3-5 حد أدنى	**المراجعة الدورية للهويات وصلاحيات الدخول**	حملة مراجعة دورية يعتمد فيها مالك كل نظام صلاحيات مستخدميه، ويُلغى غير المبرر	نتائج حملات المراجعة الموقعة، ودليل إلغاء ما رُفض

كيف يبدو الدليل: مطابقة الحسابات المميزة بالتحقق

ما الذي تراه

1. قائمة الحسابات المميزة مستخرجة من الدليل النشط وأنظمة الإدارة.
2. مقارنتها بقائمة المسجلين في نظام التحقق متعدد العوامل.
3. الفجوة بالأرقام لكل مجموعة، والمجموع.

ما الذي يبحث عنه المقيّم

- أن القائمة الأولى كاملة: كل حساب ذي صلاحيات هامة.
- وثيقة تقييم الأثر التي حددت العوامل المطلوبة.
- خطة لإغلاق الفجوة بموعد، وأن الحسابات السحابية مشمولة.

مطابقة الحسابات المميزة مع التسجيل في التحقق متعدد العوامل · 2026-09-30

المجموعة	الحسابات	مسجلة في التحقق	الفجوة
مديرو النطاق	6	6	لا فجوة
مديرو الخوادم	14	9	5 حسابات
مديرو قواعد البيانات	7	4	3 حسابات
حسابات الخدمات السحابية	10	3	7 حسابات
المجموع	37	22	15 حساباً · 59%

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 2-2-3-2 2-2-3-4

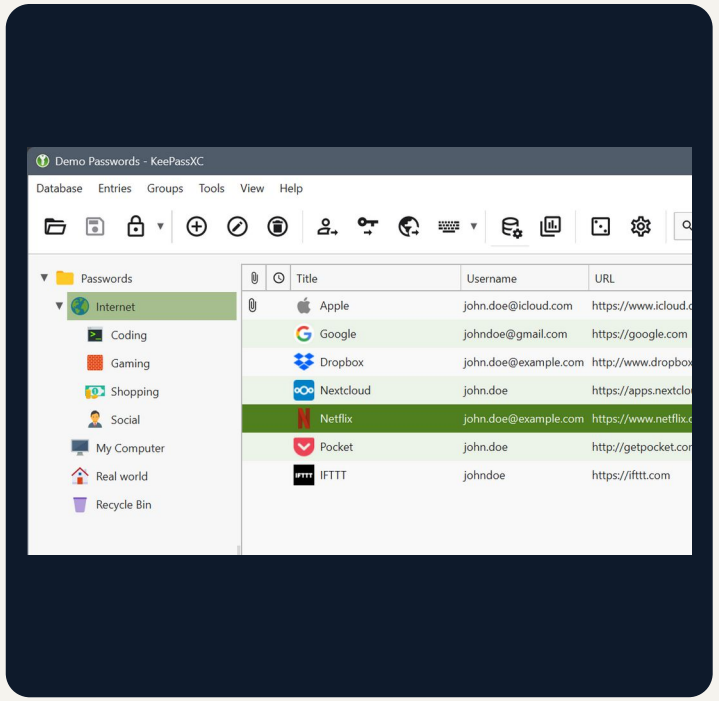
أدوات تراها في أدلة 2-2: عامل التحقق وخزنة كلمات المرور

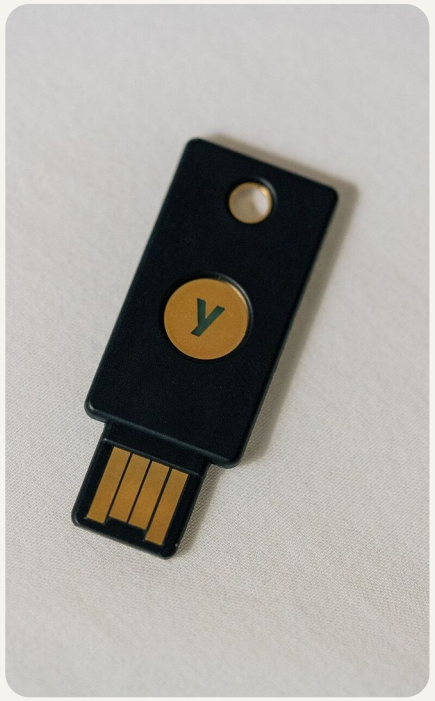
ما الذي تراه

1. عامل تحقق ثانٍ: تطبيق رموز مؤقتة أو مفتاح أمان مادي.
2. خزنة تحفظ كلمات مرور الحسابات المميزة بدل الملفات والأوراق.
3. كلاهما أداة، والدليل هو إعدادها وتغطيتها.

ما الذي يبحث عنه المقيّم

- إعداد يفرض العامل الثاني على الدخول عن بعد والحسابات المميزة.
- أن كلمات مرور الحسابات المميزة في الخزنة، ودوّرت بعد كل استخدام عند الحاجة.
- سجلات جلسات الحسابات المميزة في منصة السجلات.





صور حقيقية من الإنترنت للتوضيح · Tony Webster · CC BY 2.0 · Wikimedia Commons | · KeePassXC Team · GPL-2.0/3.0 · GitHub · keepassxreboot/keepassxc

يثبت: 2-2-3-2 2-2-3-4 2-12-3-2

2-3 حماية الأنظمة وأجهزة معالجة المعلومات

هدف الوثيقة حماية الأنظمة وأجهزة معالجة المعلومات، بما فيها أجهزة المستخدمين والبنى التحتية، من المخاطر السيبرانية.

ببساطة

حماية الخوادم وأجهزة الموظفين: برنامج حماية متقدم، وإعدادات آمنة، وتحديثات منتظمة، وتقييد وسائط التخزين، وتوقيت موحد.

مثال من الحياة

مثل صيانة السيارة: قفل جيد، وفحص دوري، وتغيير القطع المعيبة قبل أن تتعطل في الطريق.

ماذا لو غاب؟

جهاز واحد بلا حماية أو بلا تحديث يكفي لتنتشر منه برمجية ضارة إلى بقية الشبكة.

الحماية المتقدمة
تكشف السلوك المشبوه لا التواقيع فقط

خط الأساس
الإعدادات الآمنة المعتمدة للنظام

حزمة التحديث
إصلاح يصدره المورد لثغرة

حماية الأنظمة: المتطلبات والحماية من البرمجيات الضارة

الضابط	المطلوب	كيف تطبقه	الدليل
2-3-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة ومعايير تقوية لأجهزة المستخدمين والخوادم ومكونات البنية	السياسة ومعايير التقوية المعتمدة
2-3-2 تطبيق	**تطبيق المتطلبات**	خطوط أساس للإعدادات تُفرض عبر أدوات الإدارة المركزية	تقارير مطابقة الإعدادات لخط الأساس
2-3-3-1 حد أدنى	**الحماية من البرمجيات الضارة والأنشطة المشبوهة بتقنيات حديثة ومتقدمة، وإدارتها بأمان**	حل حماية متقدم لنقاط النهاية على كل الأجهزة والخوادم، بإدارة مركزية وتحديث تلقائي	تقرير التغطية من وحدة الإدارة مقارنة بسجل الأصول، وحالة التحديث
2-3-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة المتطلبات، وعينة من مطابقة الإعدادات والتغطية	تقرير المراجعة ونتائجه

الوسائط والتحديثات والتوقيت

الضابط	المطلوب	كيف تطبقه	الدليل
2-3-3-2 حد أدنى	**تقييد حازم لاستخدام وسائط التخزين الخارجية وأمنها**	منع افتراضي لوسائط التخزين عبر سياسات الأجهزة، واستثناءات معتمدة بوسائط مشفرة	إعداد سياسة المنع على الأجهزة، وسجل الاستثناءات المعتمدة
2-3-3-3 حد أدنى	**إدارة حزم التحديثات والإصلاحات للأنظمة والتطبيقات والأجهزة**	دورة تحديث منتظمة بأولويات حسب الخطورة، ونشر مركزي، وتقارير امتثال شهرية	تقارير حالة التحديثات للأجهزة والخوادم، وسجلات التغيير
2-3-3-4 حد أدنى	**مزامنة مركزية للتوقيت مع مصدر دقيق وموثوق، مثل مصادر هيئة المواصفات والمقاييس والجودة**	خادم توقيت داخلي يتزامن مع المصدر الموثوق، وكل الأنظمة تتزامن معه	إعدادات خادم التوقيت المركزي ومصدره، وعينة أنظمة متزامنة معه

تذكّر

بلا توقيت موحد لا يمكن ربط السجلات بين الأنظمة عند التحقيق في حادثة (2-12 و2-13).

كيف يبدو الدليل: تقرير تغطية الحماية

ما الذي تراه

1. عدد الأجهزة في سجل الأصول، مقابل الأجهزة المحمية والمحدثة في وحدة الإدارة.
2. التغطية لكل فئة، لا رقم إجمالي فقط.
3. الفجوة بالعدد: 240 جهازاً.

ما الذي يبحث عنه المقيّم

- أن المقام هو سجل الأصول، لا ما تراه وحدة الإدارة.
- أن التحديث تلقائي، وأن المستخدم لا يستطيع تعطيل الحماية.
- ضوابط بديلة موثقة للأجهزة التي لا تقبل الوكيل.

تقرير تغطية الحماية المتقدمة لنقاط النهاية · 2026-09-30

الفئة	في سجل الأصول	محمية ومحدثة	بلا حماية
أجهزة الموظفين	1,180	1,032	148
الخوادم	190	120	70
أجهزة شبكية تقبل الوكيل	50	28	22
المجموع	1,420	1,180	240 · 83%

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 2-3-3-1 2-1-2

2-4 حماية البريد الإلكتروني

هدف الوثيقة حماية خدمة البريد الإلكتروني للجهة من المخاطر السيبرانية.

ببساطة

حماية البريد لأنه أكثر طرق الهجوم استخداماً: تصفية الرسائل الضارة، وتحقق متعدد العوامل، وأرشفة، ومنع انتحال اسم الجهة.

مثال من الحياة

مثل البريد الورقي في جهة حكومية: يُفحص قبل توزيعه، ويحمل ختماً رسمياً يثبت أنه صادر منك.

ماذا لو غاب؟

رسالة تصيد تصل إلى كل الموظفين، أو مهاجم يرسل باسم نطاق الجهة رسائل مزيفة إلى المستفيدين.

التصفية
حجب الرسائل الضارة قبل وصولها

انتحال النطاق
إرسال بريد مزيف باسم الجهة

DMARC
سياسة تحدد مصير البريد المزيف

حماية البريد: المتطلبات والتصفية

الضابط	المطلوب	كيف تطبقه	الدليل
2-4-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	معيار لحماية البريد يغطي البنود الخمسة في 2-4-3 وإعداداتها	السياسة أو المعيار المعتمد
2-4-2 تطبيق	**تطبيق المتطلبات**	تطبيق المعيار على خادم البريد وبوابة الحماية	تصدير إعدادات بوابة البريد
2-4-3-1 حد أدنى	**تحليل الرسائل وتصفيتها، وخصوصاً التصيد والرسائل غير المرغوبة، بتقنيات حديثة ومتقدمة**	بوابة حماية بريد بتصفية للتصيد والرسائل غير المرغوبة والروابط والمرفقات	إعدادات قواعد التصفية، وتقرير الرسائل المحجوبة لفترة
2-4-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة الإعدادات والمؤشرات، مثل نسب الحجب والبلاغات	تقرير المراجعة ونتائجه

التحقق والأرشفة والتهديدات المتقدمة والنطاقات

الضابط	المطلوب	كيف تطبقه	الدليل
2-4-3-2 حد أدنى	**تحقق متعدد العوامل للدخول عن بعد ولبريد الويب، بعوامل يحددها تقييم الأثر**	تقييم أثر موثق، ثم تفعيل التحقق متعدد العوامل لكل دخول للبريد من خارج الشبكة	تقييم الأثر، وإعدادات التحقق للبريد عبر الويب والدخول عن بعد
2-4-3-3 حد أدنى	**أرشفة البريد ونسخه احتياطياً**	أرشفة ونسخ احتياطي للبريد وفق مدد الاحتفاظ المعتمدة	إعدادات الأرشفة والنسخ، ونتيجة اختبار استرجاع رسالة
2-4-3-4 حد أدنى	**الحماية من التهديدات المتقدمة المستمرة التي تستخدم برمجيات غير معروفة مسبقاً**	عزل المرفقات وتحليلها في بيئة معزولة قبل التسليم، وفحص الروابط عند النقر	إعدادات الحماية المتقدمة، وتقرير بالمرفقات المعزولة
2-4-3-5 حد أدنى	**التحقق من نطاقات البريد عبر SPF وDKIM وDMARC**	نشر SPF وتوقيع DKIM، وسياسة DMARC تتدرج إلى الرفض أو العزل بعد المراقبة	استعلام DNS يُظهر سجلات SPF وDKIM وDMARC لكل نطاق

كيف يبدو الدليل: استعلام حقيقي لسجلات SPF وDMARC

DNS lookup · 2026-10-17

```
$ dig +short TXT _dmarc.gov.uk
"v=DMARC1;p=reject;sp=none;np=reject;adkim=s;aspf=s;fo=1;rua=mailto:dmarc-rua@dmarc.service.gov.uk"
$ dig +short TXT gov.uk | grep spf
"v=spf1 -all"
$ dig +short TXT _dmarc.google.com
"v=DMARC1; p=reject; rua=mailto:mailauth-reports@google.com"
```

استعلام DNS حقيقي لنطاقين عامين عبر الإنترنت، نُفذ بتاريخ 2026-10-17 · السجلات عامة ويمكن لأي شخص الاستعلام عنها

ما الذي تراه

1. سياسة DMARC بقيمة p=reject: البريد المزيف يُرفض لا يُراقب فقط.
2. نطاق لا يرسل بريداً بسجل SPF صارم -all يمنع انتحاله.
3. عنوان rua يستقبل تقارير DMARC للمراجعة.

ما الذي يبحث عنه المقيّم

- أن السياسة رفض أو عزل، لا مراقبة فقط p=none.
- أن النطاقات الفرعية وغير المرسلة مغطاة.
- سجلات DKIM للخدمات التي ترسل باسم الجهة.

يثبت: 2-4-3-5

2-5 إدارة أمن الشبكات

هدف الوثيقة حماية شبكات الجهة من المخاطر السيبرانية.

ببساطة

تقسيم الشبكة إلى مناطق بينها جدران نارية، وعزل بيئات الاختبار، وتأمين التصفح واللاسلكي، وأنظمة لكشف الاختراق ومنعه.

مثال من الحياة

مثل سفينة مقسمة إلى غرف محكمة الإغلاق: لو دخل الماء غرفة، لا تغرق السفينة كلها.

ماذا لو غاب؟

شبكة مسطحة بلا تقسيم: مهاجم يدخل من جهاز موظف يصل مباشرة إلى خوادم قواعد البيانات.

المنطقة الشبكية
جزء معزول من الشبكة بقواعد خاصة

الرفض الافتراضي
كل ما لم يُسمح به صراحة ممنوع

نظام منع الاختراق
يوقف الحركة الهجومية المعروفة

أمن الشبكات: المتطلبات والعزل والتقسيم

الضابط	المطلوب	كيف تطبقه	الدليل
2-5-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة ومعايير لأجهزة الشبكة والجدران النارية تغطي البنود التسعة في 2-5-3	السياسة ومعايير أجهزة الشبكة المعتمدة
2-5-2 تطبيق	**تطبيق المتطلبات**	تطبيق المعايير على كل أجهزة الشبكة، ومخطط شبكة محدث ومعتمد	مخطط الشبكة المحدث، وتصدير إعدادات الأجهزة
2-5-3-1 حد أدنى	**العزل والتقسيم المادي أو المنطقي للشبكة بأمان، بجدار ناري ومبدأ الدفاع متعدد المراحل**	تقسيم الشبكة إلى مناطق حسب الحساسية، وجدار ناري بين المناطق، ومبدأ الرفض الافتراضي	مخطط المناطق الشبكية، وقواعد الجدار الناري بين المناطق ومراجعتها
2-5-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة المتطلبات، ومراجعة دورية لقواعد الجدار الناري وإزالة غير المستخدم	تقرير المراجعة، ومراجعة قواعد الجدار الناري

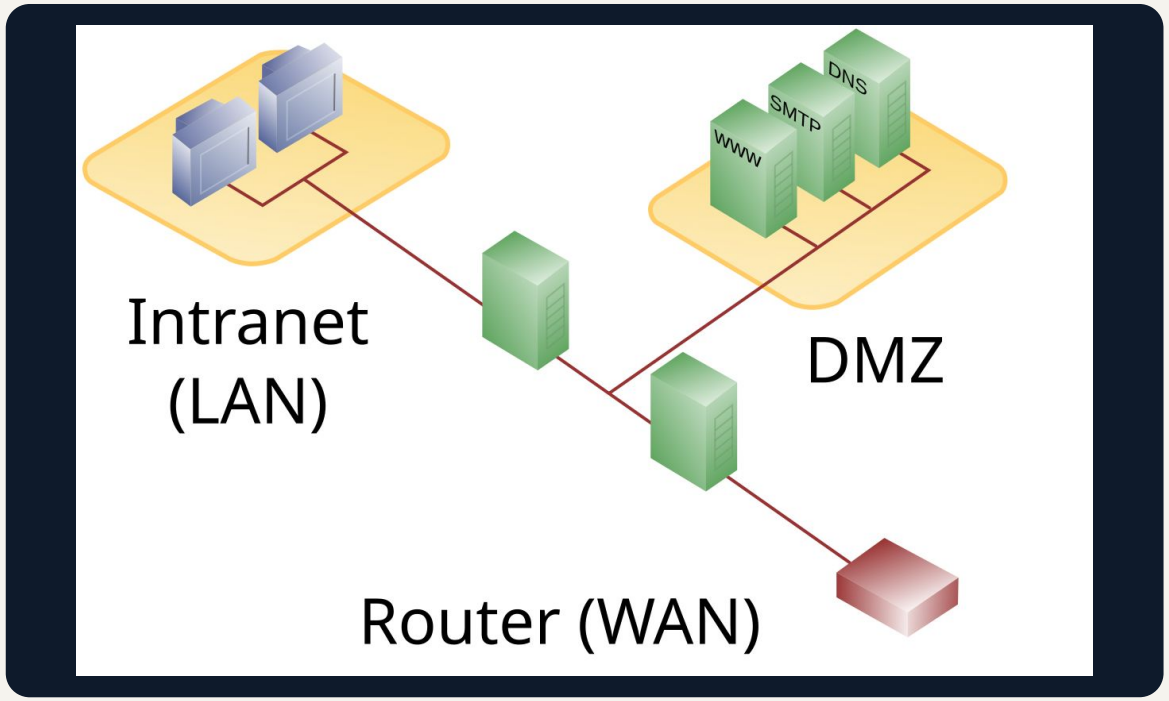
البيئات والتصفح واللاسلكي والمنافذ

الضابط	المطلوب	كيف تطبقه	الدليل
2-5-3-2 حد أدنى	**عزل شبكة الإنتاج عن شبكات الاختبار والتطوير**	مناطق منفصلة للتطوير والاختبار، ومنع الاتصال المباشر بالإنتاج إلا بقواعد محددة	مخطط البيئات، وقواعد الجدار الناري بينها
2-5-3-3 حد أدنى	**تصفح آمن مع تقييد حازم للمواقع المشبوهة ومواقع مشاركة الملفات ومواقع الدخول عن بعد**	وكيل ويب بتصنيف المواقع يحجب الفئات الثلاث، واستثناءات معتمدة بمبرر	سياسة التصفية في الوكيل، وتقرير المحجوب، وسجل الاستثناءات
2-5-3-4 حد أدنى	**أمن اللاسلكي، وعدم ربطه بالشبكة الداخلية إلا بعد تقييم شامل للمخاطر ومعالجتها**	تشفير حديث ومصادقة مركزية، وشبكة ضيوف معزولة، وتقييم مخاطر موثق لأي ربط بالداخل	إعدادات وحدة التحكم اللاسلكية، وتقييم المخاطر إن وُجد ربط داخلي
2-5-3-5 حد أدنى	**تقييد وإدارة خدمات الشبكة والبروتوكولات والمنافذ**	قائمة معتمدة بالمنافذ والبروتوكولات المسموحة، وتعطيل البروتوكولات غير الآمنة	القائمة المعتمدة، ونتيجة فحص منافذ تطابقها

منع الاختراق وDNS وحجب الخدمة

الضابط	المطلوب	كيف تطبقه	الدليل
2-5-3-6 حد أدنى	**أنظمة الحماية لاكتشاف الاختراقات ومنعها**	نظام منع اختراق على حدود الشبكة وبين المناطق الحساسة، بوضع المنع لا المراقبة فقط	إعدادات النظام ووضع التشغيل، وحالة تحديث التواقيع
2-5-3-7 حد أدنى	**أمن نظام أسماء النطاقات**	خوادم DNS داخلية مقواة، وتصفية للنطاقات الضارة، ومنع الاستعلام المباشر من الأجهزة للخارج	إعدادات خوادم DNS والتصفية، وقواعد الجدار الناري لحركة DNS
2-5-3-8 حد أدنى	**حماية قناة التصفح من التهديدات المتقدمة المستمرة**	تحليل التنزيلات في بيئة معزولة، وفحص حركة التصفح المشفرة وفق سياسة معتمدة	إعدادات الحماية المتقدمة، وتقرير الملفات المحللة أو المحجوبة
2-5-3-9 حد أدنى	**الحماية من هجمات حجب الخدمة الموزعة للحد من مخاطرها**	خدمة حماية من مزود الاتصال أو مزود متخصص للخدمات المواجهة للإنترنت، وخطة استجابة	عقد الخدمة ونطاقها، وإعداداتها، وخطة الاستجابة

كيف يبدو الدليل: مخطط شبكة بمناطق معزولة



صورة حقيقية من الإنترنت للتوضيح · Pbroks13 · ملكية عامة · المصدر: Wikimedia Commons

ما الذي تراه

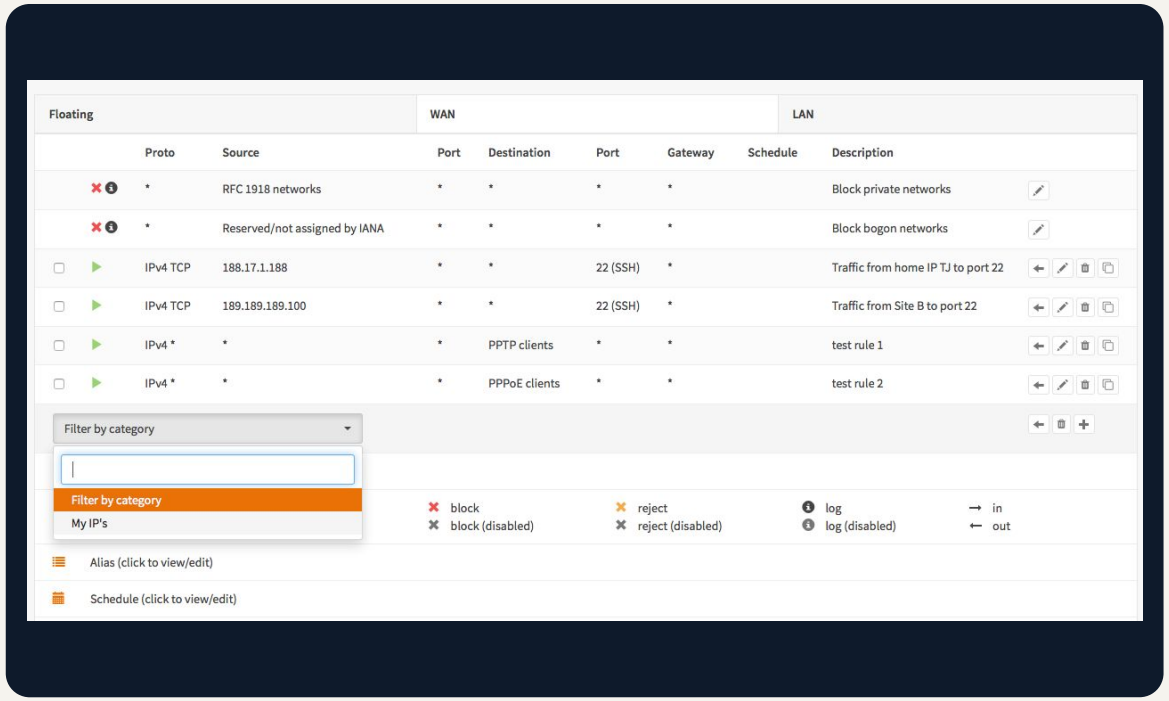
1. مناطق منفصلة: الإنترنت، والمنطقة المنزوعة السلاح، والشبكة الداخلية.
2. جدار ناري يفصل كل منطقة عن الأخرى.
3. الخدمات المواجهة للإنترنت في منطقتها، لا في الداخل.

ما الذي يبحث عنه المقيّم

- أن المخطط محدث ومعتمد ويطابق الواقع.
- قواعد الجدار الناري بين المناطق، فهي الدليل الحقيقي للعزل.
- عزل شبكة الإنتاج عن الاختبار والتطوير (2-5-3-2).

يثبت: 2-5-3-1 2-5-2

كيف يبدو الدليل: قواعد الجدار الناري



صورة حقيقية من الإنترنت للتوضيح · BSD-2-Clause · المصدر: opnsense/docs · GitHub · OPNsense documentation contributors

ما الذي تراه

1. كل قاعدة: مصدر، ووجهة، ومنفذ، وقرار سماح أو منع.
2. مثال جيد: SSH على المنفذ 22 مسموح من عنوانين محددين فقط.
3. منع الشبكات الخاصة والعناوين غير المخصصة القادمة من الإنترنت.

ما الذي يبحث عنه المقيّم

- قاعدة رفض افتراضي، وغياب قواعد any-any بين المناطق.
- مراجعة دورية للقواعد وإزالة غير المستخدم منها.
- تطابق القواعد مع المنافذ المعتمدة في 2-5-3-5.

يثبت: 2-5-3-1 2-5-3-5 2-5-4

2-6 أمن الأجهزة المحمولة

هدف الوثيقة حماية الحواسيب المحمولة والهواتف والأجهزة اللوحية، وبيانات الجهة عليها، بما فيها الأجهزة الشخصية (BYOD).

ببساطة

حماية الحواسيب المحمولة والجوالات والأجهزة اللوحية، ومنها الأجهزة الشخصية، بنظام إدارة يفرض التشفير ويفصل بيانات العمل ويمسحها عند الفقد.

مثال من الحياة

مثل حقيبة مستندات تخرج من المكتب: تُقفل، ولا تفتح لغير صاحبها، ويُتلف محتواها عن بعد إن ضاعت.

ماذا لو غاب؟

حاسوب محمول يُسرق من سيارة وعليه ملفات المستفيدين بلا تشفير.

MDM
نظام إدارة الأجهزة المحمولة

BYOD
استخدام الموظف لجهازه الشخصي

المسح عن بعد
حذف بيانات الجهة من جهاز مفقود

الأجهزة المحمولة: المتطلبات والفصل والتشفير

الضابط	المطلوب	كيف تطبقه	الدليل
2-6-1 توثيق واعتماد	**تحديد متطلبات الأجهزة المحمولة والشخصية عند ربطها بالشبكة وتوثيقها واعتمادها**	سياسة تحدد الأجهزة المسموحة وشروط ربطها والبيانات التي يُسمح بالوصول إليها منها	السياسة المعتمدة
2-6-2 تطبيق	**تطبيق المتطلبات**	نظام لإدارة الأجهزة أو التطبيقات المحمولة يفرض السياسة، ومنع غير المسجل	تقرير الأجهزة المسجلة وحالة امتثالها للسياسة
2-6-3-1 حد أدنى	**فصل بيانات الجهة على الأجهزة وتشفيرها**	حاوية عمل منفصلة على الأجهزة الشخصية، وتشفير كامل للحواسيب المحمولة	إعدادات الحاوية، وتقرير حالة التشفير للأجهزة
2-6-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة المتطلبات، ونسب التسجيل والامتثال والتشفير	تقرير المراجعة ونتائجه

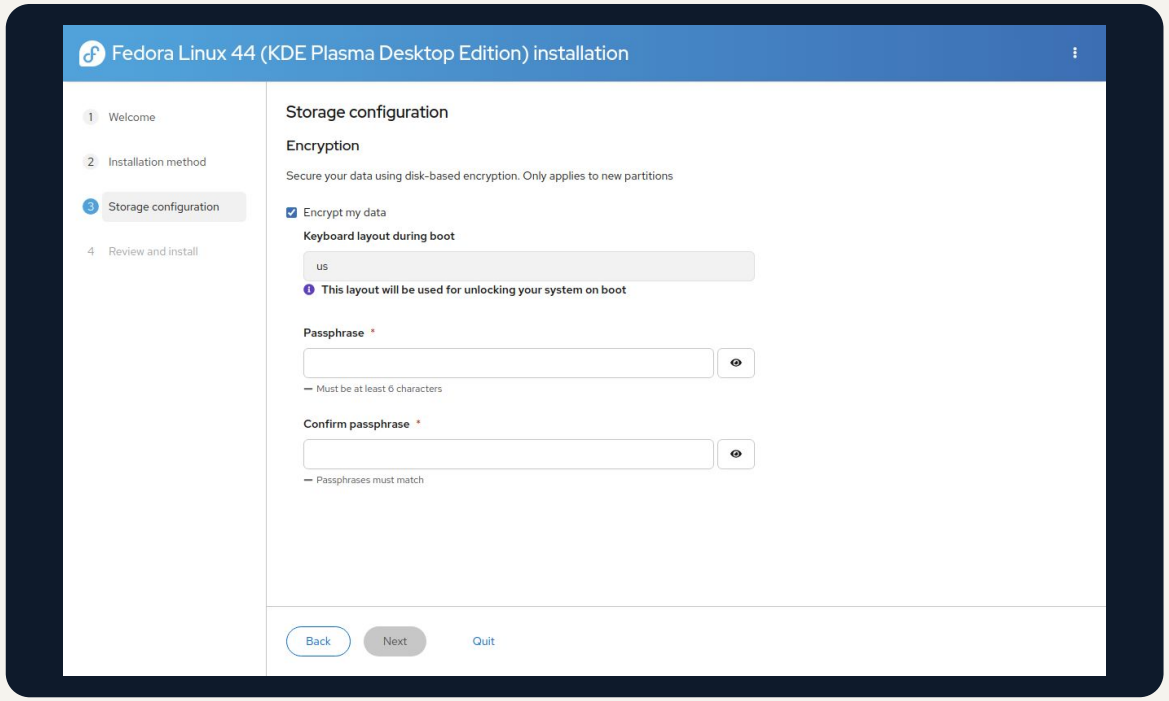
التقييد والحذف والتوعية

الضابط	المطلوب	كيف تطبقه	الدليل
2-6-3-2 حد أدنى	**استخدام مقيد ومضبوط حسب حاجة العمل**	تحديد الفئات المسموح لها والتطبيقات والخدمات المتاحة، وموافقة على كل تسجيل	قائمة المصرح لهم وموافقاتهم، وإعدادات تقييد التطبيقات
2-6-3-3 حد أدنى	**حذف بيانات الجهة عند فقد الجهاز أو انتهاء العلاقة الوظيفية**	مسح عن بعد لحاوية العمل أو الجهاز، مرتبط ببلاغ الفقد وإجراء إنهاء الخدمة	سجلات المسح عن بعد، ومطابقتها مع بلاغات الفقد وإنهاء الخدمات
2-6-3-4 حد أدنى	**التوعية الأمنية للمستخدمين**	إرشادات مختصرة عند تسجيل الجهاز، ومحتوى ضمن برنامج التوعية 1-10	الإرشادات، وإقرار المستخدم عند التسجيل

نصيحة عملية

على الجهاز الشخصي يشمل المسح بيانات الجهة فقط؛ وضّح ذلك للمستخدم في الإقرار قبل التسجيل.

كيف يبدو الدليل: تشفير القرص الكامل



صورة حقيقية من الإنترنت للتوضيح · CC BY-SA 4.0 · Fedora Documentation contributors
المصدر: docs.fedoraproject.org

ما الذي تراه

1. خيار «Encrypt my data» لتشفير القرص كاملاً عند تثبيت النظام.
2. عبارة مرور تُطلب عند كل تشغيل للجهاز.
3. بلا عبارة المرور أو مفتاح الاستعادة لا تُقرأ البيانات.

ما الذي يبحث عنه المقيّم

- تقرير من نظام الإدارة بنسبة الأجهزة المشفرة مقابل سجل الأصول.
- أن الخوارزمية ضمن المعايير الوطنية للتشفير.
- أين تُحفظ مفاتيح الاستعادة ومن يصل إليها.

يثبت: 2-6-3-1 2-8-3-3 2-8-3-2

2-7 حماية البيانات والمعلومات

هدف الوثيقة ضمان سرية بيانات الجهة وسلامتها ودقتها وتوافرها وفق المتطلبات التشريعية والتنظيمية.

ببساطة

حماية البيانات بحسب درجة حساسيتها: كلما ارتفع التصنيف زادت القيود على من يطّلع، وكيف تُخزَّن وتُنقل وتُشارك وتُتلف.

مثال من الحياة

مثل المراسلات في الجهة: العادي يُرسل بالبريد، والسري في ظرف مختوم يُسلَّم باليد.

ماذا لو غاب؟

ملف «سري» يُرسل بالبريد العادي إلى جهة خارجية، أو يُترك في مجلد مشترك مفتوح للجميع.

مستوى التصنيف
درجة حساسية البيانات

قواعد التعامل
ما يُسمح به لكل مستوى

منع التسرب
تقنية تمنع خروج البيانات الحساسة

حماية البيانات: ثلاثة ضوابط مبنية على التصنيف

الضابط	المطلوب	كيف تطبقه	الدليل
2-7-1 توثيق واعتماد	**تحديد متطلبات حماية البيانات والتعامل معها وتوثيقها واعتمادها وفق المتطلبات**	سياسة بقواعد لكل مستوى تصنيف، متوائمة مع الأنظمة الوطنية لحماية البيانات	السياسة المعتمدة، وجدول قواعد التعامل لكل مستوى
2-7-2 تطبيق	**تطبيق المتطلبات بحسب مستوى تصنيف البيانات**	ضوابط تقنية حسب المستوى: تقييد الوصول، والتشفير، ومنع تسرب البيانات، والترميز	عينة بيانات مصنفة وضوابطها المطبقة، وإعدادات منع التسرب
2-7-3 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة عينة من مستودعات البيانات مقابل قواعد مستواها	تقرير المراجعة ونتائج العينة

لكل مستوى تصنيف حدّد

من يطّلع · أين يُخزَّن · كيف يُنقل · كيف يُشارَك · كيف يُتلف

2-8 التشفير

هدف الوثيقة الاستخدام السليم والفعال للتشفير لحماية الأصول المعلوماتية الإلكترونية للجهة.

ببساطة

استخدام التشفير بشكل صحيح وفق المعايير الوطنية للتشفير، لحماية البيانات أثناء نقلها وتخزينها، مع إدارة آمنة لمفاتيح التشفير.

مثال من الحياة

مثل الخزنة: قوتها لا تفيد إن تركت مفتاحها معلقاً على بابها.

ماذا لو غاب؟

بيانات حساسة تُنقل بلا تشفير، أو تشفير قديم ضعيف، أو مفتاح محفوظ في ملف نصي بجانب البيانات.

المعايير الوطنية للتشفير
ما تعتمده الهيئة من خوارزميات وأطوال

الشهادة الرقمية
تثبت هوية الموقع وتشفر الاتصال

إدارة المفاتيح
توليد المفاتيح وحفظها وتدويرها

التشفير: المتطلبات والمعايير الوطنية

الضابط	المطلوب	كيف تطبقه	الدليل
2-8-1 توثيق واعتماد	**تحديد متطلبات التشفير وتوثيقها واعتمادها**	سياسة ومعيار تشفير مبنيان على المعايير الوطنية للتشفير	السياسة والمعيار المعتمدان
2-8-2 تطبيق	**تطبيق متطلبات التشفير**	جرد استخدامات التشفير: الشهادات والبروتوكولات والمفاتيح، وتطبيق المعيار عليها	جرد التشفير، وإعدادات عينة من الأنظمة
2-8-3 حد أدنى · وطني	**تشمل المتطلبات على الأقل ما في المعايير الوطنية للتشفير، بالمستوى المناسب للحساسية والمخاطر**	تحديد مستوى التشفير لكل فئة وفق المعايير الوطنية وطبيعة البيانات وتقييم المخاطر	جدول يربط فئات البيانات والأنظمة بمستويات التشفير ومرجعيتها
2-8-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة الجرد والخوارزميات مقابل المعايير السارية	تقرير المراجعة

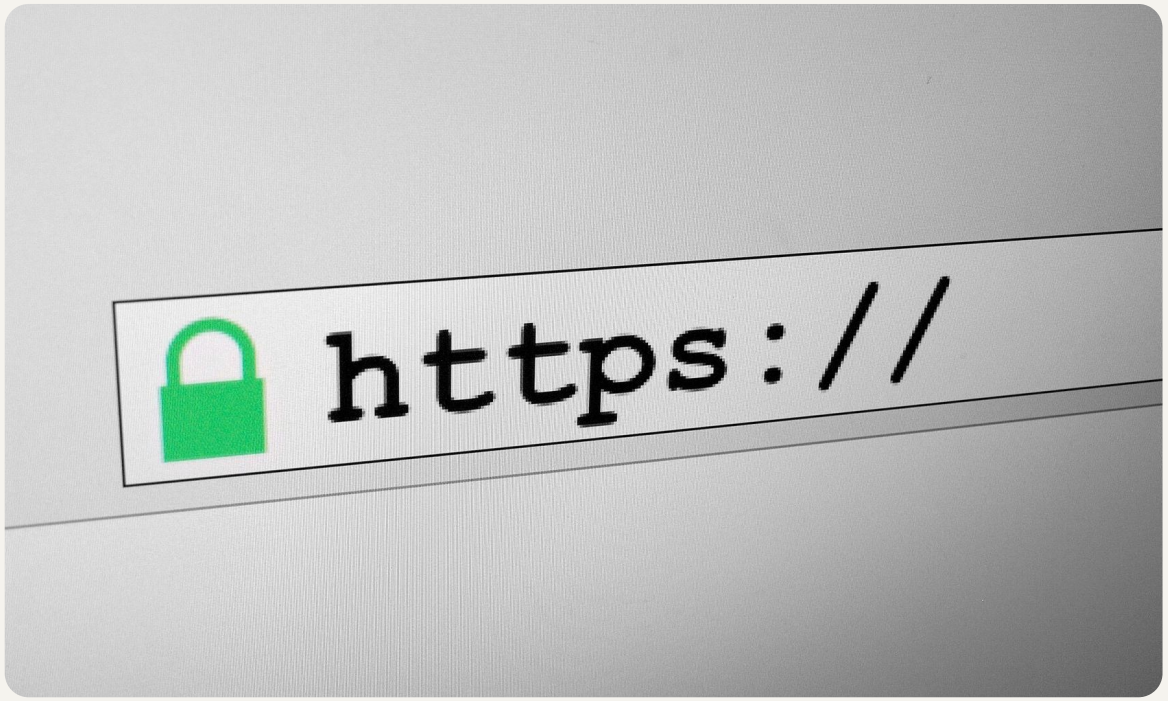
المعايير والمفاتيح والبيانات

الضابط	المطلوب	كيف تطبقه	الدليل
2-8-3-1 حد أدنى	**معايير أنظمة وحلول التشفير المعتمدة وقيودها التقنية والتنظيمية**	قائمة معتمدة بالخوارزميات وأطوال المفاتيح والبروتوكولات المسموحة والممنوعة	القائمة المعتمدة، وفحص يثبت تعطيل البروتوكولات الضعيفة
2-8-3-2 حد أدنى	**الإدارة الآمنة لمفاتيح التشفير خلال دورة حياتها**	إجراء لدورة الحياة: توليد وتخزين وتوزيع وتدوير وإلغاء وإتلاف، ووحدات أمن عتادية للمفاتيح الحساسة	الإجراء المعتمد، وسجل المفاتيح والشهادات بتواريخ انتهائها وتدويرها
2-8-3-3 حد أدنى	**تشفير البيانات أثناء النقل والتخزين حسب تصنيفها والمتطلبات**	تشفير القنوات للخدمات والتكاملات، وتشفير قواعد البيانات والأقراص والنسخ للبيانات المصنفة	إعدادات التشفير لعينة أنظمة، مقابل تصنيف بياناتها

خطأ شائع

شهادة منتهية أو بروتوكول قديم مفعّل من أكثر الملاحظات شيوعاً، ويكشفهما فحص خارجي في دقائق.

كيف يبدو الدليل: الاتصال المشفر وشهادته



صورة حقيقية من الإنترنت للتوضيح · Santeri Viinamäki · CC BY-SA 4.0 · المصدر: Wikimedia Commons

ما الذي تراه

1. القفل وhttps: الاتصال بالموقع مشفر بشهادة رقمية.
2. الضغط على القفل يعرض الجهة المصدرة وتاريخ انتهاء الشهادة.
3. القفل لا يكشف قوة الإعدادات؛ ذلك يحتاج فحصاً متخصصاً.

ما الذي يبحث عنه المقيّم

- سجل شهادات بتواريخ الانتهاء، فلا تنتهي شهادة دون علم.
- أن البروتوكولات والخوارزميات ضمن المعايير الوطنية للتشفير.
- فحصاً خارجياً لكل الخدمات المواجهة للإنترنت، لا موقعاً واحداً.

يثبت: 2-8-3-1 2-8-3-2 2-15-3-3

تمرين 5 · ثنائي · 20 دقيقة

هل يثبت هذا الدليل الامتثال؟

لكل دليل: ما الضابط، وهل يثبت الامتثال كاملاً، وما الناقص، وما الإجراء التالي؟

1. وحدة إدارة الحماية: 1,180 جهازاً محمياً. سجل الأصول: 1,420 جهازاً.
2. سجل DMARC للنطاق الرئيسي بسياسة المراقبة فقط منذ سنتين.
3. التحقق متعدد العوامل مفعّل على الشبكة الافتراضية الخاصة، ولا يشمل حسابات مديري الخوادم.
4. لاسلكي الموظفين مربوط بالشبكة الداخلية، ولا يوجد تقييم مخاطر.
5. بين منطقة المستخدمين ومنطقة الخوادم قاعدة جدار ناري تسمح بكل شيء.
6. ملفات مصنفة «سري» تُرسل بالبريد إلى جهات خارجية دون تشفير.

حل التمرين 5

ماذا يثبت كل دليل، وما الناقص

#	الضابط	الحكم والناقص	الإجراء التالي
1	2-3-3-1	جزئي: 240 جهازاً بلا حماية، أو سجل غير دقيق	مطابقة القائمتين، ثم تثبيت الحماية أو تصحيح السجل
2	2-4-3-5	منشور، لكنه لا يمنع انتحال النطاق	مراجعة تقارير DMARC، ثم التدرج إلى العزل أو الرفض
3	2-2-3-2	جزئي: الحسابات المميزة مشمولة صراحة	حصر الحسابات المميزة وتفعيل التحقق لها، مع تقييم الأثر
4	2-5-3-4	غير ممتثل: الربط مشروط بتقييم المخاطر	تقييم مخاطر شامل ومعالجة موثقة، أو عزل اللاسلكي
5	2-5-3-1	تقسيم شكلي بلا عزل فعلي	قواعد بالحد الأدنى بين المناطق، ومراجعة دورية لها
6	2-8-3-3 · 2-7-2	خلاف قواعد التعامل والتشفير أثناء النقل	تشفير إلزامي لما يُرسل خارجياً، وضوابط لمنع التسرب

الوحدة 06 · المكون الأساسي 2

06 تعزيز الأمن السيبراني (2)

الاكتشاف والاستجابة والتعافي: كيف نعرف أن لدينا ثغرة أو هجوماً، وكيف نتعامل معه، وكيف نستعيد.

2-9 النسخ الاحتياطية الشريحة 111

2-10 إدارة الثغرات الشريحة 116

2-11 اختبار الاختراق الشريحة 120

2-12 السجلات والمراقبة الشريحة 124

2-13 الحوادث والتهديدات الشريحة 129

2-14 الأمن المادي الشريحة 133

2-15 تطبيقات الويب الشريحة 138

2-9 إدارة النسخ الاحتياطية

هدف الوثيقة حماية بيانات الجهة ومعلوماتها والإعدادات التقنية لأنظمتها وتطبيقاتها من المخاطر السيبرانية.

ببساطة

نسخ البيانات والإعدادات المهمة بانتظام، وحفظ نسخة لا يصل إليها المهاجم، واختبار الاستعادة دورياً للتأكد أنها تعمل.

مثال من الحياة

مثل الإطار الاحتياطي في السيارة: لا يكفي أنه في الصندوق، بل يجب أن تتأكد أنه منفوخ وصالح قبل أن تحتاجه.

ماذا لو غاب؟

هجوم فدية يشفّر الأنظمة والنسخ المتصلة بها معاً، فلا تجد الجهة ما تستعيده.

اختبار الاستعادة
استرجاع فعلي للتأكد أن النسخة تعمل

النسخة المعزولة
نسخة لا يصل إليها المهاجم

RTO و RPO
أهداف زمن الاستعادة وفقد البيانات

النسخ الاحتياطية: المتطلبات والتطبيق والنطاق

الضابط	المطلوب	كيف تطبقه	الدليل
2-9-1 توثيق واعتماد	**تحديد متطلبات النسخ والاستعادة وتوثيقها واعتمادها**	سياسة تحدد النطاق والتكرار ومدد الاحتفاظ وأهداف الاستعادة لكل فئة من الأصول	السياسة المعتمدة
2-9-2 تطبيق	**تطبيق المتطلبات**	مهام مجدولة حسب السياسة، ومراقبة نجاحها، ونسخة معزولة أو غير قابلة للتعديل	تقرير مهام النسخ ونسب نجاحها لفترة، وإعدادات النسخة المعزولة
2-9-3-1 حد أدنى	**نطاق النسخ يغطي الأصول المعلوماتية والتقنية الحساسة**	مطابقة الأصول الحساسة في سجل الأصول مع قائمة مهام النسخ	نتيجة المطابقة: لكل أصل حساس مهمة نسخ
2-9-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة السياسة، ونسب النجاح، ونتائج اختبارات الاستعادة	تقرير المراجعة ونتائجه

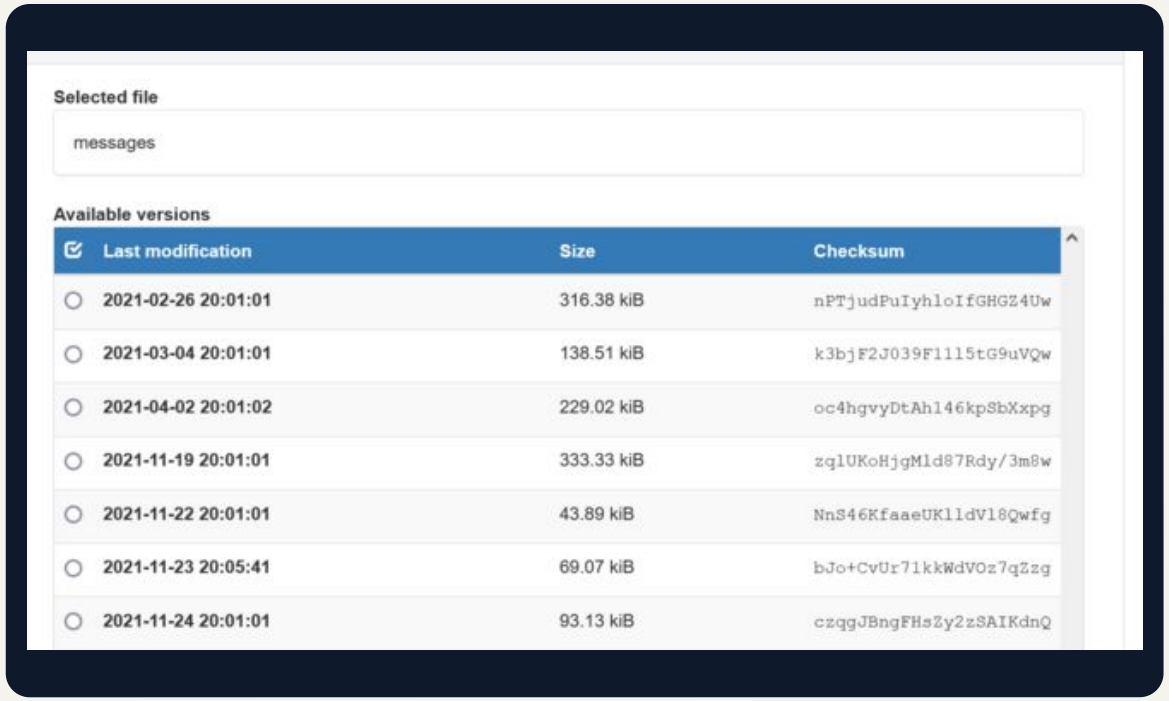
الاستعادة السريعة واختبارها

الضابط	المطلوب	كيف تطبقه	الدليل
2-9-3-2 حد أدنى	**القدرة على الاستعادة السريعة للبيانات والأنظمة بعد الحوادث السيبرانية**	أهداف استعادة لكل نظام حساس، وإجراءات موثقة، ونسخ جاهزة خارج نطاق أي حادثة	إجراءات الاستعادة، وأهدافها المعتمدة، والزمن الفعلي في الاختبارات
2-9-3-3 حد أدنى	**الفحص الدوري لفعالية استعادة النسخ**	خطة اختبار دورية تغطي عينة متغيرة من الأنظمة الحساسة، مع توثيق كل اختبار	تقارير اختبار الاستعادة بتواريخها ونتائجها ومعالجة الإخفاقات

محضر اختبار الاستعادة الجيد يتضمن

النظام المستعاد · تاريخ النسخة · تاريخ الاختبار · الزمن مقابل الهدف · التحقق من سلامة البيانات · المشكلات ومعالجتها · المنفذ والمعتمد

كيف يبدو الدليل: النسخ المتاحة للاستعادة



صورة حقيقية من الإنترنت للتوضيح · Bareos GmbH & Co. KG · مقتطعة · CC BY-SA 4.0 ·
المصدر: Wikimedia Commons

ما الذي تراه

1. ملف محدد، وله نسخ متعددة محفوظة في برنامج النسخ.
2. لكل نسخة تاريخ ووقت، فيظهر انتظام مهام النسخ.
3. حجم كل نسخة وبصمة تحقق (Checksum) لسلامتها.

ما الذي يبحث عنه المقيّم

- نسب نجاح المهام لفترة كاملة، ومتابعة كل فشل.
- أن كل أصل حساس في سجل الأصول له مهمة نسخ.
- وجود نسخة معزولة أو غير قابلة للتعديل.

يثبت: 2-9-2 2-9-3-1

كيف يبدو الدليل: محضر اختبار استعادة

ما الذي تراه

1. استعادة نظام كامل، لا ملف واحد.
2. الزمن الفعلي مقارنة بالهدف المعتمد.
3. تحقق من سلامة البيانات، ومشكلة اكتُشفت وعولجت.

ما الذي يبحث عنه المقيّم

- محاضر لعدة فترات، بعينة متغيرة من الأنظمة الحساسة.
- أن النسخة المستعادة من موقع خارج نطاق أي حادثة.
- معالجة كل إخفاق في الاختبارات السابقة.

يثبت: 2-9-3-3 2-9-3-2

محضر اختبار استعادة · نظام الموارد البشرية

ناجح

تاريخ الاختبار	2026-09-21
النسخة المستعادة	2026-09-20 · نسخة ليلية من الموقع المعزول
الهدف المعتمد	استعادة خلال 4 ساعات
الزمن الفعلي	3 ساعات و10 دقائق
سلامة البيانات	مطابقة عدد السجلات، ومراجعة عينة من 50 سجلاً

- مشكلة: كلمة مرور حساب الخدمة غير محدثة في الإجراء، وصُححت
- النتيجة: ناجح ضمن الهدف المعتمد

المنفذ	المعتمد
مهندس الأنظمة	مدير تقنية المعلومات

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

2-10 إدارة الثغرات

هدف الوثيقة اكتشاف الثغرات التقنية في الوقت المناسب ومعالجتها بفعالية، لمنع استغلالها أو تقليل احتماله وأثره.

ببساطة

البحث الدوري عن نقاط الضعف المعروفة في الأنظمة، وترتيبها حسب خطورتها، وإصلاحها في مدد محددة، ومتابعة الثغرات الجديدة من مصادر موثوقة.

مثال من الحياة

مثل فحص المبنى بحثاً عن الشقوق والتسربات: تفحص بانتظام، وتصلح الأخطر أولاً قبل أن يتسع.

ماذا لو غاب؟

ثغرة معروفة منذ أشهر بلا إصلاح على خادم مواجه للإنترنت: أسهل طريق يسلكه المهاجمون.

الثغرة
ضعف في نظام يمكن استغلاله

CVSS
مقياس خطورة من 0 إلى 10

مدة المعالجة
الأيام المسموحة لإصلاح كل مستوى

إدارة الثغرات: المتطلبات والفحص الدوري

الضابط	المطلوب	كيف تطبقه	الدليل
2-10-1 توثيق واعتماد	**تحديد متطلبات إدارة الثغرات وتوثيقها واعتمادها**	سياسة تحدد النطاق وتكرار الفحص ومستويات الخطورة ومدة المعالجة لكل مستوى	السياسة المعتمدة بجدول مدد المعالجة
2-10-2 تطبيق	**تطبيق المتطلبات**	أداة فحص تغطي كل الأصول، وسير عمل من الاكتشاف إلى الإغلاق في نظام تذاكر	تقارير الفحص، وتذاكر المعالجة، ونسب الالتزام بالمدد
2-10-3-1 حد أدنى	**تقييم الثغرات واكتشافها دورياً**	فحص مجدول بصلاحيات دخول للأنظمة الداخلية، وفحص خارجي للخدمات المواجهة للإنترنت	جدول الفحص، وتقارير لفترات متتالية، ونسبة التغطية مقابل سجل الأصول
2-10-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة السياسة، ونسب التغطية، ومتوسط زمن المعالجة	تقرير المراجعة ومؤشراته

التصنيف والمعالجة والتحديثات والمصادر

الضابط	المطلوب	كيف تطبقه	الدليل
2-10-3-2 حد أدنى	**تصنيف الثغرات حسب خطورتها**	مقياس معتمد مثل CVSS، مع تعديل حسب أهمية الأصل وتعرضه للإنترنت	معايير التصنيف في السياسة، وتطبيقها في التقارير
2-10-3-3 حد أدنى	**معالجة الثغرات حسب تصنيفها والمخاطر المرتبطة بها**	مدة معالجة لكل مستوى، واستثناء بقبول مخاطر معتمد وضوابط بديلة	تقارير متابعة المعالجة، وسجل الاستثناءات المعتمدة
2-10-3-4 حد أدنى	**إدارة التحديثات للمعالجة، مع التحقق من سلامتها وفعاليتها في بيئة غير إنتاجية قبل التطبيق**	اختبار التحديث في بيئة غير إنتاجية، ثم نشره وفق إدارة التغيير	سجل اختبار التحديثات قبل الإنتاج، وطلبات التغيير المرتبطة
2-10-3-5 حد أدنى	**التواصل والاشتراك مع مصادر موثوقة للثغرات الجديدة**	اشتراك في تنبيهات الجهات الوطنية والموردين، وإجراء لتقييم كل تنبيه	الاشتراكات، وسجل التنبيهات المستلمة والإجراء المتخذ

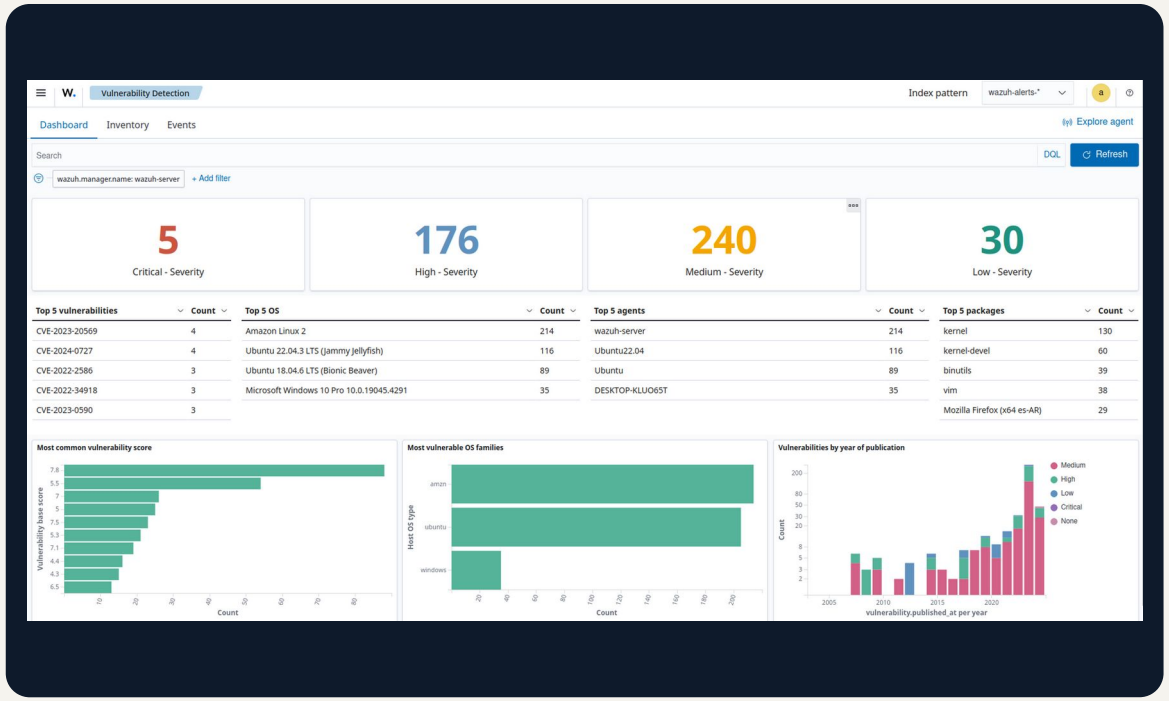
كيف يبدو الدليل: تقرير فحص الثغرات

ما الذي تراه

1. عدد الثغرات المكتشفة حسب الخطورة: حرجة وعالية ومتوسطة ومنخفضة.
2. الأنظمة والحزم الأكثر تأثراً.
3. معرّفات الثغرات العالمية (CVE) الأكثر انتشاراً.

ما الذي يبحث عنه المقيّم

- تقارير متتالية لفترات مختلفة تظهر الاتجاه.
- نسبة الأصول المفحوصة مقابل سجل الأصول.
- تذاكر معالجة بمدد تطابق السياسة، وقبول مخاطر لما تأخر.



صورة حقيقية من الإنترنت للتوضيح · GPL-2.0 · Wazuh, Inc.+ · المصدر: GitHub · wazuh/wazuh-documentation

يثبت: `2-10-3-1` `2-10-3-2` `2-10-3-3`

2-11 اختبار الاختراق

هدف الوثيقة تقييم مدى فعالية قدرات الدفاع لدى الجهة، بمحاكاة أساليب الهجوم الحقيقية وتقنياته، لاكتشاف نقاط ضعف غير معروفة قد تؤدي إلى اختراق الجهة.

ببساطة

تكليف مختصين بمهاجمة خدمات الجهة المتاحة عبر الإنترنت بشكل مصرح ومنظم، لاكتشاف ما يمكن أن يستغله مهاجم حقيقي.

مثال من الحياة

مثل تكليف خبير أقفال بمحاولة دخول بيتك بإذنك: يكشف لك الطريق قبل أن يكتشفه اللص.

ماذا لو غاب؟

تطبيق جوال أو بوابة دخول عن بعد لم تُختبر قط، فيكتشف المهاجم ثغرتها قبلك.

نطاق الاختبار
الأنظمة المسموح باختبارها

قواعد الاشتباك
حدود الاختبار وتوقيته وموافقاته

إعادة الاختبار
التأكد من إغلاق الثغرات بعد إصلاحها

اختبار الاختراق: المتطلبات والتطبيق والنطاق

الضابط	المطلوب	كيف تطبقه	الدليل
2-11-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة تحدد النطاق والتكرار والمنهجية ومؤهلات المختبرين وقواعد الاشتباك	السياسة المعتمدة
2-11-2 تطبيق	**تطبيق المتطلبات**	اختبارات من فريق مؤهل مستقل، بخطاب تفويض وقواعد اشتباك موقعة	خطاب التفويض، وتقارير الاختبار، وخطة معالجة النتائج
2-11-3-1 حد أدنى	**النطاق: كل الخدمات المقدمة عبر الإنترنت ومكوناتها: البنية، والمواقع، وتطبيقات الويب والجوال، والبريد، والدخول عن بعد**	استخراج النطاق من سجل الأصول ومطابقته مع فحص خارجي يكتشف ما لم يُسجل	وثيقة النطاق مطابقة لقائمة الأصول المواجهة للإنترنت

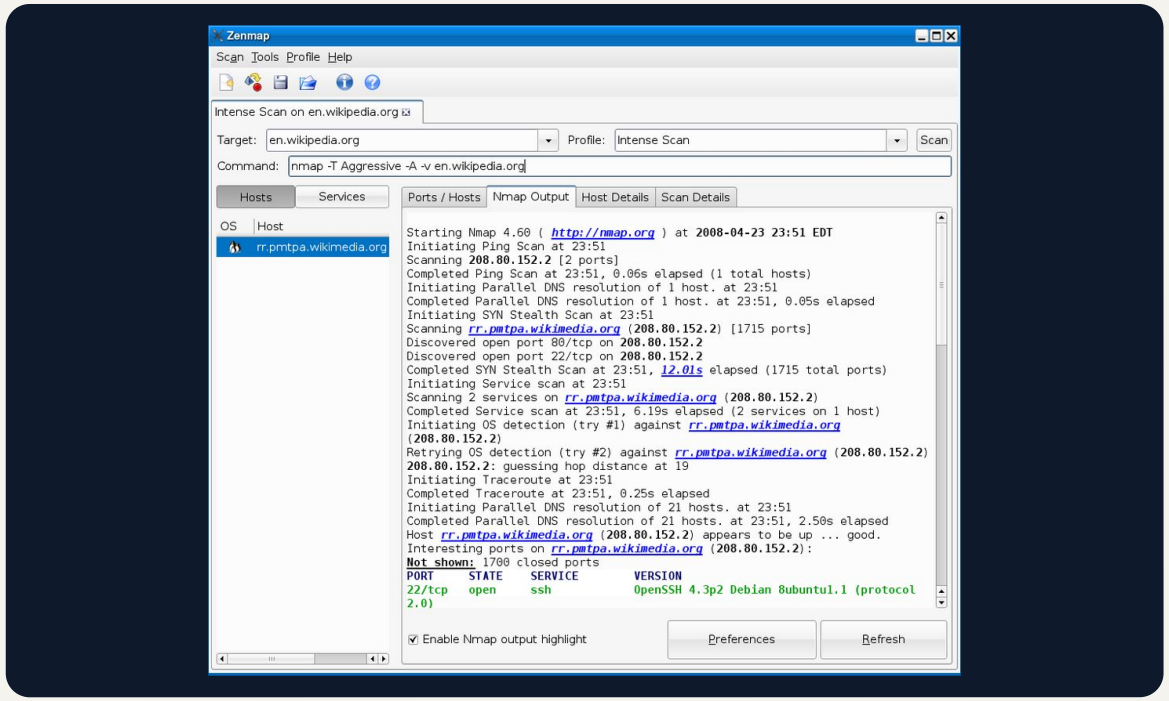
اختبار الاختراق: الدورية والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
2-11-3-2 حد أدنى	**إجراء الاختبارات دورياً**	جدول دوري معتمد، وإعادة اختبار بعد المعالجة وبعد التغييرات الجوهرية	تقارير لدورات متتالية، وتقارير إعادة الاختبار
2-11-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة النطاق والتكرار ونسب إغلاق النتائج	تقرير المراجعة

خطأ شائع

نطاق أضيق من الواقع: اختبار الموقع الرئيسي وإغفال تطبيق الجوال أو بوابة الدخول عن بعد. ابدأ من فحص خارجي يكشف كل ما هو مكشوف فعلاً.

كيف يبدو الدليل: فحص المنافذ المكشوفة للإنترنت



صورة حقيقية من الإنترنت للتوضيح · GPL-2.0 · Zenmap · Am088+ · المصدر: Wikimedia Commons

ما الذي تراه

1. أداة فحص تعرض المنافذ المفتوحة على العنوان المفحوص.
2. لكل منفذ الخدمة التي تعمل عليه.
3. هذا الفحص من أول خطوات أي اختبار اختراق.

ما الذي يبحث عنه المقيّم

- أن نطاق الاختبار يشمل كل ما كشفه الفحص الخارجي.
- خطاب تفويض وقواعد اشتباك موقعة قبل الاختبار.
- تقرير الاختبار مع خطة معالجة وإعادة اختبار.

يثبت: 2-11-3-1 2-11-2 2-5-3-5

2-12 إدارة سجلات الأحداث ومراقبة الأمن السيبراني

هدف الوثيقة جمع السجلات وتحليلها ومراقبتها في الوقت المناسب، للاكتشاف الاستباقي للهجمات وإدارتها بفعالية.

ببساطة

تسجيل ما يحدث في الأنظمة المهمة، وجمعه في منصة مركزية تراقبه باستمرار وتنبه عند المشبوه، والاحتفاظ بالسجلات 12 شهراً على الأقل.

مثال من الحياة

مثل كاميرات المراقبة مع حارس يشاهدها: الكاميرا وحدها تسجل، والحارس هو من يكتشف ويتصرف.

ماذا لو غاب؟

المهاجم داخل الشبكة أسابيع دون أن يلاحظه أحد، وحين تقع الحادثة لا توجد سجلات تكشف ما حدث.

SIEM
منصة جمع السجلات وتحليلها

حالة الاستخدام
قاعدة تحوّل السجلات إلى تنبيه

مدة الاحتفاظ
12 شهراً على الأقل

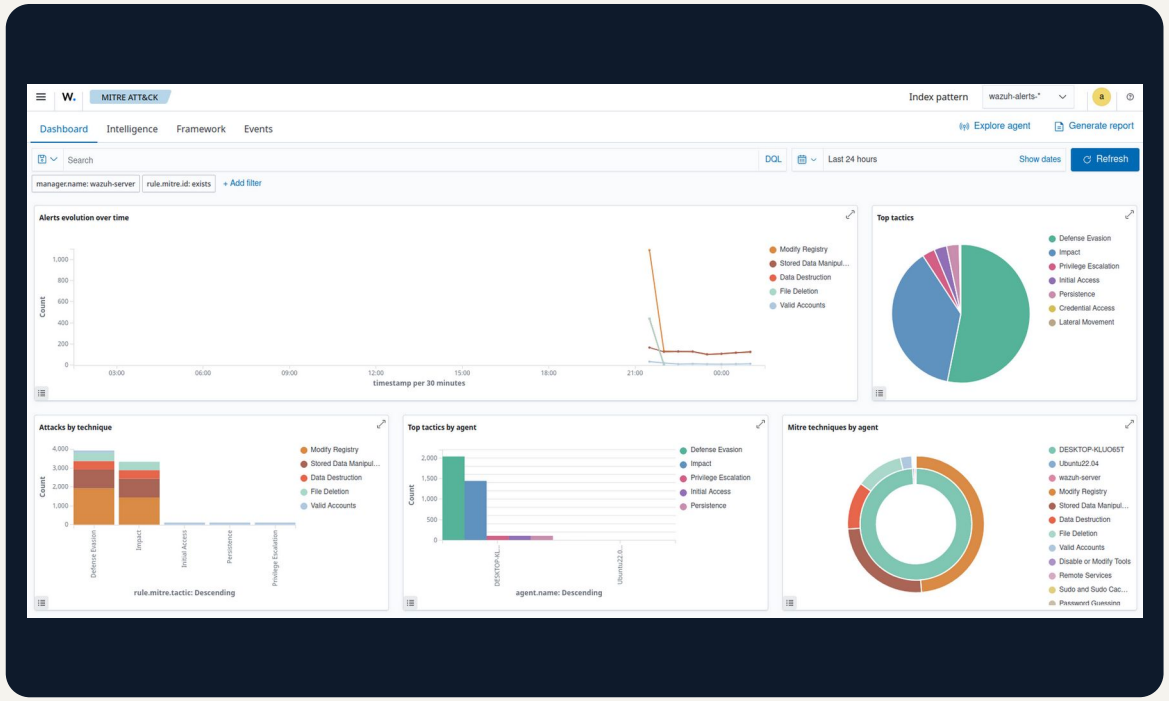
السجلات والمراقبة: المتطلبات والأصول الحساسة

الضابط	المطلوب	كيف تطبقه	الدليل
2-12-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة تحدد مصادر السجلات وحالات الاستخدام ومدد الاحتفاظ والأدوار	السياسة المعتمدة
2-12-2 تطبيق	**تطبيق المتطلبات**	منصة مركزية لإدارة الأحداث، ومراقبة من مركز عمليات داخلي أو مُدار	قائمة المصادر المربوطة، وحالات الاستخدام المفعلة
2-12-3-1 حد أدنى	**تفعيل سجلات الأحداث للأصول المعلوماتية الحساسة**	تفعيل السجلات على كل أصل حساس وربطها بالمنصة، ومراقبة انقطاع أي مصدر	مطابقة الأصول الحساسة في السجل مع المصادر المربوطة بالمنصة
2-12-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة التغطية وحالات الاستخدام وزمن الاستجابة للتنبيهات	تقرير المراجعة ومؤشراته

الحسابات المميزة والمراقبة والاحتفاظ

الضابط	المطلوب	كيف تطبقه	الدليل
2-12-3-2 حد أدنى	**تفعيل السجلات للحسابات ذات الصلاحيات الهامة والحساسة، ولأحداث الدخول عن بعد**	إرسال سجلات الدليل النشط وإدارة الصلاحيات والدخول عن بعد للمنصة، بحالات استخدام لها	عينة أحداث لحسابات مميزة ودخول عن بعد ظاهرة في المنصة
2-12-3-3 حد أدنى	**تحديد تقنيات إدارة الأحداث (SIEM) اللازمة لجمع السجلات**	اختيار المنصة وتوثيق معمارية الجمع والتخزين	وثيقة المعمارية، وقائمة المصادر
2-12-3-4 حد أدنى	**المراقبة المستمرة لسجلات الأحداث**	مراقبة مستمرة بتغطية تحددها السياسة، داخلياً أو عبر مركز مُدار داخل المملكة، مع فرز وتصعيد	جداول المناوبة أو عقد الخدمة، وتذاكر تنبيهات معالجة لفترات مختلفة
2-12-3-5 حد أدنى · وطني	**الاحتفاظ بالسجلات 12 شهراً على الأقل**	إعداد الاحتفاظ في المنصة أو الأرشيف، وتخطيط السعة اللازمة	إعداد الاحتفاظ، وأقدم سجل متاح للاستعلام

كيف يبدو الدليل: لوحة منصة المراقبة



صورة حقيقية من الإنترنت للتوضيح · GPL-2.0 · Wazuh, Inc.+ · المصدر: GitHub · wazuh/wazuh-documentation

ما الذي تراه

1. منصة تجمع الأحداث من مصادر متعددة في مكان واحد.
2. تنبيهات مصنفة حسب أساليب الهجوم (MITRE ATT&CK).
3. رسوم بيانية لحجم التنبيهات عبر الزمن ولكل جهاز.

ما الذي يبحث عنه المقيّم

- قائمة المصادر المربوطة مقابل الأصول الحساسة.
- حالات استخدام مفعلة، وتذاكر معالجة لتنبيهات حقيقية.
- إعداد الاحتفاظ، وإمكانية الاستعلام عن حدث قبل 11 شهراً.

يثبت: 2-12-2 2-12-3-4 2-12-3-5

كيف يبدو الدليل: تغطية مصادر السجلات

ما الذي تراه

1. كل أصل حساس، وهل سجلاته مربوطة بالمنصة.
2. وقت آخر حدث وصل من كل مصدر.
3. مصدر متوقف منذ شهرين دون أن ينتبه أحد، ومصدر لم يُربط.

ما الذي يبحث عنه المقيّم

- أن قائمة الأصول الحساسة مأخوذة من سجل الأصول.
- تنبيهاً آلياً عند انقطاع أي مصدر.
- أن الحسابات المميزة والدخول عن بعد مشمولة كما ينص 2-12-3-2.

مطابقة الأصول الحساسة بمصادر السجلات · 2026-09-30

المصدر	مربوط بالمنصة	آخر حدث مستلم
الدليل النشط	نعم	قبل دقيقتين
بوابة الشبكة الافتراضية	نعم	قبل 5 دقائق
قاعدة بيانات الرواتب	نعم	متوقف منذ 63 يوماً
الجدار الناري الخارجي	نعم	قبل دقيقة
نظام الصلاحيات المميزة	لا	لم يُربط بعد

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 2-12-3-1 2-12-3-2

2-13 إدارة حوادث وتهديدات الأمن السيبراني

هدف الوثيقة اكتشاف الحوادث في الوقت المناسب وإدارتها بفعالية، والتعامل الاستباقي مع التهديدات، وفق الأمر السامي 37140.

ببساطة

الاستعداد للحوادث السيبرانية والتعامل معها: خطط استجابة، وتصنيف للحادثة، وتصعيد، وإبلاغ الهيئة، ومشاركة معلومات التهديدات.

مثال من الحياة

مثل خطة الإخلاء والإطفاء في المبنى: كل شخص يعرف دوره مسبقاً، ولا يُرتجل شيء وقت الحريق.

ماذا لو غاب؟

ارتباك وقت الهجوم: لا أحد يعرف من يقرر فصل الأنظمة، ويتأخر إبلاغ الهيئة فيتسع الضرر.

دليل الاستجابة
خطوات محددة لكل نوع حادثة

التصعيد
رفع الحادثة لمن يملك القرار

تمرين المحاكاة
اختبار الخطة على سيناريو افتراضي

الحوادث: المتطلبات والخطط والتصعيد

الضابط	المطلوب	كيف تطبقه	الدليل
2-13-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة وإجراءات تغطي دورة الحادثة من الاكتشاف إلى الدروس المستفادة	السياسة والإجراءات المعتمدة
2-13-2 تطبيق	**تطبيق المتطلبات**	فريق استجابة محدد الأدوار، وسجل حوادث، وأدوات للتحقيق وجمع الأدلة	سجل الحوادث وتقاريرها لفترة
2-13-3-1 حد أدنى	**خطط الاستجابة للحوادث وإجراءات التصعيد**	أدلة استجابة لأهم السيناريوهات كالفدية والتصيد والتسرب، ومصفوفة تصعيد بالأسماء، وتمارين محاكاة	الخطط وأدلة الاستجابة، ومصفوفة التصعيد، وتقارير تمارين المحاكاة
2-13-4 مراجعة دورية	**مراجعة تطبيق المتطلبات دورياً**	مراجعة بعد كل حادثة كبيرة، وفي موعد مخطط	تقارير الدروس المستفادة والمراجعة

التصنيف والإبلاغ والمشاركة ومعلومات التهديدات

الضابط	المطلوب	كيف تطبقه	الدليل
2-13-3-2 حد أدنى	**تصنيف الحوادث**	مستويات خطورة بمعايير واضحة: الأثر على الخدمات والبيانات والانتشار، ترتبط بالتصعيد	معايير التصنيف المعتمدة، وتصنيف كل حادثة في السجل
2-13-3-3 حد أدنى · وطني	**إبلاغ الهيئة بالحوادث السيبرانية**	إجراء يحدد ما يُبلَّغ عنه، ومن يبلغ، والقناة، والمهلة، وفق تعليمات الهيئة	إجراء الإبلاغ، وسجل البلاغات المرسلة ومراسلاتها
2-13-3-4 حد أدنى · وطني	**مشاركة التنبيهات ومعلومات التهديدات ومؤشرات الاختراق وتقارير الحوادث مع الهيئة**	مسؤول محدد وقناة معتمدة، والمشاركة خطوة ضمن إجراء ما بعد الحادثة	سجل المشاركات مع الهيئة
2-13-3-5 حد أدنى	**جمع معلومات التهديدات والتعامل معها**	مصادر معلومات تهديدات موثوقة، وتحويل المؤشرات إلى قواعد حجب واكتشاف	المصادر المشترك فيها، وأمثلة مؤشرات طُبقت في أدوات الحماية

كيف يبدو الدليل: تمرين محاكاة للاستجابة



صورة حقيقية من الإنترنت للتوضيح · Sgt. Yohannes Mogos · U.S. Army National Guard · ملكية عامة · المصدر: Wikimedia Commons

ما الذي تراه

1. فريق من إدارات مختلفة يناقش سيناريو حادثة افتراضية.
2. كل مشارك يمثل دوره في خطة الاستجابة.
3. التمرين يكشف ثغرات الخطة قبل الحادثة الحقيقية.

ما الذي يبحث عنه المقيّم

- تقرير التمرين: السيناريو، والحضور، والدروس، والإجراءات.
- تحديث الخطط ومصفوفة التصعيد بناءً على الدروس.
- سجل حوادث حقيقي مصنف، وبلاغات للهيئة عند لزومها.

يثبت: 2-13-3-1 2-13-3-2 2-13-4

2-14 الأمن المادي

هدف الوثيقة حماية الأصول المعلوماتية والتقنية من الوصول المادي غير المصرح به، والفقدان، والسرقة، والتخريب.

ببساطة

حماية الأماكن والمعدات: من يدخل مركز البيانات وغرف الشبكات، وتسجيل الدخول والكاميرات، والإتلاف الآمن للأجهزة والوثائق.

مثال من الحياة

مثل خزينة البنك: باب مقفل، وقائمة بمن يحق له الدخول، وكاميرا، وسجل لكل دخول.

ماذا لو غاب؟

شخص غير مصرح يدخل غرفة الخوادم، أو قرص قديم يُعاد للمورد وعليه بيانات الجهة.

المنطقة الحساسة
مكان يحتاج دخولاً مصرحاً

سجل الدخول
من دخل ومتى

الإتلاف الآمن
إتلاف يمنع استرجاع البيانات

الأمن المادي: المتطلبات والدخول المصرح

الضابط	المطلوب	كيف تطبقه	الدليل
2-14-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	سياسة أمن مادي بالتنسيق مع إدارة الأمن والسلامة، تحدد المناطق الحساسة	السياسة، وقائمة المناطق الحساسة المعتمدة
2-14-2 تطبيق	**تطبيق المتطلبات**	ضوابط دخول ومراقبة تتدرج حسب حساسية كل منطقة	جولة ميدانية موثقة، وإعدادات أنظمة الدخول
2-14-3-1 حد أدنى	**الدخول المصرح به للمناطق الحساسة: مراكز البيانات والتعافي، وغرف الشبكات، ومركز المراقبة**	قائمة معتمدة لكل منطقة، وبطاقات دخول، وتسجيل الزوار ومرافقتهم	قوائم المصرح لهم، ومطابقتها مع صلاحيات نظام الدخول، وسجل الزوار
2-14-4 مراجعة دورية	**مراجعة المتطلبات دورياً**	مراجعة المتطلبات، وقوائم المصرح لهم مقابل الحاجة الفعلية	تقرير المراجعة

السجلات والكاميرات والإتلاف والأجهزة

الضابط	المطلوب	كيف تطبقه	الدليل
2-14-3-2 حد أدنى	**سجلات الدخول والمراقبة بالكاميرات**	تسجيل كل دخول للمناطق الحساسة، وكاميرات تغطي مداخلها	سجلات الدخول لفترة، ولقطات من نظام المراقبة تثبت التغطية
2-14-3-3 حد أدنى	**حماية معلومات سجلات الدخول والمراقبة**	تقييد الوصول لأنظمة الدخول والمراقبة، ومدة احتفاظ معتمدة، وحماية من التعديل	صلاحيات الوصول لهذه الأنظمة، وإعداد الاحتفاظ
2-14-3-4 حد أدنى	**أمن إتلاف الأصول المادية المصنفة وإعادة استخدامها، ومنها الوثائق الورقية ووسائط التخزين**	إتلاف آمن حسب التصنيف، ومحو معتمد قبل إعادة الاستخدام، وتوثيق كل عملية	الإجراء المعتمد، ومحاضر أو شهادات الإتلاف لعينة أصول
2-14-3-5 حد أدنى	**أمن الأجهزة والمعدات داخل مباني الجهة وخارجها**	تأمين الأجهزة داخل المباني، وقواعد لإخراجها وحمايتها خارجها	نماذج إخراج الأجهزة، وسجل الأجهزة خارج المباني

كيف يبدو الدليل: ضوابط الدخول والمراقبة المادية





صور حقيقية من الإنترنت للتوضيح · Kent Madsen · CC BY-SA | Ca.garcia.s · CC BY-SA 4.0 · المصدر: Wikimedia Commons

ما الذي تراه

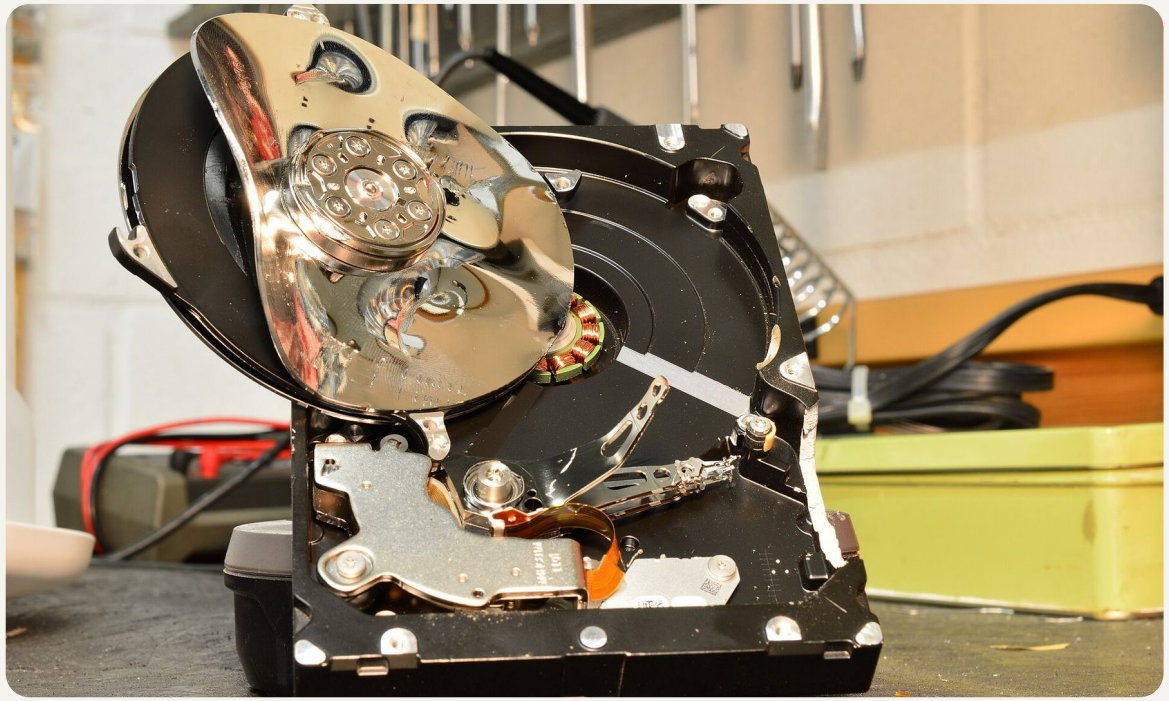
1. قارئ بطاقات يفتح الباب لحاملي البطاقات المصرح لهم فقط.
2. كاميرا تغطي مدخل المنطقة الحساسة.
3. كلاهما ينتج سجلاً: من دخل ومتى.

ما الذي يبحث عنه المقيّم

- قائمة المصرح لهم مطابقة لصلاحيات نظام الدخول.
- سجلات الدخول ولقطات تثبت التغطية لفترة.
- حماية هذه السجلات نفسها وتقييد الوصول إليها (2-14-3-3).

يثبت: 2-14-3-1 2-14-3-2 2-14-3-3

كيف يبدو الإتلاف الآمن للوسائط



صورة حقيقية من الإنترنت للتوضيح · CC BY-SA 4.0 · Jaroslaw B (Yarkob) · المصدر: Wikimedia Commons

ما الذي تراه

1. قرص صلب أُتلف مادياً فلا يمكن استرجاع بياناته.
2. الإتلاف يُوثَّق لكل أصل برقمه التسلسلي.
3. يشمل الوثائق الورقية ووسائط التخزين.

ما الذي يبحث عنه المقيّم

- إجراءً معتمداً للإتلاف حسب التصنيف.
- شهادات أو محاضر إتلاف لعينة أصول من سجل الأصول.
- محواً آمناً موثقاً قبل إعادة استخدام أي جهاز.

يثبت: 2-14-3-4

2-15 حماية تطبيقات الويب

هدف الوثيقة حماية تطبيقات الويب الخارجية للجهة من المخاطر السيبرانية.

ببساطة

حماية المواقع والبوابات المتاحة للجمهور: جدار حماية للتطبيقات، ومعمارية متعددة المستويات، واتصال مشفر، وتحقق مناسب من المستخدمين.

مثال من الحياة

مثل واجهة محل على الشارع: الجميع يراها، فتحتاج زجاجاً متيناً وحارساً، ولا تُترك الخزنة خلف الزجاج مباشرة.

ماذا لو غاب؟

ثغرة في البوابة الإلكترونية تكشف بيانات المستفيدين لأي شخص على الإنترنت.

WAF
جدار حماية تطبيقات الويب

المعمارية متعددة المستويات
فصل العرض والتطبيق وقاعدة البيانات

HTTPS
اتصال مشفر بين المستخدم والموقع

تطبيقات الويب: المتطلبات وجدار الحماية

الضابط	المطلوب	كيف تطبقه	الدليل
2-15-1 توثيق واعتماد	**تحديد متطلبات حماية تطبيقات الويب الخارجية وتوثيقها واعتمادها**	معيار لتطبيقات الويب يغطي البنود الخمسة، ويرتبط بالتطوير الآمن في 3-6-1	المعيار المعتمد
2-15-2 تطبيق	**تطبيق المتطلبات**	حصر كل تطبيقات الويب الخارجية، وتطبيق المعيار على كل منها	قائمة التطبيقات وحالة امتثال كل منها
2-15-3-1 حد أدنى	**استخدام جدار حماية تطبيقات الويب (WAF)**	كل تطبيق خارجي خلف جدار حماية بوضع المنع وقواعد محدثة	قائمة التطبيقات المحمية مقابل كل التطبيقات، وإعدادات وضع المنع
2-15-4 مراجعة دورية	**مراجعة المتطلبات دورياً**	مراجعة المعيار وحالة امتثال التطبيقات ونتائج اختبارها	تقرير المراجعة

المعمارية والبروتوكولات والتحقق

الضابط	المطلوب	كيف تطبقه	الدليل
2-15-3-2 حد أدنى	**اعتماد مبدأ المعمارية متعددة المستويات**	فصل طبقات العرض والتطبيق وقواعد البيانات في مناطق شبكية مختلفة	مخطط معمارية كل تطبيق، وقواعد الجدار الناري بين الطبقات
2-15-3-3 حد أدنى	**استخدام بروتوكولات آمنة مثل HTTPS**	HTTPS إلزامي مع إعادة توجيه، وإعدادات تشفير وفق المعايير الوطنية للتشفير	نتيجة فحص خارجي لإعدادات التشفير لكل تطبيق
2-15-3-4 حد أدنى	**توضيح سياسة الاستخدام الآمن للمستخدمين**	سياسة استخدام منشورة في التطبيق، وإرشادات أمان للمستخدمين	رابط السياسة في كل تطبيق
2-15-3-5 حد أدنى	**التحقق من هوية المستخدمين بعوامل وتقنيات يحددها تقييم أثر فشل التحقق أو تجاوزه**	تقييم أثر لكل تطبيق ثم مستوى التحقق المناسب، كالتحقق متعدد العوامل أو التكامل مع النفاذ الوطني الموحد حيث يناسب	تقييم الأثر لكل تطبيق، وإعدادات التحقق المطبقة

كيف يبدو الدليل: سجل تطبيقات الويب الخارجية

ما الذي تراه

1. كل تطبيق ويب خارجي، وحالة الضوابط الأساسية عليه.
2. تطبيقان منسيان بلا جدار حماية، أحدهما بلا تشفير.
3. تطبيق خلف الجدار لكن بوضع المراقبة فقط.

ما الذي يبحث عنه المقيّم

- أن الحصر جاء من فحص خارجي للنطاقات والعناوين، لا من الذاكرة.
- وضع المنع على كل تطبيق، أو مدة محددة للمراقبة.
- تقييم أثر يحدد مستوى التحقق لكل تطبيق (2-15-3-5).

سجل تطبيقات الويب الخارجية وحالة حمايتها · 2026-09

التطبيق	جدار الحماية	HTTPS	التحقق
البوابة الإلكترونية	وضع المنع	نعم	متعدد العوامل
نظام المواعيد	مراقبة فقط	نعم	كلمة مرور فقط
موقع حملة قديمة	لا	لا	لا يوجد
بيئة اختبار مكشوفة	لا	نعم	كلمة مرور فقط

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 2-15-2 2-15-3-1 2-15-3-5

تمرين 6 · مجموعات · 25 دقيقة

حادثة فدية افتراضية: أين انكسرت الضوابط؟

لكل مرحلة: أي ضابط كان سيمنعها أو يكشفها أو يحد من أثرها؟ وما الدليل الذي سيطلبه المقيّم بعد الحادثة؟

1. موظف يفتح مرفقاً ضاراً في رسالة تصيد.
2. البرمجية الضارة تعمل على الجهاز دون أي اكتشاف.
3. المهاجم يستولي على حساب مدير نظام بلا تحقق متعدد العوامل.
4. نشاطه داخل الشبكة يستمر أسبوعين دون تنبيه.
5. التشفير يصيب الخوادم والنسخ الاحتياطية المتصلة بالشبكة معاً.
6. الجهة تتأخر في إبلاغ الهيئة لأنها «تجمع المعلومات أولاً».

حل التمرين 6

سلسلة الضوابط التي انكسرت

المرحلة	الضوابط	الدليل الذي سيُطلب
1 · رسالة التصيد	1-10-3-1 · 2-4-3-4-1 · 2-4-3-1	إعدادات التصفية وتحليل المرفقات، ونتائج التوعية
2 · التنفيذ دون اكتشاف	2-3-3-1	تغطية الحماية على الجهاز وحالة تحديثها
3 · حساب المدير	2-2-3-4 · 2-2-3-2	تقييم الأثر، ومطابقة الحسابات المميزة مع التحقق
4 · أسبوعان دون تنبيه	2-12-3-4 · 2-12-3-2	مصادر السجلات، وحالات الاستخدام، والمراقبة
5 · النسخ المشفرة	2-9-3-3 · 2-9-3-2	نسخة معزولة، واختبارات استعادة سابقة
6 · تأخر الإبلاغ	2-13-3-3 · 2-13-3-2	إجراء الإبلاغ، وتصنيف الحادثة، وتوقيت البلاغ

الوحدة 07 · المكونان الأساسيان 3 و4

07 الصمود والأطراف الخارجية والسحابة

ما يمتد خارج حدود الأنظمة: استمرار الخدمات رغم الحوادث، وحماية البيانات لدى الموردين ومزودي السحابة.

3-1	الأمن السيبراني في استمرارية الأعمال	الشريحة 145
4-1	الأطراف الخارجية	الشريحة 149
4-2	الحوسبة السحابية والاستضافة	الشريحة 153

3-1 الأمن السيبراني في استمرارية الأعمال

هدف الوثيقة تضمين صمود الأمن السيبراني في استمرارية الأعمال، والحد من أثر الاضطرابات السيبرانية على الخدمات الإلكترونية الحساسة.

ببساطة

ضمان أن الخدمات الحساسة تستمر أو تعود بسرعة رغم الحوادث السيبرانية، وأن أنظمة الحماية نفسها تعمل في موقع التعافي.

مثال من الحياة

مثل المولد الاحتياطي في المستشفى: لا يكفي وجوده، بل يُشغَّل ويُختبر، ويغذي الأقسام الحرجة أولاً.

ماذا لو غاب؟

توقف خدمة حساسة أياماً بعد هجوم، أو التحول إلى موقع تعافٍ بلا حماية ولا مراقبة.

تحليل الأثر على الأعمال
تحديد الخدمات الحساسة وأولوياتها

موقع التعافي
موقع بديل لتشغيل الأنظمة

خطة التعافي
خطوات إعادة الأنظمة والبيانات

الاستمرارية: المتطلبات والتطبيق واستمرار أنظمة الحماية

الضابط	المطلوب	كيف تطبقه	الدليل
3-1-1 توثيق واعتماد	**تحديد المتطلبات وتوثيقها واعتمادها**	إدراج المتطلبات في سياسة استمرارية الأعمال، بالتنسيق مع مالكها في الجهة	السياسة المعتمدة بمتطلباتها السيبرانية
3-1-2 تطبيق	**تطبيق المتطلبات**	تحليل أثر يحدد الخدمات الحساسة وأهداف استعادتها، ثم خطط مبنية عليه	تحليل الأثر على الأعمال، والخطط المعتمدة المبنية عليه
3-1-3-1 حد أدنى	**ضمان استمرارية أنظمة وإجراءات الأمن السيبراني**	تضمين أنظمة الحماية والمراقبة في خطط الاستمرارية، وتوفيرها في موقع التعافي	الخطة تشمل أنظمة الأمن السيبراني، وإعدادات الحماية في موقع التعافي
3-1-4 مراجعة دورية	**مراجعة المتطلبات دورياً**	مراجعة بعد كل اختبار أو حادثة، وفي موعد مخطط	تقرير المراجعة

خطط الاستجابة والاستمرارية والتعافي

الضابط	المطلوب	كيف تطبقه	الدليل
3-1-3-2 حد أدنى	**خطط للاستجابة للحوادث السيبرانية التي قد تؤثر على استمرارية الأعمال**	سيناريوهات سيبرانية في خطط الاستمرارية، كالفدية وحجب الخدمة واختراق مزود، مرتبطة بخطط 2-13	الخطط بسيناريوهاتها السيبرانية، وتقارير تمارينها
3-1-3-3 حد أدنى	**وضع خطط التعافي من الكوارث**	خطة لكل نظام حساس بأهداف استعادة، وموقع تعافٍ، واختبار دوري	خطط التعافي المعتمدة، وتقارير اختبارها وزمن الاستعادة الفعلي

01
الاستجابة للحوادث · 2-13
احتواء الهجوم، والتحقيق، والإبلاغ.

02
الاستمرارية · 3-1-3-2
استمرار الخدمات الحساسة أثناء الحادثة.

03
التعافي · 3-1-3-3
إعادة الأنظمة والبيانات بعد الكارثة.

كيف يبدو الدليل: تقرير تمرين التعافي

ما الذي تراه

1. سيناريو سيبراني، لا عطلاً عادياً فقط.
2. الزمن الفعلي مقارنة بهدف الاستعادة المعتمد.
3. بنود تتحقق أن الحماية والمراقبة تعمل في الموقع البديل.

ما الذي يبحث عنه المقيّم

- أن التمرين يختبر الخطط الثلاث معاً على سيناريو واحد.
- معالجة ما فشل، مثل انقطاع السجلات، في الخطة المحدثة.
- تمارين دورية بتواريخ، لا تميناً واحداً.

تقرير تمرين التعافي من الكوارث · خدمة البوابة الإلكترونية

تاريخ التمرين	2026-08-27
السيناريو	هجوم فدية على مركز البيانات الرئيسي
هدف الاستعادة	تشغيل البوابة من موقع التعافي خلال 8 ساعات
الزمن الفعلي	6 ساعات و40 دقيقة

- جدار حماية تطبيقات الويب يعمل في موقع التعافي: نعم
- السجلات تصل إلى منصة المراقبة من موقع التعافي: لا، وأُضيفت للخطة
- التحقق متعدد العوامل للدخول الإداري: نعم

منسق الاستمرارية
التوقيع والتاريخ

ممثل الأمن السيبراني
التوقيع والتاريخ

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 3-1-3-1 3-1-3-3 3-1-4

4-1 الأمن السيبراني المتعلق بالأطراف الخارجية

هدف الوثيقة حماية أصول الجهة من مخاطر الأطراف الخارجية، بما فيها إسناد خدمات تقنية المعلومات، وإسناد الأمن السيبراني، والخدمات المُدارة.

ببساطة

التأكد أن الموردين والمقاولين ومقدمي الخدمات يحمون بيانات الجهة وخدماتها، ببنود واضحة في العقود، وتقييم مخاطر قبل التوقيع.

مثال من الحياة

مثل تسليم مفتاح بيتك لشركة صيانة: تختار شركة موثوقة، وتكتب شروطاً واضحة، وتستعيد المفتاح عند الانتهاء.

ماذا لو غاب؟

اختراق يأتي من مورد يملك دخولاً عن بعد لأنظمة الجهة، بلا شروط أمنية في عقده.

ملحق الأمن السيبراني
بنود موحدة تُرفق بالعقود

الخدمات المُدارة
خدمة يشغلها مورد للجهة

حق التدقيق
التحقق من التزام المورد

الأطراف الخارجية: المتطلبات وبنود العقود

الضابط	المطلوب	كيف تطبقه	الدليل
4-1-1 توثيق واعتماد	**تحديد متطلبات الأمن السيبراني في العقود والاتفاقيات وتوثيقها واعتمادها**	ملحق أمن سيبراني موحد للعقود، بالتنسيق مع المشتريات والشؤون القانونية	الملحق المعتمد، وإجراء المشتريات الذي يلزم به
4-1-2-1 بنود العقود	**عدم الإفصاح، والحذف الآمن لبيانات الجهة عند انتهاء الخدمة**	بند صريح في كل عقد يمس البيانات أو الخدمات، وشهادة حذف عند الانتهاء	عينة عقود بالبند، وشهادات حذف لعقود منتهية
4-1-2-2 بنود العقود	**إجراءات التواصل عند وقوع حادثة سيبرانية**	بند يلزم المورد بالإبلاغ خلال مدة محددة، وجهات اتصال معروفة للطرفين	البند في العقود، وقائمة جهات الاتصال المحدثة
4-1-2-3 بنود العقود	**إلزام الطرف الخارجي بمتطلبات الجهة وسياساتها والمتطلبات التشريعية**	بند إلزام، وحق التدقيق، وتقييم دوري لالتزام الموردين المهمين	البند، ونتائج تقييم التزام الموردين المهمين

الإسناد والخدمات المُدارة

الضابط	المطلوب	كيف تطبقه	الدليل
4-1-3-1 الإسناد والمُدارة	**تقييم المخاطر والتأكد من ضوابط معالجتها قبل توقيع العقد أو عند تغير المتطلبات**	تقييم مخاطر المورد والخدمة في مرحلة الطرح، وشروط المعالجة تُدرج في العقد	تقييمات مؤرخة قبل التوقيع، وخطط معالجة المخاطر المرتبطة
4-1-3-2 الإسناد والمُدارة · وطني	**مراكز الخدمات المدارة للمراقبة والتشغيل التي تستخدم الدخول عن بعد تكون بالكامل داخل المملكة**	شرط في كراسة الشروط والعقد، وتحقق من مواقع المحللين والبنية قبل الترسية	بند العقد، وإقرار المورد بمواقع التشغيل، ونتيجة التحقق
4-1-4 مراجعة دورية	**مراجعة متطلبات الأطراف الخارجية دورياً**	مراجعة الملحق، وسجل الموردين وحالة بنودهم، وتقييمات الموردين المهمين	تقرير المراجعة، وسجل الموردين المحدث

كيف يبدو الدليل: ملحق الأمن السيبراني في العقد

ما الذي تراه

1. ملحق موحد يُرفق بالعقد، وكل بند يذكر الضابط الذي يحققه.
2. بند صريح لموقع التشغيل داخل المملكة.
3. توقيع الطرفين، فالملحق جزء ملزم من العقد.

ما الذي يبحث عنه المقيّم

- عينة من العقود السارية، والبحث فيها عن البنود الثلاثة في 4-1-2.
- تقييم مخاطر مؤرخ قبل التوقيع (4-1-3-1).
- إقرار المورد بمواقع التشغيل وما يثبتها.

ملحق الأمن السيبراني · عقد خدمة مركز عمليات مُدار

رقم العقد CT-2026-118 · [اسم المورد]

- البند 3: السرية، والحذف الآمن عند الانتهاء (4-1-2-1)
- البند 4: الإبلاغ عن أي حادثة خلال [__] (4-1-2-2)
- البند 5: الالتزام بسياسات الجهة وحق التدقيق (4-1-2-3)
- البند 6: التشغيل عن بعد بالكامل داخل المملكة (4-1-3-2)

عن الجهة	عن المورد
التوقيع والتاريخ	التوقيع والتاريخ

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 4-1-2-1 4-1-2-2 4-1-2-3 4-1-3-2

4-2 الأمن السيبراني المتعلق بالحوسبة السحابية والاستضافة

هدف الوثيقة حماية أصول الجهة على الخدمات السحابية التي يستضيفها أو يعالجها أو يديرها طرف خارجي.

ببساطة

حماية أصول الجهة حين تُستضاف أو تُعالج لدى مزود سحابي: سياسة لما يُنقل إلى السحابة، وبنود لحماية البيانات وإعادتها، وفصل بيئة الجهة.

مثال من الحياة

مثل استئجار مستودع لدى شركة تخزين: البضاعة بضاعتك، فتشترط الحماية، وأن تستعيدها كاملة متى أردت.

ماذا لو غاب؟

بيانات حساسة في خدمة سحابية لا يعرف بها أحد، أو مزود لا يعيد البيانات إلا بصيغة لا تُقرأ.

المزود السحابي
جهة تستضيف خدمات الجهة

السحابة غير المعتمدة
خدمة تُستخدم دون علم التقنية

فصل البيئة
عزل بيانات الجهة عن عملاء المزود الآخرين

الحوسبة السحابية: المتطلبات والتطبيق والمراجعة

الضابط	المطلوب	كيف تطبقه	الدليل
4-2-1 توثيق واعتماد	**تحديد متطلبات استخدام السحابة والاستضافة وتوثيقها واعتمادها**	سياسة تحدد ما يُسمح بنقله للسحابة حسب التصنيف، وشروط اختيار المزود	السياسة المعتمدة
4-2-2 تطبيق	**تطبيق المتطلبات**	سجل بكل خدمة سحابية مستخدمة، وتقييم قبل اعتمادها، وإعدادات آمنة لحساباتها	سجل الخدمات السحابية وتقييماتها، وإعدادات الحسابات
4-2-4 مراجعة دورية	**مراجعة المتطلبات دورياً**	مراجعة السجل، وكشف الخدمات السحابية غير المعتمدة المستخدمة فعلاً	تقرير المراجعة

تذكّر

ينطبق على من يستخدم السحابة أو يخطط لاستخدامها، إضافة إلى ضوابط المكونات 1 و2 و3 و1-4 المنطبقة.

حماية البيانات وإعادتها وفصل البيئة

الضابط	المطلوب	كيف تطبقه	الدليل
4-2-3-1 حد أدنى	**حماية المزود لبيانات الجهة حسب تصنيفها، وإعادتها بصيغة قابلة للاستخدام عند انتهاء الخدمة**	بنود تربط الحماية بالتصنيف، وبند إعادة البيانات بصيغة ومدة محددتين ثم حذفها	بنود العقد، وتأكيد المزود لصيغة الإعادة، واختبار لتصدير البيانات
4-2-3-2 حد أدنى	**فصل بيئة الجهة، وخاصة الخوادم الافتراضية، عن بيئات الجهات الأخرى لدى المزود**	متطلب في العقد، وتوثيق المزود لآلية العزل، أو بيئة مخصصة للبيانات الحساسة	بند العقد، ووثائق المزود عن العزل، أو تقارير تدقيق مستقلة له

تسلسل مقترح قبل نقل أي نظام إلى السحابة

1 · التصنيف · 2-1-5 ← 2 · تقييم المخاطر · 3-3-5-1 ← 3 · العقد · 1-4 و2-4 ← 4 · الإعدادات الآمنة

كيف يبدو الدليل: سجل الخدمات السحابية

ما الذي تراه

1. كل خدمة سحابية تستخدمها الجهة، وتصنيف بياناتها.
2. تقييم مؤرخ قبل اعتماد كل خدمة.
3. خدمة غير معتمدة اكتُشفت بمراقبة حركة الإنترنت.

ما الذي يبحث عنه المقيّم

- أن السجل يشمل السحابة غير المعتمدة، لا ما اشترته التقنية فقط.
- بنود الحماية وإعادة البيانات في عقد كل خدمة.
- أن موقع الاستضافة يتوافق مع تصنيف البيانات والمتطلبات الوطنية.

سجل الخدمات السحابية · 2026-09

الخدمة السحابية	التصنيف	تقييم قبل الاعتماد	الحالة
البريد والتعاون	مقيد	نعم · 2025-11	معتمدة
نظام التوظيف	سري	نعم · 2026-03	معتمدة
مشاركة ملفات يستخدمها قسم	غير معروف	لا	غير معتمدة · اكتُشفت بالمراقبة
أداة استبيانات	عام	نعم · 2026-06	معتمدة

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

يثبت: 4-2-2 4-2-3-1 4-2-4

تمرين 7 · ثنائي · 20 دقيقة

راجع ستة بنود من عقدين

مقتطفات من عقد مركز عمليات مُدار وعقد استضافة سحابية. لكل بند: ما الضابط، وهل يحققه، وكيف تعيد صياغته؟

1. «يلتزم المورد بسرية المعلومات طوال مدة العقد».
2. «تُقدَّم المراقبة عن بعد من مركزين: في المملكة وفي دولة أخرى».
3. «تُذكر الحوادث الأمنية في التقرير الشهري للخدمة».
4. «يلتزم المورد بسياساته الأمنية الداخلية المعتمدة لديه».
5. «تُعاد البيانات عند انتهاء العقد بالصيغة التي يختارها المزود».
6. ملاحظة الملف: «أُجري تقييم المخاطر بعد شهرين من توقيع العقد».

حل التمرين 7

الحكم والصياغة البديلة

#	الضابط	الحكم	صياغة أفضل
1	4-1-2-1	جزئي: لا حذف ولا ما بعد العقد	السرية أثناء العقد وبعده، والحذف الآمن عند الانتهاء بشهادة
2	4-1-3-2	غير ممتثل	كل مراكز المراقبة والتشغيل عن بعد داخل المملكة بالكامل
3	4-1-2-2	ضعيف: التقرير الشهري متأخر	إبلاغ فوري بالحوادث خلال مدة محددة، بجهات اتصال معتمدة
4	4-1-2-3	غير ممتثل: سياسات المورد لا الجهة	الالتزام بمتطلبات الجهة وسياساتها والمتطلبات التشريعية، مع حق التدقيق
5	4-2-3-1	جزئي: الصيغة بيد المزود	إعادة البيانات بصيغة قابلة للاستخدام تُحدَّد في العقد، ثم حذفها
6	4-1-3-1	غير ممتثل: التقييم بعد التوقيع	جعل تقييم المخاطر شرطاً قبل الترسية في إجراء المشتريات

الوحدة 08 · ما بعد التطبيق

08 الاستدامة والجاهزية

كيف يبقى ما بنيناه حياً: حزمة وثائق محدثة، وتقويم مراجعات، ومؤشرات تُرفع للجنة، وجاهزية دائمة لتقييم الهيئة.

01 لماذا لا ينتهي الامتثال — الشريحة 160

02 حزمة الوثائق الأساسية — الشريحة 161

03 تقويم المراجعات الدورية — الشريحة 162

04 المؤشرات ولوحة اللجنة — الشريحة 163

05 الاستعداد لتقييم الهيئة — الشريحة 165

06 أخطاء التطبيق الشائعة — الشريحة 166

07 المشروع التطبيقي — الشريحة 167

لماذا لا ينتهي الامتثال بانتهاء المشروع؟

الامتثال يشبه صيانة السيارة: فحص اليوم لا يضمن سلامتها بعد سنة. أربعة أسباب تجعله عملاً مستمراً:

الأنظمة تتغير

أنظمة وموظفون وموردون جدد كل شهر، وكل تغيير قد يفتح فجوة لم تكن موجودة.

الضوابط تطلب المراجعة

في كل مكون فرعي تقريباً ضابط مراجعة دورية (X-4)، فالمراجعة جزء من الامتثال نفسه.

الأدلة لها تاريخ

دليل عمره سنتان لا يثبت الوضع اليوم. المقيّم يطلب أدلة حديثة ضمن فترة التقييم.

التهديدات تتطور

أساليب هجوم جديدة تجعل إعدادات الأمس غير كافية، فتتحدث المعايير والأدلة التشغيلية.

الفكرة الأساسية

الهدف في هذه الوحدة: تحويل ما بنيناه إلى نظام يعمل وحده طوال السنة، لا مشروع ينتهي بانتهاء الميزانية.

حزمة الوثائق الأساسية وضوابطها

الحوكمة

استراتيجية الأمن السيبراني	1-1
قرار الإدارة وميثاق اللجنة	1-2
الأدوار والمسؤوليات	1-4
منهجية إدارة المخاطر	1-5
الأمن في المشاريع والتغيير	1-6
سجل الالتزامات	1-7
خطة المراجعة والتدقيق	1-8
أمن الموارد البشرية	1-9
برنامج التوعية والتدريب	1-10

التعزيز (1)

الأصول والاستخدام المقبول والتصنيف	2-1
الهويات والصلاحيات	2-2
حماية الأنظمة ومعايير التقوية	2-3
البريد الإلكتروني	2-4
أمن الشبكات	2-5
الأجهزة المحمولة	2-6
حماية البيانات والتشفير	2-7 و2-8

التعزيز (2) والصمود والأطراف

النسخ الاحتياطية	2-9
الثغرات واختبار الاختراق	2-10 و2-11
السجلات والمراقبة	2-12
الحوادث والتهديدات	2-13
الأمن المادي وتطبيقات الويب	2-14 و2-15
الاستمرارية والتعافي	3-1
الأطراف الخارجية والسحابة	4-1 و4-2

كل وثيقة في الحزمة لها: مالك واضح · رقم إصدار · موعد مراجعة · اعتماد صاحب الصلاحية (1-3-1) · تعميم على المعنيين

تقويم الاستدامة السنوي

شهرياً

- تقارير الثغرات والتحديثات
- مؤشرات المراقبة والتنبيهات
- تحديث الأدلة التشغيلية
- مطابقة الحماية مع سجل الأصول

ربع سنوي

- مراجعة صلاحيات الأنظمة الحساسة
- تقرير للجنة الإشرافية
- اختبار استعادة لعينة
- محاكاة تصيد

نصف سنوي

- مراجعة قواعد الجدار الناري
- تمرين استجابة للحوادث
- مراجعة الحسابات المميزة

سنوياً

- مراجعة الوثائق ومراجعات X-4
- التقييم الذاتي الشامل
- المراجعة المستقلة
- اختبار الاختراق
- اختبار التعافي من الكوارث

عند الحدث

- مشروع أو تغيير جوهري
- عقد أو خدمة جديدة
- حادثة كبيرة
- تنظيم أو إصدار جديد
- تغيير تنظيمي في الجهة

⚠ الضوابط لا تحدد هذه التكرارات، عدا الاحتفاظ بالسجلات 12 شهراً. ما تكتبه في سياساتك يصبح المعيار الذي تُقيَّم عليه.

ثمانية مؤشرات تُرفع للجنة الإشرافية

لكل مؤشر: هدف معتمد، وحد أدنى، واتجاه عبر الزمن، لا الرقم الحالي فقط.

المؤشر	الضابط	طريقة الحساب
نسبة الامتثال الكلية	1-8-1	كما تحسبها أداة التقييم المعتمدة
تغطية حماية نقاط النهاية	2-3-3-1	الأجهزة المحمية ÷ الأجهزة في سجل الأصول
تغطية التحقق متعدد العوامل للمميزة	2-2-3-2	الحسابات المسجلة ÷ كل الحسابات المميزة
ثغرات تجاوزت مدة المعالجة	2-10-3-3	عددها وأعمارها حسب مستوى الخطورة
تغطية السجلات للأصول الحساسة	2-12-3-1	المصادر المربوطة ÷ الأصول الحساسة
نجاح اختبارات الاستعادة	2-9-3-3	الاختبارات الناجحة ضمن الهدف ÷ المنفذة
زمن تعطيل الحسابات بعد الانتهاء	1-9-5	متوسط الساعات من انتهاء الخدمة إلى التعطيل
نتيجة محاكاة التصيد	1-10-5	النقرات ÷ المستلمين، مع نسبة الإبلاغ

كيف يبدو الدليل: لوحة المؤشرات في تقرير اللجنة

ما الذي تراه

1. ثمانية مؤشرات، لكل منها قيمة حالية وهدف معتمد.
2. حالة واضحة لكل مؤشر: متحقق أو غير متحقق.
3. ما دون الهدف هو ما يناقشه الاجتماع ويقرر فيه.

ما الذي يبحث عنه المقيّم

- أن اللوحة تُرفع للجنة دورياً، ومحاضر تثبت مناقشتها.
- أن كل رقم يمكن تتبعه إلى مصدره في الأنظمة.
- خطة بمالك وموعد لكل مؤشر دون الهدف.

يثبت: 1-2-3 1-8-1 1-8-3

لوحة مؤشرات اللجنة الإشرافية · الربع الثالث 2026

المؤشر	القيمة	الهدف	الحالة
نسبة الامتثال الكلية	78%	90%	غير متحقق
حماية نقاط النهاية	97%	100%	غير متحقق
التحقق للحسابات المميزة	100%	100%	متحقق
ثغرات حرجة تجاوزت المدة	6	0	غير متحقق
تغطية السجلات للحساسة	92%	90%	متحقق
اختبارات الاستعادة	4 من 4	4 من 4	متحقق
تعطيل الحسابات	5 ساعات	8 ساعات أو أقل	متحقق
نقرات محاكاة التصيد	9%	5% أو أقل	غير متحقق

نموذج توضيحي من إعداد الكورس · البيانات والأسماء افتراضية

الاستعداد لتقييم الهيئة

قبل التقييم

- سجل أدلة محدث لكل ضابط، بأدلة ضمن فترة التقييم
- تقييم ذاتي حديث بأداة الهيئة، وخطط معالجة لفجواته
- مبرر موثق ومعتمد لكل ضابط «غير منطبق»
- منسق رئيسي، ومسؤول لكل مكون فرعي
- عرض موجز: الهيكل والنطاق والإنجازات والفجوات

أثناء التقييم وبعده

- قدّم الدليل المطلوب بالضبط، لا ملفات غير مطلوبة
- اعرض الأنظمة مباشرة عند الطلب، لا لقطات قديمة
- كن صريحاً في الفجوات، واعرض خطة معالجتها
- دوّن كل طلب وموعده، وتابعه حتى الإغلاق
- بعده: خطة تصحيحية تُعرض على اللجنة (3-8-1)

تذكّر

هذه ممارسات مقترحة من الكورس، لا إجراءات الهيئة الرسمية. اتبع دائماً تعليمات الهيئة وأداتها المعتمدة.

سبعة أخطاء شائعة في التطبيق وتصحيحها

#	الخطأ	التصحيح
1	التعامل مع ECC كمشروع تقني فقط	برنامج يشمل الاستراتيجية والأشخاص والإجراءات والتقنية
2	وثائق ممتازة بلا تطبيق	لكل وثيقة (X-1) دليل تطبيق (X-2) وأدلة تشغيلية للحد الأدنى (X-3)
3	شراء الأدوات قبل حصر الأصول وتصنيفها	الحصر والتصنيف والمخاطر أولاً، ثم الأدوات
4	التطبيق على جزء من النطاق	قياس التغطية بالمطابقة مع سجل الأصول
5	نسيان المراجعات الدورية بعد انتهاء المشروع	تقويم استدامة بمواعيد ومالكين
6	«غير منطبق» للضوابط الصعبة	مبرر موثق ومعتمد، أو خطة تطبيق بموعد
7	إغفال المتطلبات الوطنية الخاصة	تتبّع خاص لـ 1-2-1 و2-2-1 و3-8-2 و5-3-12-2 و3-3-13-2 و2-3-1-4

الأكثر شيوعاً

الخطأ الثاني هو الأشيع بلا منازع: حزمة سياسات معتمدة وممتازة، وتطبيق جزئي أو غائب.

تمرين 8 · المشروع التطبيقي · 40 دقيقة

خطة تطبيق مكون فرعي من جهتك

اختر مكوناً فرعياً واحداً من جهتك، واملأ البطاقة بحقولها السبعة. الشريحة التالية مثال مكتمل للمكون 2-2.

1. **الوضع الحالي:** ما المطبق اليوم، وما الفجوات؟
2. **الوثائق:** ما الذي يُكتب أو يُحدَّث ويُعتمد؟
3. **المبادرات:** ما الذي يُنفذ تقنياً وتشغيلياً؟
4. **الاعتماديات:** ما الذي يجب أن يسبقها؟
5. **المالكون والمواعيد:** من ينفذ، ومتى؟
6. **الأدلة:** ما الدليل الذي يثبت كل ضابط؟
7. **الاستدامة:** ما المؤشر، ومتى المراجعة الدورية؟

مثال مكتمل للتمرين 8 · جهة افتراضية

بطاقة تطبيق المكون 2-2: إدارة الهويات والصلاحيات

الحقل	المحتوى
1 · الوضع الحالي	دليل نشط مركزي، وتحقق متعدد العوامل للشبكة الافتراضية فقط، ولا حصر للمميزة ولا مراجعة للصلاحيات.
2 · الوثائق	تحديث سياسة الهويات، ومعيار كلمات المرور، وإجراء طلب الصلاحية ومراجعتها.
3 · المبادرات	حصر الحسابات المميزة، وتوسيع التحقق لها، ونظام لإدارة الصلاحيات المميزة، ومراجعة دورية.
4 · الاعتماديات	سجل الأصول (2-1)، وملاك الأنظمة (4-1)، ومنصة السجلات للجلسات المميزة (2-12).
5 · المالكون	[مدير الهويات] للحصر خلال شهر · [مدير البنية] للتحقق خلال 3 أشهر · [__] للنظام خلال 9 أشهر.
6 · الأدلة	الوثائق المعتمدة، ومطابقة المميزة مع التحقق، ونتائج حملات المراجعة، وسجلات الجلسات.
7 · الاستدامة	مؤشر تغطية التحقق للحسابات المميزة بهدف 100%، ومراجعة 4-2-2 في موعدها السنوي.

الوحدة 09 · الختام

09 الاختبار والختام

عشرة أسئلة تغطي المكونات الأساسية الأربعة، ثم خطتك بعد الكورس والخلاصة.

01	الاختبار: الأسئلة 1 إلى 5	الشريحة 170
02	الاختبار: الأسئلة 6 إلى 10	الشريحة 171
03	مفتاح الإجابات	الشريحة 172
04	خطتك بعد الكورس	الشريحة 173
05	الخلاصة	الشريحة 174

الاختبار النهائي · الأسئلة 1 إلى 5

اختبر فهمك (1 من 2)

1 ماذا يطلب الضابط 1-2-1؟

أ) ارتباط الأمن السيبراني بمدير التقنية | ب) إدارة مستقلة عن تقنية المعلومات والاتصالات | ج) إسناد الأمن السيبراني لطرف خارجي

2 من يعتمد سياسات الأمن السيبراني وفق 1-3-1؟

أ) مدير الأمن السيبراني | ب) اللجنة الإشرافية | ج) صاحب الصلاحية

3 متى يجب تقييم المخاطر وفق 3-5-1؟

أ) سنوياً فقط | ب) في أربع حالات، منها بداية المشاريع وقبل التغييرات الجوهرية | ج) عند طلب الهيئة

4 التحقق متعدد العوامل في 2-2-3-2 يشمل:

أ) الدخول عن بعد فقط | ب) الدخول عن بعد والحسابات ذات الصلاحيات الهامة | ج) كل المستخدمين داخل الشبكة

5 أي مصدر يذكره 4-3-3-2 مثالاً لمزامنة التوقيت؟

أ) هيئة المواصفات والمقاييس والجودة | ب) الهيئة الوطنية للأمن السيبراني | ج) مزود الإنترنت

الاختبار النهائي · الأسئلة 6 إلى 10

اختبر فهمك (2 من 2)

6 **ما الحد الأدنى للاحتفاظ بسجلات الأحداث السيبرانية؟**

أ) 6 أشهر | ب) 12 شهراً | ج) 24 شهراً

7 **أي ضابط يطلب الفحص الدوري لفعالية استعادة النسخ؟**

أ) 3-9-3-2 | ب) 1-10-3-2 | ج) 3-1-3-3

8 **ربط الشبكة اللاسلكية بالشبكة الداخلية وفق 4-3-5-2:**

أ) ممنوع مطلقاً | ب) مسموح دون شروط | ج) بعد تقييم شامل للمخاطر ومعالجتها

9 **مركز عمليات مُدار يراقب عن بعد من داخل المملكة وخارجها:**

أ) ممتثل | ب) غير ممتثل لـ 2-3-1-4 | ج) ممتثل إن كان المورد محلياً

10 **جهة لا تستخدم السحابة اليوم وتخطط لها العام القادم. ضوابط 2-4:**

أ) لا تنطبق | ب) تنطبق | ج) تنطبق بعد التعاقد فقط

الاختبار النهائي

مفتاح الإجابات

#	الإجابة	التوضيح	المرجع
1	ب	إدارة مستقلة عن تقنية المعلومات والاتصالات	الضابط 1-2-1
2	ج	صاحب الصلاحية	الضابط 1-3-1
3	ب	أربع حالات محددة كحد أدنى، لا تقييم سنوي فقط	الضابط 1-5-3
4	ب	الدخول عن بعد والحسابات ذات الصلاحيات الهامة	الضابط 2-2-3-2
5	أ	هيئة المواصفات والمقاييس والجودة	الضابط 2-3-3-4
6	ب	12 شهراً على الأقل	الضابط 2-12-3-5
7	أ	2-9-3-3	المكون 2-9
8	ج	بعد تقييم شامل للمخاطر ومعالجتها	الضابط 2-5-3-4
9	ب	مراكز التشغيل عن بعد بالكامل داخل المملكة	الضابط 4-1-3-2
10	ب	تنطبق على من يستخدم السحابة أو يخطط لاستخدامها	قابلية التطبيق

خطتك بعد الكورس: أربع خطوات

التعلم الحقيقي يبدأ عند التطبيق. هذه أربع خطوات عملية لتحويل ما تعلمته إلى عمل في جهتك:

01

اقرأ المرجع الرسمي

وثيقة ECC-2:2024 كاملة من موقع الهيئة، واستخدم هذا الكورس دليلاً لقراءتها.

02

طبّق على مكون واحد

أكمل بطاقة التمرين 8 لمكون فرعي من جهتك، واعرضها على مديرك خلال أسبوعين.

03

ابدأ سجل الأدلة

مجلدات بالرموز، ومالك لكل ضابط، وتاريخ لكل دليل، من اليوم الأول.

04

أكمل السلسلة

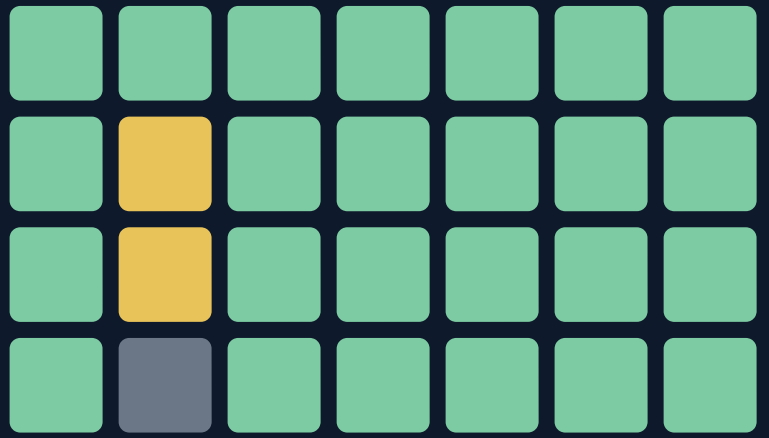
كورسا تقييم المخاطر وتقييم الفجوات يكملان ما تعلمته هنا.

نصيحة عملية

ابدأ صغيراً: مكون فرعي واحد مطبق بأدلة كاملة أفضل من عشرة مكونات على الورق فقط.

ختام الكورس

الخلاصة



1. **الأساس**
   حوكمة ومالكون وحصر للأصول قبل الأدوات.
2. **الطبقات**
   وثّق، وطبّق، وغطِّ الحد الأدنى، وراجع.
3. **الدليل**
   لكل ضابط دليل حديث يغطي النطاق كله.
4. **الاستدامة**
   تقويم مراجعات، ومؤشرات، وتقارير للجنة.

المرجع: الضوابط الأساسية للأمن السيبراني ECC-2:2024 الصادرة عن الهيئة الوطنية للأمن السيبراني. راجع nca.gov.sa لأحدث نسخة، والنص العربي هو المعتمد عند الاختلاف.